

Protocolo de comunicación de incidentes a clientes

Fecha 02/02/26

Divier Jácamo Álvarez

Parque metropolitano la libertad

Introducción

En este caso desarrollare un protocolo de comunicación a clientes ante algún incidente en la organización debe haber algo llamado transparencia técnica protegiendo las privacidades de dichos pacientes al no comunicarles dichos incidentes o encubrirlos a los clientes podría repercutir a una demanda por la violación de sus derechos y a procedimientos legales hacia la organización

A continuación se detallan los pasos principales del protocolo

1. Descubrimiento y clasificación

Identifique el alcance y determine inmediatamente si el ataque comprometió la confidencialidad de los datos la integridad o la disponibilidad.

Evaluar el riesgo: En salud mental, cualquier violación se considera de alto riesgo debido a la naturaleza de los datos.

2. Aviso a las autoridades

Aunque la Ley 8968 no tiene un límite de tiempo las disposiciones de la Ley 8968 y las buenas prácticas exigen actuar con rapidez.

¿A quién?: comunicarse con la PRODHAB

¿Qué reportar?: Tipo de incidente, categorías de datos afectados y acciones correctivas tomadas.

3. Comunicación con clientes

Según el principio de autodeterminación informada, los pacientes tienen derecho a saber qué sucede con su información.

Plazo: Debe ser inmediato si el incidente puede afectar a sus derechos por ejemplo el chantaje con datos clínicos

Qué pasó explica que hubo un acceso no autorizado.

Qué datos se vieron afectados: como nombres, diagnósticos, historial de citas

Qué deben hacer: se debe cambiar contraseñas si usan el portal del paciente tener cuidado con correos electrónicos sospechosos

4. Apoyo del CSIRT Nacional

Como PYME, puede buscar orientación técnica y reportar un incidente al CSIRT de Costa Rica para ayudar a prevenir ataques similares en la industria de la salud

Ahora hare un prototipo de bitácora de incidentes de como seria documentado y que lo use en un futuro me gusto el tipo de formato más organizado

campo	Descripción
ID del incidente	INC-2026-001
Fecha y hora de detención	2026/02/02 14:25 UTC
Analista responsable	Divier Jácamo Á
Categoría de incidente	Filtración de datos y acceso no autorizado
Nivel de sensibilidad	Datos sensibles (Salud)
Origen del incidente	IP externa con falla de proveedor de nube
Descripcion Tecnica	BD SQL comprometida
Impacto a clientes	Expedientes en riesgo
Acciones de contención	Se han revocado credenciales se ha apagado la instancia y se aplicó WAF
Estado de notificación	Se envió correo a pacientes y se ha comunicado a la PRODHAB
Estado de cierre	En investigación

Valor del servicio

Fecha 03/02/26

Divier Jácamo Álvarez

Parque metropolitano La Libertad

En este caso desarrollare el valor del servicio de ciberseguridad a un cliente sobre cómo que proceso de protección de sus datos los beneficios las protecciones de los pacientes al documentar esto demuestra como el monitoreo puede prevenir crisis que costarían dinero y reputación a la clínica

Valor del servicio: informe a cliente sobre cómo son resguardados sus datos personales

Valor invertido: mi supervisión garantiza que la clínica no cometa violaciones graves ante Prodhav, que pueden derivar en una multa de hasta 13,5 millones de colones o incluso sanciones penales si se filtra información.

Continuidad ante el MICITT: Costa Rica registró aproximadamente 29,1 millones de intentos de ciberataques solo en el primer semestre de 2025. Como Nivel 1, soy el primer filtro que evita que la clínica se convierta en una estadística más en los informes de incidentes monitoreados por el MICITT.

2. Protección del activo más importante: el historial médico

A diferencia de una tarjeta de crédito que se puede cancelar, un diagnóstico de salud mental filtrado causa un daño permanente a los pacientes.

Costos del mercado negro: El valor de una revista en la dark web puede oscilar entre \$30, que equivalen a 15 mil colones, hasta \$1.000, que equivalen a 500.000 colones, mientras que una tarjeta de crédito cuesta casi \$6, que equivale a 6.000 colones.

Impacto local: El trabajo que hago protege la reputación de la clínica en un mercado pequeño como Costa Rica, donde una filtración de datos de empleados públicos o pacientes privados significaría un cierre técnico del negocio debido a la pérdida de confianza de los clientes actuales o futuros.

3. Mediciones de valor para el informe mensual

Alertas de Acceso Incorrecto: Se bloquearon X intentos de accesos de datos de historias clínicas donde estoy garantizando total privacidad del paciente.

Disponibilidad del sistema: Gracias a los triajes preventivos, la operaciones del sistema de registros y contabilidad electrónica se mantuvo al 100%, evitando demoras en la asistencia médica.

Clasificación de phishing: Detectar correos electrónicos maliciosos dirigidos al personal administrativo, evitando el robo de datos que ha afectado a varias instituciones de este país.

este sería el prototipo de correo para enviar a los clientes cada mes

Descripción general del valor para el cliente

Mi trabajo como analista SOC nivel 1 es asegurar que la clínica cumpla estrictamente con los requisitos de la Ley 8968, proteja la privacidad de nuestros pacientes y evite multas millonarias. En un contexto donde Costa Rica recibe millones de ataques cada mes, mi supervisión constante garantiza que los médicos puedan diagnosticar sin interrupción y nunca dejar la información más sensible de estos clientes.

Avance Semanal

Divier jacamo alvarez

CETAV

Rol: Analista SOC L1

Fecha 04/02/2026

Escenario de caso en clínica de salud mental

El SIEM de la Clínica Médica Integral genera una alerta de correlación que es recibida inicialmente por el Analista SOC Nivel 1.

La alerta corresponde a un inicio de sesión exitoso en el sistema de información clínica utilizando una cuenta de un usuario administrativo.

Al revisar el evento, el analista SOC Nivel 1 observa que el acceso se realiza fuera del horario habitual de trabajo del usuario y desde un punto de acceso que no coincide con sus registros históricos de

conexión.

Minutos después del inicio de sesión, se registraron múltiples consultas consecutivas a expedientes clínicos de diferentes pacientes en un periodo de tiempo muy corto, además de un comportamiento

anormal.

La cantidad de accesos durante las primeras horas es superior al comportamiento normal de ese usuario dentro del sistema.

Durante la misma sesión, el SIEM también registra eventos relacionados con operaciones internas sobre archivos del sistema de información clínica.

Debido a que el comportamiento observado no corresponde con dicho uso habitual del usuario y puede implicar un riesgo para la información clínica de la institución, el Analista SOC Nivel 1 documenta la alerta y eleva el caso para su análisis al Analista SOC Nivel 2.

Mi respuesta como Analista SOC 1

Como Analista SOC Nivel 1, antes de proceder con la elevación del caso, se realiza la validación inicial del incidente a partir de la alerta

Generado por el SIEM.

Primero, verifique si la alerta es real. Para hacer esto, observe los registros de cuándo alguien se conectó al sistema. Comprobamos la cuenta que está involucrada, la fecha y la hora en que alguien accedió, y el sistema que se vio afectado quiero asegurarme de que la conexión al sistema fue exitosa y que sucedió en un momento en que

el usuario normalmente no está trabajando.

Posteriormente, se revisan los registros de acceso al sistema de información clínica con el fin de confirmar la cantidad de expedientes consultados durante la sesión y el intervalo de tiempo en el que se produjeron los accesos, comprobando que el volumen de consultas es superior al comportamiento histórico del usuario.

A continuación, examinare los eventos relacionados con la sesión para encontrar actividades adicionales esto incluye comprobar si hay operaciones sobre archivos dentro del sistema clínico.

También se revisan, de forma general, los registros disponibles del equipo origen y del sistema de red para confirmar que la actividad se concentra en una única sesión y en una sola cuenta de usuario.

Finalmente, una vez confirmada la anomalía y sin realizar acciones de contención directa, el Analista SOC Nivel 1 documenta los hallazgos iniciales, clasifica el evento como incidente potencial de seguridad y procede a elevar el caso al Analista SOC Nivel 2 para su análisis especializado.

Caso Analista SOC 1 sin elevación a Analista SOC 2

El día de hoy martes se recibió una alerta en el sistema de monitoreo.

Esta alerta se debe a que se ha conectado un dispositivo USB externo a una computadora en la zona 2, la cual es la red administrativa.

Además, se han detectado procesos que no suelen ejecutarse en esa computadora; como primera acción valide la alerta en la plataforma SIEM, confirmando la hora de conexión del dispositivo USB el equipo afectado y la cuenta de usuario que se encontraba activa en la estación de trabajo.

Posteriormente revisa los registros del sistema operativo enviados al SIEM y verifica que el evento de detección del dispositivo USB coincide temporalmente con el inicio de los procesos inusuales.

El analista identifica que la actividad se origina únicamente desde una estación de trabajo de la red administrativa y que no existen, hasta ese momento, registros de accesos exitosos a los servidores de la Zona 5. Se revisan los eventos del firewall y se confirma que las conexiones desde el equipo administrativo hacia los servidores internos no se establecieron como deberían.

Se procedió a analizar los procesos con el threat intelligence del SIEM se investigó si los procesos correspondían a herramientas legítimas se procedió a documentar la coincidencia de dichas firmas

Los procesos inusuales fueron terminados y puestos en cuarentena automáticamente por políticas de seguridad

Se verifico en el directorio si dicho USB tiene un número de serie registrado por el hospital

Reporte Final en el SIEM

Se cierra la alerta como un falso positivo por actividades no autorizadas, aunque dichos procesos fueron inusuales el análisis del firewall confirmo que no salieron datos ni saltos en la zona 5 el usuario valido sus actividades y se procedió a eliminar dichos archivos temporales

Avance Semanal
Divier Álvarez
Cetav
Rol: Analista SOC L1

Fecha 05/02/26

Registro de eventos en Windows y Linux

Introducción

Los sistemas operativos modernos incluyen un mecanismo de registro de eventos llamado registro que le permite almacenar información importante sobre la actividad del sistema.

Estos registros son esenciales para la administración, el monitoreo y la seguridad de TI porque facilitan la detección de incidentes, el análisis de errores y las pruebas. Este trabajo analizó los principales tipos de registros de eventos generados por los sistemas operativos Windows y Linux, enfocándose en la autenticación de usuarios, intentos fallidos de acceso, ejecución de procesos y modificaciones de archivos críticos.

Registro de eventos en sistemas Windows

En el sistema operativo Windows, los registros de eventos se administran mediante el Visor de eventos, que le permite ver y analizar eventos generados por el sistema y las aplicaciones.

Error de autenticación y acceso

El registro de seguridad almacena información relacionada con los inicios y cierres de sesión de los usuarios. Este registro registra tanto los accesos exitosos como los fallidos, incluida información como el nombre de usuario y el tipo de inicio de sesión. Estos eventos nos permiten identificar intentos de acceso no autorizados y posibles amenazas a la seguridad del sistema

Ejecutar el proceso

Si la auditoría está habilitada, Windows puede registrar la creación y finalización de procesos. Estos registros proporcionan información sobre los programas en ejecución, los usuarios responsables y los tiempos de ejecución, lo que resulta útil para monitorear la actividad y detectar comportamientos inusuales.

Cambiar archivos importantes

El sistema operativo también le permite auditar los permisos de acceso y los cambios en archivos y carpetas importantes. Este tipo de registro es clave para detectar cambios no

autorizados en archivos del sistema o configuraciones importantes que podrían afectar la estabilidad o seguridad de su computadora.

Registro de eventos en sistemas Linux

En los sistemas Linux, los registros de eventos se almacenan principalmente en el directorio `/var/log`, aunque su organización puede variar según la distribución utilizada. Error de autenticación y acceso

El registro de autenticación contiene información sobre los intentos de inicio de sesión del usuario, tanto local como remoto. Registran el acceso exitoso, el acceso fallido y el uso de privilegios administrativos, lo que permite identificar posibles intentos de intrusión

Linux proporciona herramientas de auditoría que le permiten registrar la ejecución de procesos. Estos registros pueden mostrar qué usuarios ejecutaron un comando, cuándo lo ejecutaron y, en algunos casos, qué acción realizaron, lo que facilita el seguimiento de la actividad en el sistema. Cambiar archivos importantes

El sistema también puede rastrear los cambios realizados en archivos confidenciales, por ejemplo relacionados con usuarios, contraseñas o configuraciones del sistema. Monitorear estos archivos es necesario para mantener la integridad y seguridad del sistema operativo.

Importancia de los registros de eventos

El análisis de registros de eventos es una práctica de seguridad informática esencial porque ayuda a detectar problemas, investigar errores, realizar auditorías y garantizar el cumplimiento de las normas de seguridad tanto Windows como Linux tienen mecanismos de registro que brindan información valiosa para la administración y seguridad del sistema.

Análisis de eventos generados por un ataque de ransomware

El ransomware es un malware que cifra la información de un sistema con el objetivo de exigir un pago para su recuperación. Durante su ejecución, este tipo de ataque genera diversos eventos detectables en el sistema operativo, los cuales pueden ser identificados a través del análisis de los registros de eventos el estudio de estos registros resulta fundamental para la detección temprana y el análisis de incidentes de seguridad.

Eventos detectables durante un ataque de ransomware

En la fase de dichos ataques, el sistema registra la ejecución de procesos maliciosos, generalmente asociados a archivos descargados o adjuntos abiertos por el usuario estos eventos permiten identificar programas ejecutados desde ubicaciones inusuales o sin firma confiable.

Posteriormente, el ransomware puede intentar obtener persistencia o privilegios elevados, lo que genera eventos relacionados con cambios en configuraciones del sistema o uso de cuentas con permisos administrativos.

Durante la fase principal del ataque, el cifrado masivo de archivos produce múltiples accesos y modificaciones lo cual constituye un comportamiento anómalo fácilmente detectable mediante auditoría de archivos. Finalmente, suelen registrarse eventos asociados a la creación de mensajes de rescate, eliminación de copias con servidores externos.

Importancia del análisis de eventos

El análisis de los eventos generados por un ataque de ransomware permite reconstruir la

secuencia del ataque, identificar el punto de entrada y apoyar las acciones de respuesta ante incidentes. Por ello, el monitoreo adecuado de los registros del sistema operativo es una medida clave para fortalecer la seguridad informática.

Tabla tecnica de eventos para la detencion temprana de incidentes

Sistema operativo	Categoría	Evento	Descripción	Indicador de incidente
Windows	Autenticación	ID 4625	Intentos de acceso fallido	Posible ataque de fuerza bruta
Windows	Autenticación	ID 4624	Inicio de sesion exitoso desde ubicación desconocida	Acceso no Autorizado
Windows	Procesos	ID 4688	Creación de nuevo proceso	Ejecucion de malware
Windows	Procesos	Sysmon Event ID 1	Ejecucion de procesos con hashes desconocidos	Archivo malicioso
Windows	Archivos	ID 4663	Modificación de archivos	Cifrado masivo de archivos
Linux	Persistencia	Cambios sin registro	Modificacion de inicio automatico	Persistencia de malware
Linux	Autenticación	/Var/log/auth.log	Multiples intentos de acceso fallidos	Ataque de fuerza bruta
Linux	autenticación	Var/log/secure	Uso inusual de privilegios sudo	Escalamiento de privilegios
Linux	Procesos	Auditd -execve	Ejecucion de comandos no habituales	Ejecucion de ransomware
Linux	Archivos	Auditd open/write	Escritura masiva de archivos críticos	Cifrado de información
Linux	Configuración	auditd	Modificacion de archivos en /etc	Alteración del sistema
Linux	Red	Logs de firewall	Conexiones salientes a IP desconocidas	Comunicación con servidor malicioso

Importancia de la detección temprana

La identificación temprana de estos eventos permite detectar comportamientos anómalos antes de que el incidente tenga un impacto significativo. La correlación de múltiples eventos, como ejecuciones sospechosas junto con modificaciones masivas de archivos, es clave para una respuesta rápida y efectiva ante incidentes de seguridad.

Listado de logs que el SOC puede monitorear

Categoría	Fuente de log	Tipo de log	Relevancia para el SOC
Sistemas operativos Windows	Security Log	Inicio de sesión exitoso cambios de privilegios	Detectar accesos no autorizados a historiales clínicos
Sistemas operativos Windows	System log	Errores de hardware	Garantiza disponibilidad de sistemas críticos
Sistemas operativos Windows	Application log	Fallos de aplicaciones médicas	Detención de interrupciones en aplicaciones
Sistemas operativos windows	Powershell log	Ejecución de scripts y comandos	Identificación de actividad maliciosa
Sistemas operativos Windows	Sysmon	Creación de procesos	Detención de ransomware o malware
Sistemas operativos Linux	/var/log/auth.log	Intentos de acceso fallidos	Prevención de accesos no autorizados
Sistemas operativos Linux	auditd	Acceso a archivos de historiales médicos	Monitoreo de cambios anómalos en archivos sensibles
Redes y seguridad	firewalls	Conexiones bloqueadas	Detecta intentos de intrusión
Redes y seguridad	IDS/IPS	Alertas de firmas de ataque y anomalías	Identificación temprana de malware
Aplicaciones y servicios críticos	Servidores de bases de datos	Accesos y modificaciones	Protección contra exfiltración de información
Aplicaciones y servicios críticos	Correo	Archivos adjuntos sospechosos	Detención de phishing al personal sanitario
Dispositivos y endpoints	Antivirus	Alertas de malware y eliminación de archivos	Monitoreo de endpoints en estaciones de enfermería
Fuentes Adicionales	SIEM	Correlación de eventos de múltiples fuentes	Permite análisis integral y respuesta rápida ante incidentes

Conclusión del Análisis

La monitorización de eventos en hospitales psiquiátricos es esencial para la detección temprana de incidentes de seguridad y la protección de datos confidenciales de los pacientes.

Supervise los registros de los sistemas operativos, redes, aplicaciones de misión crítica, puntos finales y soluciones SIEM de Windows y Linux para identificar accesos no autorizados, ransomware, phishing, movimiento lateral de malware y fallas en sistemas críticos. La correlación de eventos ayuda a priorizar las alertas, optimizar la respuesta SOC clínica y la continuidad de los servicios hospitalarios. Además, adaptar la monitorización al entorno hospitalario teniendo en cuenta las normas de privacidad como HIPAA y GDPR mejorará la protección de los registros médicos y la gestión proactiva de la seguridad.

Fecha 06/02/26

Métodos de clasificación de alarmas utilizados en los Centros de Operaciones de Seguridad SOC

Introducción

El aumento de la sofisticación de las ciberamenazas y la proliferación de herramientas de monitoreo ha resultado en una sobrecarga de alertas para los SOC; diversos estudios muestran que una gran proporción de estas alertas corresponden a falsos positivos o lo que aumentaría mucho al cansancio del analista y aumenta el riesgo de pasar por alto situaciones críticos en este contexto, la clasificación de alarmas se consolida como una función esencial para garantizar una respuesta eficaz ante incidentes de seguridad.

2. Proceso de triajes y clasificaciones de alarmas

En los SOC la clasificación de las alarmas está integrada en el proceso de distribución de alarmas, que consiste en la evaluación, categorización y priorización sistemática de las alertas de seguridad este proceso suele implicar los siguientes pasos la validación inicial de recepción y aceptación de alertas de sistemas como SIEM, EDR o IDS, donde se decide si la alerta corresponde a un evento real o a un falso positivo clasificando la alerta como benigna, sospechosa o maliciosa Priorizando en el impacto, la criticidad de los activos y la probabilidad de usos el escalar si se requiere un análisis más profundo o una respuesta especializada este enfoque es consistente con las recomendaciones

del NIST para manejar incidentes de seguridad.

3. Técnicas basadas en reglas y contexto

Los SOC tradicionales utilizan sistemas SIEM para clasificar alertas mediante reglas de correlación predefinidas estas reglas combinan eventos de diferentes fuentes y generan alertas cuando se cumplen ciertas condiciones, como el cumplimiento de indicadores conocidos de compromiso aunque este enfoque ofrece trazabilidad y control, tiene limitaciones frente a nuevas amenazas o técnicas de evasión porque depende en gran medida del conocimiento previo y el mantenimiento constante de reglas.

4. Automatización mediante SOAR

Las plataformas SOAR complementan SIEM al automatizar tareas repetitivas en el proceso de clasificación las guías real SOC SOAR le permitirían que enriquezca las alertas con inteligencia sobre amenazas al tomar decisiones de clasificación automatizadas para casos de baja complejidad y reducir el tiempo medio de análisis según gartner, el uso de SOAR ha reducido significativamente la carga operativa de los analistas de nivel 1.

5. Clasificación basada en aprendizaje automático

Los SOC avanzados incorporan técnicas de aprendizaje automático para mejorar la

clasificación y priorización de alarmas los enfoques más comunes incluyen

Aprendizaje supervisado entrenado sobre alertas previamente etiquetadas como verdaderas o

falsas, aprendizaje no supervisado utilizado para detectar anomalías y agrupar alertas

similares sistemas adaptativos que incorporan feedback de analistas para mejorar

continuamente el modelo estas técnicas nos permiten reducir el ruido y descubrir patrones

complejos que no pueden identificarse únicamente mediante reglas estáticas.

6. Contextualización mejorada y modelos híbridos.

Las técnicas de última generación utilizan modelos basados en gráficos para vincular alertas,

eventos y activos, lo que permite la visualización de cadenas de ataques completas asimismo,

alinear las alertas con marcos en tácticas y técnicas del adversario, mejorando la comprensión

del contexto del incidente en la práctica, la mayoría de los SOC utilizan modelos híbridos en

los que la automatización maneja alertas de bajo riesgo mientras los analistas humanos toman

decisiones en casos inciertos o críticos.

Conclusiones

Los métodos de clasificación de alarmas en SOC reales han evolucionado desde enfoques

manuales y basados en reglas hasta modelos híbridos que integran automatización,

aprendizaje automático y análisis humano; no existe una metodología universal; en cambio,

los SOC exitosos adaptan los procesos a nivel de madurez y perfil de riesgo clasificar

correctamente las alertas no solo mejora la eficacia del SOC, sino que también aumenta la capacidad de detectar y responder a amenazas avanzadas.

Matriz de clasificación de alarmas basada en la gravedad del SOC

.Propósito de la matriz

La matriz de clasificación de alertas tiene como objetivo estandarizar la evaluación, priorización y respuesta a eventos de seguridad detectados por las herramientas SOC. El objetivo de criterios claros y repetibles es reducir la ambigüedad en la toma de decisiones, minimizar los falsos positivos y garantizar una asignación eficaz de los recursos del SOC basada en el riesgo

Nivel de severidad	Descripción	Criterios Técnicos	Ejemplos de alertas	Acción Requerida	Responsable
Critica	Incidente confirmado	Evidencia clara	Ransomware activo	Contención inmediata	SOC L2
Alta	Actividad maliciosa	Indicadores confiables	Movimiento lateral	Investigación profunda	SOC L1 Y L2
Media	Actividad sospechosa	Anomalías de comportamiento	Escaneo interno	Monitoreo y análisis contextual	SOC L1
Baja	Evento anómalo	Desviación leve de comportamiento normal	Login fallido	Registro y seguimiento	SOC L1
Informática	Evento benigno	Eventos conocidos y controlados	Actualizaciones del sistema	Solo registro	Automatizado

Matriz de clasificacion de alertas basada en severidades

Severidad	Prioridad por defecto	Tiempo de Respuesta
Critica	Maxima	24 horas
Alta	Alta	4 horas
Media	Media	1 hora
Baja	Baja	15 minutos
Informativa	Muy baja	N/A

Criterios Tecnicos de clasificacion de Alertas criticas medias y bajas

Introducción

El creciente número de alertas generadas por las herramientas de seguridad modernas ha hecho que la clasificación de la gravedad sea un elemento crítico de las operaciones SOC sin criterios técnicos claramente definidos, los analistas enfrentarán decisiones inconsistentes, más falsos positivos y un uso ineficiente de los recursos en este contexto, es necesario establecer criterios formales para diferenciar objetivamente las alertas críticas, medias y bajas, teniendo en cuenta tanto los factores técnicos como el impacto potencial en la organización.

Método de diseño de criterios.

La diferenciación de gravedad propuesta se basa en un enfoque de criterios múltiples, donde la gravedad de la advertencia se determina basándose en una combinación de varias especificaciones este enfoque sigue las mejores prácticas recomendadas por plataformas y permite procesos tanto manuales como automatizados.

Parámetros considerados: evidencia de actividad maliciosa, impacto en los recursos, criticidad de los recursos, probabilidad de explotación y escala del evento.

Este parámetro evalúa el grado de certeza técnica de que este evento corresponde a una actividad maliciosa real se tienen en cuenta los índices de compromiso las coincidencias con firmas conocidas y las correlaciones entre eventos.

Evidencia alta: uso confirmado, que involucra infraestructura maliciosa conocida.

Nivel de evidencia moderado: conducta aberrante persistente o empíricamente corregida bajo nivel de evidencia son eventos aislados sin correlación ni indicación confiable Impacto en los activos se refiere al impacto real o potencial de un evento en la seguridad, integridad y

disponibilidad de un sistema es el alto Impacto que es una violación directa de información
confidencial o interrupción del servicio la de

Impacto medio es la interferencia limitada o atenuación parcial y el Impacto bajo es que no se
detectaron consecuencias operativas.

Criticidad de los recursos afectados

La clasificación de activos se basa en el inventario de activos del SOC y su importancia para
el negocio. Activos Críticos son sistemas que son necesarios para operar o contienen
información sensible una ventaja importante es el soporte para servidores y aplicaciones
internos. Recursos no críticos son la estación de trabajo del usuario o entorno de prueba.

Posibilidad de explotación

Esta medida evalúa la probabilidad de que una amenaza detectada sea explotada con éxito
alta probabilidad las vulnerabilidades se están explotando activamente o se están utilizando
exploits públicos que son la probabilidad media son vulnerabilidades conocidas pero sin
signos de explotación activa las de probabilidad baja que son las condiciones operativas no se
pueden lograr o no se pueden mitigar evaluar la escala espacial y temporal de un evento en un
ambiente controlado y las de alcance alto Son las que se ven afectados múltiples recursos o
hay movimiento lateral

Escala media es la repetición de un evento en el mismo tema. Baja escala son los eventos específicos y aislados clasificar las advertencias por nivel de gravedad y las advertencias importantes

Las alertas críticas corresponden a incidentes confirmados o altamente probables, que afectan a activos críticos y tienen un impacto significativo. a menudo incorporan un alto nivel de pruebas técnicas, un impacto directo sobre la confidencialidad, la integridad o la disponibilidad y una amplia gama de aplicaciones ejemplos de este nivel incluyen ejecutar ransomware, robar datos o comunicarse activamente con servidores de comando y control.

Advertencias medias

Las alertas de gravedad media reflejan actividad sospechosa en curso que podría provocar incidentes con consecuencias más graves si no se investigan rápidamente. Aunque no existe una confirmación completa del cumplimiento, aún se puede observar una correlación entre eventos o anomalías persistentes.

Los ejemplos comunes incluyen el uso inusual de herramientas administrativas, análisis internos repetidos o intentos de autenticación correlacionados advertencia de nivel bajo las alertas de gravedad baja corresponden a eventos noticiosos o anomalías leves sin signos evidentes de actividad maliciosa tienen un impacto mínimo o nulo y, a menudo, afectan a

recursos no críticos los ejemplos incluyen intentos fallidos de inicio de sesión o eventos programados fuera del horario comercial normal.

Modelos de decisión y umbrales de materialidad

Para facilitar la automatización, cada parámetro se puede evaluar numéricamente en una escala del uno al tres, donde un parámetro es bajo y tres es alto la puntuación total le permite asignar niveles de gravedad según umbrales predefinidos este modelo promueve la reproducibilidad de la clasificación y reduce la dependencia del juicio personal del analista.

Conclusión

Establecer criterios técnicos formales para distinguir entre alertas críticas, moderadas y bajas mejorará la coherencia y eficiencia del proceso de clasificación SOC el modelo propuesto proporciona una base sólida tanto para la implementación operativa como para la justificación académica al integrar aspectos técnicos objetivos de acuerdo con estándares reconocidos su uso contribuye a una mejor priorización de los incidentes y una respuesta más eficaz a las amenazas a la seguridad

Análisis de tratamiento de alertas dentro del flujo operativo

Introducción

Una vez que las alertas de seguridad se clasifican por gravedad, el SOC debe integrarlas en un flujo de trabajo estructurado para garantizar una respuesta eficaz y coherente. La importancia actúa como un mecanismo de control que gobierna la asignación de recursos, el tiempo de respuesta y la profundidad del análisis. En este sentido, el tratamiento diferencial de los niveles de alerta críticos, medios y bajos es fundamental para evitar la sobresaturación de los analistas y asegurar una atención priorizada a los incidentes de mayor impacto.

Flujo general de gestión de alarmas dentro del SOC

Un flujo de trabajo SOC típico incluye los siguientes pasos

Generar alertas utilizando herramientas de detección.

Enriquecimiento automatizado utilizando inteligencia sobre amenazas y contexto de activos.

Categorizar y priorizar según criterios importantes identificados.

Analizar personas por nivel de gravedad respuesta y protección, en su caso

Cierre y retroalimentación, incluidas las lecciones aprendidas el nivel de gravedad determina

cómo se realiza cada uno de estos pasos.

3. Manejar alertas críticas

Las alertas críticas se envían al flujo SOC con la máxima prioridad, lo que activa inmediatamente los mecanismos de notificación y presentación de informes. Estas alertas a menudo se generan en base a correlaciones complejas o hallazgos de alta confianza, como indicadores verificados de violaciones de seguridad.

Análisis e informes

El análisis preliminar se puede realizar automáticamente, pero se pasa rápidamente a analistas de nivel 2 o 3. El objetivo de esta fase es confirmar el alcance de la infracción, identificar técnicas de ataque y evaluar el verdadero impacto en los recursos críticos.

Respuesta y prevenciones

Las advertencias críticas desaparecieron de las acciones de soporte inmediato, las historias del sistema operativo, la revocación de credenciales o el bloqueo de mensajes maliciosos.

Estas actividades se pueden automatizar utilizando SOAR, pero se requiere el juicio humano para lograr altos niveles de impacto operativo

Cierre y retroalimentación

Cerrar las alertas críticas requiere documentación detallada del incidente, análisis de la causa raíz y ajuste de las reglas, scripts o modelos de detección. Esta retroalimentación es importante para mejorar las capacidades SOC futuras. 4. Admite advertencia media

Análisis de contexto

Las alertas de nivel medio generalmente se asignan a analistas de Nivel 1 o Nivel 2, quienes realizan un análisis contextual más profundo para determinar si una actividad sospechosa tiene el potencial de convertirse en un incidente grave. En esta etapa, se analizarán patrones históricos, comportamiento de los usuarios y correlaciones adicionales.

Decisión de actualizar

El manejo de estas advertencias se caracteriza por una toma de decisiones condicional. Si se identifican nuevos signos de infracción o expansión, la alerta puede reclasificarse como crítica y tomarse las medidas adecuadas.

Retroalimentación controlada

Las acciones para responder a alertas de nivel medio suelen ser limitadas y reversibles, e

incluyen aumentar el monitoreo, realizar análisis adicionales o requerir revisión de otras áreas técnicas.

Cierre

Si no se confirma la actividad maliciosa, la alerta se considerará un evento falso positivo o inofensivo y se registrará la información relacionada para mejorar la clasificación futura.

Manejo de alarma baja

Las alertas de baja gravedad se gestionan en su mayoría de forma automática. El SOC puede aplicar políticas automáticas de contención, agrupamiento o cierre si determina que el evento no representa un riesgo significativo.

Análisis mínimo

En el caso de la verificación humana, el análisis es superficial y se limita a comprobar si el evento está asociado a alertas de mayor importancia. Estas alertas suelen ser gestionadas por analistas de nivel

Incluso cuando no hay respuesta, las alertas de bajo nivel se conservan para análisis estadístico y detección de tendencias, lo que le permite identificar patrones emergentes o cambios en el comportamiento normal

Conclusión

El análisis del manejo de alertas en el flujo SOC muestra que la validez es importante para la toma de decisiones operativas. Si bien las alertas críticas requieren atención inmediata y análisis dedicado, las alertas medias actúan como un mecanismo de detección temprana y las alertas bajas le permiten mantener la visibilidad sin estresar a su equipo un flujo SOC claramente definido, respaldado por criterios técnicos sólidos, mejorará significativamente la eficacia de la gestión de incidentes de seguridad.

Avance semanal

Divier Álvarez

Cetav

Rol: Analista SOC L1

Fecha 09/02/26

Funcionamiento de los sistemas SIEM y su rol en la correlación de eventos

Introducción

Hoy en día, las organizaciones deben lidiar con un aumento de amenazas en el ciberespacio, lo que exige métodos más sofisticados para detectar y responder a estos peligros. Los sistemas de Gestión de Información y Eventos de Seguridad (SIEM) se han vuelto esenciales para manejar la seguridad, ya que permiten recolectar, analizar y relacionar eventos de diversas fuentes. Su mayor ventaja es que pueden convertir grandes cantidades de datos en información útil, lo que ayuda a identificar incidentes de seguridad de manera temprana y cumplir con las normativas.

Concepto y componentes de un sistema SIEM

Un sistema SIEM es una herramienta tecnológica que combina las funciones de Gestión de Información de seguridad y examinar eventos en tiempo real estos sistemas recopilan datos por herramientas de seguridad, como cortafuegos, sistemas que detectan intrusiones y antivirus.

Los elementos principales de un SIEM incluyen el módulo que recoge los datos, el motor que normaliza la información, un sistema que almacena todo de forma centralizada y el motor que analiza y relaciona los eventos la normalización ayuda a uniformizar los eventos de diferentes fuentes, facilitando su análisis después. Además, los SIEM suelen tener paneles de visualización y sistemas que generan alertas, lo que ayuda al equipo de seguridad en su toma de decisiones.

Funcionamiento de los sistemas SIEM

se basa en un ciclo constante que comienza con la recopilación de eventos. Estos datos son enviados al sistema usando agentes o protocolos comunes, como Syslog o API una vez que los eventos llegan, se filtran y normalizan para eliminar la información repetida y ajustarse a un formato estándar.

Después, el SIEM guarda los eventos en repositorios seguros que permiten acceder a ellos en el futuro. Esta capacidad es crucial tanto para el análisis forense como para asegurar que se sigan las normativas de seguridad y auditoría por último, el motor de análisis revisa aplicando reglas establecidas, modelos estadísticos o métodos de análisis avanzado para detectar comportamientos inusuales.

Rol de la correlación de eventos en los SIEM

La correlación de eventos es uno de los elementos más importantes de los sistemas SIEM este proceso implica vincular varios eventos individuales que, por sí solos, pueden no parecer peligrosos pero que, juntos, pueden señalar un posible problema de seguridad a través de reglas de correlación, el SIEM puede identificar patrones complejos, como intentos de acceso no autorizado, movimientos sospechosos dentro de la red o intentos de robar información.

La correlación ayuda a disminuir la cantidad de errores de alerta y a dar prioridad a las notificaciones según su grado de riesgo, mejorando así el trabajo de los analistas de seguridad además, algunos sistemas SIEM modernos utilizan técnicas de aprendizaje automático para aumentar la precisión de la correlación, adaptándose al comportamiento habitual de la infraestructura y reconociendo desviaciones importantes.

Importancia de los SIEM en la gestión de la seguridad

El uso de sistemas SIEM trae beneficios importantes para las organizaciones, como una visión central de la seguridad, una mejor detección de incidentes y la capacidad de responder rápidamente a las amenazas al mismo tiempo, los SIEM ayudan a cumplir con normas y regulaciones como ISO/IEC 27001, PCI DSS y GDPR, al ofrecer pruebas y reportes

detallados sobre eventos de seguridad.

Sin embargo, la efectividad de un SIEM depende de una configuración adecuada, del diseño correcto de las reglas de correlación y del entrenamiento del personal que lo maneja si no se tienen en cuenta estos factores, el sistema puede producir un gran número de alertas inútiles o ignorar incidentes importantes.

Conclusión

Los sistemas SIEM son fundamentales para proteger los sistemas de información, ya que permiten la recolección, análisis y correlación de eventos de seguridad de forma centralizada. Su habilidad para correlacionar eventos de diferentes fuentes los convierte en herramientas esenciales para detectar a tiempo amenazas complejas. En un entorno digital que se vuelve más dinámico y peligroso, implementar correctamente un SIEM es un elemento clave en cualquier programa completo de ciberseguridad.

Diagrama de Flujo de monitoreo de SOC

Explicación del flujo

Dispositivos y sistemas para hospitales psiquiátricos.

Estos incluyen sistemas de registros médicos electrónicos, servidores de bases de datos de pacientes, estaciones de trabajo del personal médico, cámaras de seguridad, firewalls y sistemas de control de acceso físico y lógico.

Generación de eventos

Se produce un incidente, por ejemplo, un intento de obtener acceso no autorizado a un sistema de registro de pacientes psiquiátricos. Colección de registros
Los registros generados por los sistemas se envían al SIEM mediante agentes o protocolos como Syslog.

Normalización y filtrado en SIEM

SIEM estandariza eventos para facilitar el análisis y eliminar información redundante o irrelevante. Almacenamiento centralizado
Los eventos se almacenan en un repositorio seguro que permite auditorías y análisis forenses posteriores, lo cual es fundamental debido a la sensibilidad de los datos de salud mental.

Correlación de eventos

SIEM correlaciona múltiples eventos, como accesos fallidos repetidos fuera del horario comercial y desde una ubicación inusual, para identificar patrones de riesgo.

Evaluación del evento

Se determina si el comportamiento es consistente con una actividad normal o sospechosa.

Clasificación del nivel de riesgo

Si el evento es sospechoso, se clasifica según su impacto y criticidad, teniendo en cuenta la confidencialidad de la información médica. Generación de alarma

El SIEM crea una alerta detallada con información relevante sobre el evento detectado.

Declaración del analista de SOC

Un analista recibe una alerta para comenzar el proceso de análisis, contención y respuesta al incidente.



Validación manual de incidentes por analista SOC

Introducción

Aunque los sistemas SIEM automatizan la recopilación, el análisis y la correlación de eventos de seguridad, la intervención de los analistas de SOC sigue siendo fundamental para garantizar una detección precisa de eventos en entornos sensibles, como un hospital psiquiátrico donde se manejan datos clínicos altamente confidenciales, la validación manual es clave para reducir los falsos positivos y evaluar adecuadamente el impacto de los eventos detectados.

Puntos críticos de validación manual.

Uno de los puntos más importantes en los que debe intervenir un analista es la correlación posterior al evento, donde SIEM identifica patrones potencialmente maliciosos. El analista valida el contexto del evento, teniendo en cuenta factores como horarios atípicos, roles del personal médico y acceso de emergencia que son comunes en entornos de atención médica.

Otro punto importante es la clasificación del nivel de riesgo. Mientras el SIEM asigna un nivel de gravedad inicial, el analista evalúa manualmente el impacto real en la confidencialidad, integridad y disponibilidad de la información psiquiátrica, ajusta la prioridad de alerta según el sistema afectado y el tipo de datos involucrados.

Además, durante la revisión de las alertas generadas, el analista confirma la validez técnica del evento, verifica configuraciones, eventos relacionados y recurrencia. Esta validación evita la escalada innecesaria de alertas inapropiadas y optimiza la respuesta del SOC. Finalmente, antes de pasar a un incidente de seguridad, el analista decide manualmente si activa protocolos de respuesta, notifica el cumplimiento legal o regulatorio, lo cual es especialmente importante en las organizaciones de atención médica.

Documentación técnica del proceso de monitorización de seguridad SOC.

Introducción

El monitoreo de seguridad es una función clave ya que permite la detección, análisis y respuesta oportuna a eventos que puedan comprometer los sistemas de información en un hospital psiquiátrico, este proceso adquiere mayor relevancia debido a la sensibilidad de los datos clínicos y psiquiátricos ingresados. El monitoreo técnico se basa principalmente en sistemas SIEM que automatizan la recopilación y el análisis de eventos, aunque se requiere monitoreo y validación humanos para garantizar su efectividad.

Una colección de eventos

El proceso técnico comienza con la recopilación de eventos de seguridad generados por varios sistemas hospitalarios, como registros médicos electrónicos, servidores de bases de datos, estaciones de trabajo del personal médico, dispositivos de red y sistemas de control de acceso estos eventos se reenvían al SIEM mediante agentes o protocolos estándar como Syslog y API, asegurando la integridad y disponibilidad de los registros

Normalización y almacenamiento.

Después de la agregación, los eventos se normalizan, es decir, se transforman en un formato común que facilita su análisis este proceso elimina inconsistencias y reduce la complejidad que surge de múltiples fuentes luego, los eventos normalizados se almacenan en un repositorio centralizado y seguro que proporciona consulta histórica, análisis forense y cumplimiento de los requisitos reglamentarios de la industria de la salud.

Análisis y coherencia de eventos

SIEM realiza análisis y correlación de eventos utilizando reglas y patrones de comportamiento predefinidos. Esta fase identifica patrones que pueden indicar actividad maliciosa, como acceso no autorizado repetido a registros clínicos o intentos de autenticación fuera del horario comercial normal. La correlación permite contextualizar eventos aislados y reducir el número de alertas irrelevantes

Generación y reconocimiento de alertas

Cuando se detecta actividad sospechosa, el sistema genera una alerta que se envía al analista de SOC en este punto, el analista realiza una validación técnica manual que analiza el contexto del evento, la criticidad del sistema afectado y la sensibilidad de la información involucrada esta confirmación es importante para confirmar la legitimidad de la alerta antes de una escalada.

Escalamiento y registro

Si la alerta se confirma como un potencial incidente, el analista procede con el escalamiento, activa los protocolos de respuesta adecuados y notifica a las áreas responsables todos los eventos y decisiones tomadas durante el seguimiento quedan documentados, permitiendo

mantener la trazabilidad, mejorar los procesos de seguridad y cumplir con la normativa de protección de datos sanitarios.

Conclusión

El proceso de monitoreo técnico en un SOC consta de eventos hasta la confirmación y escalamiento de alertas este proceso es crucial para proteger la confidencialidad y la integridad de la información la combinación de la automatización SIEM y la intervención de los analistas SOC garantiza una gestión de la seguridad más precisa y eficiente.

Avance semanal

Divier Jácamo Álvarez

Cetav

Rol: Analista Soc L1

Fecha 10/02/26

Procedimiento de análisis inicial de alertas

El procedimiento de análisis inicial de alertas tiene como objetivo establecer una metodología estructurada para la evaluación temprana de las notificaciones generadas por los sistemas de monitoreo o reporte institucional este proceso busca identificar la validez, relevancia y nivel de prioridad de cada alerta, con el fin de facilitar una toma de decisiones informada y oportuna.

El análisis inicia con la recepción y registro de la alerta, seguida de la verificación de la información asociada para descartar errores o falsos positivos posteriormente, la alerta es clasificada de acuerdo con criterios previamente definidos, tales como severidad, urgencia e impacto potencial a continuación, se realiza un análisis contextual que considera antecedentes, condiciones actuales del sistema y posibles causas del evento finalmente, con base en los resultados obtenidos, se determinan las acciones iniciales correspondientes, las cuales pueden incluir el seguimiento, el escalamiento o el cierre de la alerta, asegurando en todo momento la adecuada documentación del proceso este procedimiento contribuye a una gestión más eficiente y sistemática de incidentes dentro de la organización.

Validación de alertas de seguridad

Introducción

El monitoreo continuo de los eventos de seguridad es una función esencial del SOC. por sistemas como SIEM, EDR o IDS/IPS reflejan hechos reales. Validar correctamente estas alertas es una responsabilidad clave del SOC Nivel 1 que actúa como la primera línea de defensa contra posibles ciberamenazas en los hospitales psiquiátricos, donde se manejan datos clínicos altamente sensibles y sistemas críticos para la atención médica, una validación incorrecta puede tener consecuencias importantes. Por lo tanto, es importante contar con un procedimiento claro y documentado que permita a un analista de Nivel 1 evaluar sistemáticamente la legitimidad de una alerta antes de que se cierre o se escale.

Alcance

El procedimiento descrito sólo aplica para la etapa de validación inicial de las alertas de seguridad realizadas por el SOC L1 esto finaliza con la decisión de cerrar la alarma o elevarla al nivel SOC 2 no incluye operaciones de contención, erradicación o recuperación.

Recepción de alarma y revisión inicial.

El analista de SOC L1 debe leer la alerta en su totalidad, especificando el tipo de evento, la hora del evento, la herramienta que lo generó y la regla o firma asociada. Reconocimiento de la fuente del descubrimiento.

Se ha confirmado que la alerta proviene de una fuente confiable y configurada correctamente, lo que garantiza que no se trata de un error en la herramienta ni de una mala parametrización.

Identificación de bienes afectados

El analista identifica al agente involucrado determina su nivel crítico en el hospital.

Análisis del contexto de activos y usuarios.

El comportamiento normal de un activo o usuario se evalúa en términos de horarios de trabajo, funciones clínicas o administrativas y acceso preautorizado.

Revisar publicaciones relacionadas

El analista examina los registros relevantes en busca de actividad anómala, patrones sospechosos o eventos recurrentes que respalden una alerta. Conexión con otros eventos

Durante el mismo período de tiempo, se verifican alertas similares o relacionadas que pueden indicar un ataque en curso o una acción coordinada.

Respaldo Contra Acciones Legales

Comprueba si el evento se puede atribuir a mantenimiento programado, actualizaciones de software, pruebas internas o actividades preaprobadas

Identificar métricas de participación

El analista busca indicadores de compromiso, como direcciones IP maliciosas, dominios sospechosos, hashes conocidos o comportamiento de ataque típico.

Evaluación de posibles consecuencias.

Se analiza el impacto potencial del evento en la confidencialidad, integridad y disponibilidad de la información, priorizando los datos clínicos y los servicios médicos.

Clasificación inicial de eventos.

Según la evidencia recopilada, el evento se clasifica como un falso positivo, un evento benigno o un posible evento de seguridad

Documentación de análisis

Todas las acciones, evidencias y hallazgos deben registrarse en el sistema de gestión de incidentes para su auditabilidad y trazabilidad. Decisión de cerrar o escalar

Finalmente, el analista decide cerrar la alerta si no hay riesgo o escalarla al SOC L2 si se encuentran signos claros de un incidente real.

Tabla de alertas de seguridad y acciones iniciales del analista

Tipo de alerta	Descripción General	Acción Inicial
Acceso no autorizado	Intentos de acceso fallidos desde ubicaciones desconocidas	Verificar identidad del usuario revisar logs de autenticación y validar el acceso
Malware detectado	Identificación de software malicioso en un equipo o servidor	Confirmar detención revisar tipo de malware y evaluar si el archivo fue ejecutado
Actividad anómala del usuario	Comportamientos fuera del patrón normal del usuario	Analizar historial de actividad validar si corresponde a funciones laborales
Trafico de red sospechoso	Comunicación con direcciones ip	Revisar logs de red y confirmar reputación de ip
Exfiltración de datos	Trasferencias inusuales de información	Identificar volumen y tipo de datos involucrados y verificar legitimidad
Escalamiento de privilegios	Incremento no autorizado de permisos	Validar cambios recientes de roles y revisar registros de sistema
Alertas de ransomware	Comportamientos asociados cifrado masivo de archivos	Verificar procesos activos y evaluar impacto potencial
Fallos repetitivos de autenticación	Múltiples intentos fallidos de inicio de sesión	Determinar si se trata de error de usuario o posible ataque de fuerza bruta
Cambios no automatizados en sistemas	Modificaciones en configuraciones criticas	Revisar historial de cambios y confirmar si fueron aprobados
Alertas de dispositivos médicos	Actividad anómala en equipos conectados	Verificar funcionamiento normal y notificar si afecta servicios clínicos

Fecha: 11/02/26

Escenario simulado de generación de alertas de ransomware

El ransomware se encarga de restringir el acceso a sistemas o datos mediante cifrado, generalmente acompañado de exigencias financieras las variantes actuales incluyen esquemas de doble extorsión, donde se extraen datos además del cifrado en este contexto, herramientas como SIEM, IDS y EDR permiten identificar patrones inusuales y generar alertas oportunas.

Escenarios simulados

1. universidad estatal

El ataque comienza con un ataque de phishing dirigido al personal administrativo. Después de ejecutar un archivo malicioso, se detectan comunicaciones con servidores sospechosos, intentos de autenticación inusuales y cifrado de archivos de gran tamaño. El sistema SIEM genera alertas críticas por comportamiento inusual y la creación de notas de rescate. La respuesta rápida evita el impacto general de los sistemas académicos.

2. Hospital Estatal

El incidente está relacionado con la explotación de una vulnerabilidad de servidor abierto. Las alertas incluyen intentos de acceso no autorizados, desactivación de antivirus y actividad de cifrado detectada por EDR la intervención temprana permite restaurar los sistemas clínicos a partir de copias de seguridad, minimizando el impacto en la atención médica.

3. Negocio financiero

El acceso se proporciona mediante credenciales comprometidas. Se generan alertas para inicios de sesión desde ubicaciones inusuales, transferencias masivas de datos y patrones de cifrado compatibles con ransomware la detección temprana bloquea la exfiltración y reduce los riesgos regulatorios.

Conclusiones

Los escenarios muestran que las alertas relacionadas con ransomware se activan a partir de una serie de eventos sospechosos, como accesos inusuales, transferencias de datos inusuales y cifrado masivo la implementación de monitoreo continuo y planes de respuesta estructurados es fundamental para minimizar el impacto operativo y reputacional de estos ataques.

Análisis de comportamiento de eventos de ransomware

El comportamiento de los eventos observados en los escenarios simulados muestra una secuencia progresiva y correlacionada típica de los ataques de ransomware. En primer lugar, se identifica el primer caso de acceso no autorizado, normalmente relacionado con phishing o explotación de una vulnerabilidad este evento se caracteriza por indicadores como iniciar sesión desde ubicaciones inusuales, múltiples intentos fallidos de autenticación o ejecutar archivos no reconocidos.

Luego viene una fase de movimiento lateral y escalada de privilegios, que se refleja en el aumento del tráfico interno la creación de nuevas cuentas administrativas o el abuso de

herramientas legítimas de sistemas estos acontecimientos, si bien individualmente pueden parecer legítimos, adquieren significado cuando se vinculan temporalmente.

En la siguiente fase, los sistemas de seguimiento detectan comportamientos inusuales y de alto impacto, como la desactivación de soluciones antivirus, la compresión masiva de archivos o la modificación acelerada de extensiones, indicando la fase de cifrado finalmente, pueden ocurrir eventos de exfiltración de datos, como lo demuestran las transferencias inusualmente grandes a direcciones externas.

Línea de tiempo de detención de incidentes

Descripción cronológica del evento.

08:15 a.m. Recibir correo electrónico malicioso

El usuario recibe un correo electrónico de phishing con un archivo adjunto fraudulento. El sistema de filtrado no la clasifica como amenaza crítica.

08:22 a.m. Ejecución de archivos maliciosos

Se ejecuta el archivo adjunto. EDR registra la creación de un proceso inusual de y genera una alerta de gravedad media para comportamientos sospechosos.

08:25 a.m. Comunicación con servidor externo

El firewall detecta el tráfico saliente hacia un dominio clasificado como malicioso el SIEM correlaciona el evento con la alerta anterior y eleva el nivel de gravedad a alto.

08:32 a.m. Intentos de autenticación fallidos

Se registran varios intentos fallidos de acceder a otras computadoras en la red, seguidos de un inicio de sesión exitoso. Se genera una alarma por posible movimiento lateral.

08:40 a.m. Desactivación de antivirus

El sistema detecta cambios no autorizados en los servicios de seguridad se emite una advertencia crítica.

08:47 a.m. Comience con cifrado masivo

EDR identifica cambios acelerados de archivos y cambios masivos de extensiones. Se confirma el comportamiento compatible con ransomware.

08:50 a.m. Activando el protocolo de respuesta

El equipo de seguridad aísla la computadora afectada, bloquea las credenciales comprometidas y activa un plan de contingencia.

Documentación de simulación de incidente

Establecer objetivos

El objetivo de la simulación era analizar la generación y correlación de alertas en caso de un incidente de ransomware en un entorno organizacional controlado para evaluar la capacidad de detección temprana y respuesta de un sistema de monitoreo de seguridad.

Ámbito de actividad La simulación se desarrolló en un entorno virtualizado que representó la infraestructura básica de una organización mediana,

incluyendo: Servidor de archivos servidor de autenticación cinco estaciones de trabajo sistema SIEM para correlación de eventos solución EDR instalada en endpoints no se utilizó ningún malware real; Para evitar riesgos operativos, se imitó el comportamiento típico del ransomware.

Método

La simulación se realizó en cuatro fases

Acceso inicial se simuló un ataque de phishing que conducía a la ejecución controlada de un script que generaba eventos de comportamiento sospechosos.

Movimiento lateral se emularon intentos fallidos de autenticación e inicios de sesión exitosos con credenciales comprometidas para generar registros de errores.

Escalada y evitación se simuló la desactivación de servicios de seguridad y la creación de tareas programadas.

Cifrado simulado se ejecutó un script que cambió las extensiones del archivo de prueba para replicar los patrones de cifrado masivo sin afectar la información real.

Resultados

El SIEM generó alertas graduadas de gravedad media, alta y crítica principalmente por los siguientes motivos

Realización de procesos inusuales contactar con dominios sospechosos el Incremento anormal del tráfico interno los Cambios masivo de archivos la correlación temporal permitió identificar un evento antes de que el impacto fuera generalizado.

Conclusión

La simulación demostró que la detección efectiva de ransomware depende de la correlación entre múltiples eventos y el monitoreo continuo también enfatizó la importancia de establecer protocolos de respuesta bien definidos para minimizar el impacto operativo.

Falsos positivos monitoreo SOC

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 12/02/26

Introducción

El monitoreo continuo de SOC se basa en herramientas como SIEM, IDS/IPS y EDR para identificar actividades sospechosas sin embargo, estas tecnologías pueden generar falsos positivos, definidos como alertas que clasifican erróneamente actividades legítimas como maliciosas Este fenómeno es un desafío crítico para la eficacia operativa del equipo de seguridad.

1. Configuración de reglas incorrecta

Las reglas genéricas o mal adaptadas en herramientas como SIEM a menudo generan alertas innecesarias sin adaptarse al contexto organizacional específico la falta de procesos continuos de adaptación aumenta este problema.

2. Falta de contextualización

La falta de información contextual, como perfiles de activos legítimas se interpreten como inusuales

3. Cambios en el entorno tecnológico

La migración a la nube, nuevas aplicaciones o cambios en la infraestructura cambian los patrones de comportamiento normales. Si las herramientas no se actualizan con estos cambios, se muestran advertencias inapropiadas.

4. Limitaciones tecnológicas

Los sistemas basados en firmas pueden generar coincidencias parciales con acciones legítimas, mientras que los modelos de aprendizaje automático pueden producir errores si no tienen suficientes datos de entrenamiento

5. Factores organizacionales

la mala formación y la falta de métricas claras contribuyen a una gestión de alertas ineficaz y a una mayor percepción de falsos positivos.

Ejemplos de falsos positivos

1. Múltiples intentos fallidos de autenticación debido a que se olvidó la contraseña

Escenario: Un usuario intenta repetidamente acceder a un sistema crítico de la empresa y falla cinco veces seguidas.

Alarma generada: Es posible un ataque de fuerza bruta.

Análisis real: Después del cambio de credencial obligatorio, el usuario ha olvidado su contraseña.

Motivo del resultado falso positivo: La regla se configura sin tener en cuenta el contexto

2. Escaneo interno autorizado

Escenario: El equipo de infraestructura realiza pruebas de vulnerabilidad programadas utilizando herramientas como Nessus u Open VAS.

Alarma generada: Actividad sospechosa de escaneo o reconocimiento de puertos. Análisis real: Actividad legítima confirmada como parte del plan de vulnerabilidad.

Motivo del resultado falso positivo: Falta de comunicación entre equipos y falta de exclusión en SIEM.

3. Transferencia masiva de datos con copia de seguridad programada

Escenario: Se ejecuta una copia de seguridad nocturna, que transfiere una gran cantidad de información al servidor de copia de seguridad.

Alarma generada: Posible filtración de datos.

Análisis real: Proceso de copia de seguridad autorizado automatizado.

Motivo del resultado falso positivo: La regla se basa únicamente en la cantidad de datos transferidos sin un análisis de objetivos fiable.

4. Acceso remoto legal desde una nueva ubicación

Escenario: Un empleado accede al sistema de la empresa desde otra ciudad debido a un viaje de negocios.

Alarma generada: Acceso sospechoso desde una ubicación inusual.

Análisis real: Actividad laboral jurídica.

Motivo del resultado falso positivo: Modelo de detección de anomalías sin actualización dinámica del perfil de usuario.

5. Instalación legal de software administrativo

Escenario: El departamento de TI instala una herramienta de administración remota en varios ordenadores.

Alarma generada: Potencialmente explotando una herramienta de acceso remoto

Análisis real: La implementación está confirmada por la política de la empresa.

Motivo del resultado falso positivo: Firmas coincidentes asociadas con herramientas que también pueden ser utilizadas por atacantes.

6. Automatización DevOps en el entorno de la nube

Escenario: Una canalización automatizada crea y elimina varias instancias de la nube en cuestión de minutos.

Alarma generada: Comportamiento anormal o posible actividad de ataque automatizado.

Análisis real: Proceso normal de implementación continua

Motivo del resultado falso positivo: Las herramientas de monitoreo no están adaptadas a la naturaleza dinámica del entorno de la nube.

7. Envío masivo de correos electrónicos internos

Escenario: El área de personal envía un aviso institucional a todos los empleados.

Alarma generada: Posible campaña de phishing interno.

Análisis real: Comunicación oficial jurídica. Motivo del resultado falso positivo: Reglas basadas en volumen de envío sin validación de dominio o cuenta comercial autorizada.

Procedimiento para descartar falsos positivos

Introducción

El descarte adecuado de falsos positivos es esencial para mantener la eficiencia operativa de un SOC y reducir la fatiga de alertas. Para ello, es necesario aplicar criterios técnicos, contextuales y procedimentales que permitan clasificar correctamente las alertas sin comprometer la seguridad.

1. Criterios Contextuales

Comportamiento histórico del usuario: Verificar si la actividad coincide con patrones habituales (horarios, ubicación, dispositivos).

Rol y privilegios: Confirmar que la acción corresponde a funciones autorizadas del usuario.

Se descarta si la actividad es coherente con el perfil y no existen indicadores adicionales de compromiso.

2. Criterios Técnicos

Validación de infraestructura confiable: Confirmar que IP, dominio o servidor pertenezcan a activos autorizados.

Correlación de eventos: Determinar si existen otros eventos relacionados que respalden la sospecha.

Se descarta si el evento es aislado y no muestra evidencia técnica adicional.

3. Criterios Operativos

Cambios autorizados: Verificar si la actividad corresponde a mantenimientos, respaldos o escaneos programados.

Confirmación con áreas técnicas: Validar con el equipo responsable si la actividad fue legítima.

Se descarta cuando existe documentación o confirmación formal.

4. Criterio de Evaluación de Riesgo

Antes de cerrar la alerta, el analista debe evaluar:

¿Existe evidencia concreta de compromiso?

¿El activo es crítico?

¿Hay múltiples indicadores de ataque?

Si el riesgo es bajo y existe justificación documentada, la alerta puede clasificarse como falso positivo.

Documentación del proceso de validación de las alertas

Proceso de reconocimiento de alertas en el SOC

1. Establecer objetivos

Establecer un procedimiento estandarizado para validar, clasificar y cerrar las alertas generadas por las herramientas de monitoreo de SOC, garantizando consistencia, trazabilidad y reduciendo falsos positivos sin comprometer la detección de eventos reales.

2. Ámbito de actividad

Este proceso se aplica a todas las alertas generadas por plataformas de monitoreo como SIEM, EDR, IDS/IPS, herramientas de seguridad en la nube y sistemas de correlación de eventos.

3. Funciones y responsabilidades

Analista Nivel 1: Ingesta, análisis inicial y clasificación inicial. Analista Nivel 2: Análisis profundo y correlación avanzada.

SOC Manager / Incident Handler: Aprobación final en casos críticos y escalamiento.

4. Flujo del proceso de validación

Registro automático en la plataforma de gestión de incidencias. Priorización según la gravedad que determine la herramienta.

Resultado esperado: Alarma formalmente documentada y asignada.

Para el analista:

Revise el tipo de alerta y la regla que la generó.

Identifique el usuario, el recurso, la IP de origen/destino y la marca de tiempo. Evaluar la criticidad del bien afectado.

Decisión provisional:

Posible evento. Leve sospecha.

Posiblemente un falso positivo.

Consulte registros adicionales

Analizar eventos relacionados en una ventana de tiempo cerrada. Consultar indicadores de reputación

Objetivo: Determinar si existen múltiples indicadores que coincidan con el ataque.

Revisar el historial de usuarios o activos.

Verificar cambios autorizados Confirmar en las áreas técnicas que la operación es legal.

Clasificación de alarmas

La advertencia debe clasificarse como:

Evento aprobado

Falso positivo confirmado

Actividad legal documentada

Alerta de información

Cada clasificación debe tener una justificación técnica documentada.

Aumenta a un nivel superior si:

El activo es crítico.

Hay evidencia de una compensación. La acción continúa o se intensifica.

Llenado y documentación

Para cerrar la alerta:

Se ha realizado un análisis del expediente. Agregue evidencia técnica.

Indique la causa raíz. Recomendar corrección de reglas, si corresponde.

5. Criterios de calidad del proceso

El proceso debe asegurar:

Trazabilidad total.

Tiempo de respuesta según SLA. Reducción progresiva de falsos positivos.

Mejora continua mediante adaptación de reglas

6. Indicadores de desempeño

Un falso positivo. Tiempo medio de análisis

Tiempo medio de respuesta porcentaje de alertas clasificadas correctamente.

Conclusión

La validación de las alertas en el SOC debe realizarse mediante un procedimiento estructurado que combine análisis técnico, contextual y organizativo. La estandarización del proceso permite reducir la incertidumbre en la toma de decisiones, optimizar recursos y fortalecer la capacidad real de detección frente a amenazas.

Monitoreo clasificación de alertas

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha: 13/02/26

Integración de un flujo de monitoreo de alertas

El monitoreo continuo del sistema es una parte esencial de la gestión de riesgos tecnológicos y la protección de activos críticos en el entorno de una organización este proceso permite un conocimiento situacional constante del estado de seguridad de los sistemas de información sin embargo, la ocurrencia de incidentes masivos puede provocar fatiga operativa si no se implementa un esquema estructurado de clasificación y priorización de alarmas.

El flujo de seguimiento integral se formula en cinco etapas interdependientes:

- a) recopilación de datos de varias fuentes tecnológicas;
- b) normalización de eventos para identificar patrones significativos;
- c) detección de anomalías mediante reglas predefinidas o métodos automatizados;
- d) clasificación de las alertas según criterios de gravedad técnica, criticidad de los activos, probabilidad de riesgo contexto operativo; la gestión de respuesta destinada a contener, mitigar y eliminar las consecuencias de un incidente.

La clasificación multinivel permite establecer prioridades y tiempos de respuesta diferenciados, optimizar recursos y reducir los falsos positivos. Como resultado, la integración de este flujo fortalece la resiliencia organizacional, mejora la eficiencia del centro de operaciones de seguridad y facilita la gestión proactiva contra amenazas emergentes.

Proceso operativo de analista SOC L1

Introducción

En un entorno organizacional con una infraestructura tecnológica compleja, el monitoreo continuo es un mecanismo esencial para la identificación temprana de amenazas. En esta estructura, el analista L1 es el primer nivel operativo responsable de revisar y validar las alertas generadas por plataformas de monitoreo como sistemas SIEM y herramientas de detección de amenazas. El funcionamiento eficaz del analista L1 es esencial para evitar una escalada innecesaria de incidentes y reducir la carga operativa en los niveles superiores. Por lo tanto, es necesario crear un proceso técnico estructurado que delimite funciones, criterios de toma de decisiones y responsabilidad.

Todo el proceso de los analistas L1 se puede organizar en seis fases operativas interrelacionadas:

1. Recepción de alarmas y seguimiento continuo

El analista L1 realiza un monitoreo continuo en consolas de monitoreo que centralizan eventos de diversas fuentes esta actividad implica una revisión constante de los paneles y colas de eventos.

2. Reconocimiento del evento original

Esta etapa determina la legalidad técnica de la alerta. El analista confirma:

Fuente del evento

Hora y contexto del evento.

Propiedad afectada

Reglas de correlación relacionadas

El objetivo es identificar falsos positivos y excluir eventos que no suponen un riesgo real.

3. Clasificación y priorización

Una vez confirmado el evento, el analista procede a clasificarlo según criterios predefinidos:

Dificultades técnicas

Criticidad de los activos

Posible impacto

Nivel de exposición

La clasificación se puede estructurar en niveles que determinan los tiempos de respuesta y los procedimientos de escalamiento.

4. Análisis preliminar

El analista L1 realiza el análisis inicial:

Revisión de registros adicionales

Consultoría con inteligencia de amenazas

Indicadores de verificación de compromiso (IoC)

Conexión con eventos anteriores

Esta etapa no implica una investigación en profundidad, sino más bien una evaluación básica para determinar la necesidad de una mayor intervención.

5. Escalada

Si un incidente excede las capacidades operativas de Nivel 1 o confirma una actividad maliciosa, se realiza una derivación formal a un analista de Nivel 2 o un equipo de respuesta a incidentes. La escalada debe incluir información documentada y evidencia recopilada para facilitar la continuidad del análisis.

6. Documentación y Cierre

Todas las actividades deben registrarse en la plataforma de gestión de incidentes. La

documentación incluye:

Descripción del evento

Acciones tomadas

Evidencia recopilada

Motivo del cierre o escalada

La trazabilidad garantiza el cumplimiento legal y facilita futuras auditorías. Habilidades técnicas del analista L1.

Un analista L1 debe tener conocimientos de:

Red y protocolos

Sistemas operativos

Análisis básico de malware

Usando herramientas SIEM

Procedimientos de emergencia

También requiere habilidades analíticas, capacidad para tomar decisiones bajo presión y un estricto cumplimiento de los procedimientos establecidos.

Indicadores de desempeño

La eficacia del proceso L1 se puede evaluar utilizando indicadores como:

Tiempo medio de detección

Tiempo medio de respuesta

Un falso positivo

Número de alertas procesadas

Estas métricas permiten optimizar los flujos operativos y reforzar la mejora continua.

Validación de proceso a SOC Lead

Introducción

El gerente de SOC es responsable de supervisar el funcionamiento general del SOC y garantizar que los procesos realizados en el nivel L1 cumplan con los objetivos estratégicos, los acuerdos de nivel de servicio y las regulaciones aplicables la validación formal del proceso L1 ayuda a reducir las desviaciones operativas, mejorar la calidad del análisis inicial y fortalecer la capacidad de respuesta a incidentes. Método de validación

La validación del proceso se puede estructurar en cinco pasos:

1. Examen de documentos

El gerente del SOC verifica que el procedimiento L1 esté formalmente documentado y se incluya:

corriente de atencion

Criterios de clasificación

Matriz de escala

Plantillas de documentación

Se evalúa el cumplimiento de políticas y estándares internos como ISO/IEC 27035. 2.

Validación técnica mediante casos de prueba.

Se ejecutan escenarios controlados para evaluar:

Identificación de alerta correcta

Gravedad adecuada

Cumplimiento de los tiempos de respuesta

Calidad de escala

Esta fase permite valorar la aplicabilidad real del procedimiento.

3. Análisis de medidas operativas

El gerente de SOC analiza los indicadores clave de desempeño:

Tiempo medio de detección

Tiempo medio de respuesta

El porcentaje de falsos positivos.

Nivel de escalada exitoso

La evaluación cuantitativa permite identificar brechas de desempeño.

4. Revisión de casos históricos

Se seleccionan eventos cerrados para verificar:

Calidad del análisis previo

Consistencia en la clasificación

Trazabilidad de documentos

Justificación técnica del cierre

Esta auditoría interna permite evaluar la madurez operativa.

5. Retroalimentación y mejora continua

Finalmente, el líder del SOC lleva a cabo una sesión formal de retroalimentación en la que:

Se identifican oportunidades de mejora

Se han actualizado los criterios de clasificación.

Se ajustan las reglas de correlación

Se fortalece la formación técnica

La validación no debe verse como un evento único, sino como un proceso cíclico de mejora continua.

Criterios de aprobación

El trámite L1 se considera aprobado si:

Cumple con la documentación oficial requerida.

Mantiene métricas dentro de los umbrales de SLA esto garantiza la uniformidad en la clasificación de las alertas.

Garantiza la trazabilidad total de cada incidencia.

Documentación de ajustes del analista SOC

Los procesos operativos en un SOC requieren revisiones periódicas para adaptarse a nuevas amenazas, cambios tecnológicos y lecciones aprendidas derivadas de incidentes reales. Tras la validación formal del proceso L1, se identificaron oportunidades de mejora orientadas a incrementar la precisión analítica y disminuir la carga operativa innecesaria.

Descripción de Ajustes Implementados

1. Ajustes en la Clasificación de Alertas

Se redefinieron los criterios de severidad incorporando una matriz de impacto-probabilidad más detallada. Este ajuste permitió:

Reducir la ambigüedad en la categorización.

Disminuir inconsistencias entre analistas.

Establecer umbrales más claros para el escalamiento.

Asimismo, se integró una guía contextual para activos críticos, considerando su nivel de exposición y valor estratégico.

2. Optimización del Proceso de Escalamiento

Se formalizó una matriz de escalamiento con tiempos máximos definidos según nivel de criticidad. Se establecieron:

Plantillas estandarizadas de traspaso a L2.

Requisitos mínimos de evidencia antes del escalamiento.

Criterios de no escalamiento debidamente justificados.

Este ajuste redujo escalaciones innecesarias y mejoró la calidad del análisis preliminar.

3. Mejora en la Documentación y Trazabilidad

Se implementó un formato estructurado obligatorio para el registro de incidentes, incluyendo:

Línea temporal del evento.

Indicadores de compromiso observados.

Acciones realizadas y resultados obtenidos.

Esta medida fortaleció la auditoría interna y el cumplimiento normativo.

4. Ajustes en Métricas de Desempeño

Se redefinieron indicadores clave de desempeño (KPI), incorporando:

Tasa de clasificación correcta validada por L2.

Tiempo promedio de validación inicial.

Índice de reincidencia de alertas similares.

Estos indicadores permiten monitorear la efectividad del ajuste implementado.

Impacto Operativo

Los ajustes realizados generaron mejoras observables en:

Reducción del porcentaje de falsos positivos.

Disminución del tiempo medio de respuesta

Mayor consistencia en la priorización de incidentes.

Incremento en la calidad de la documentación técnica.

La implementación sistemática de estos cambios fortalece la madurez del SOC y su alineación con marcos internacionales de gestión de incidentes.

Conclusión

La implementación de un flujo de monitoreo integral con una clasificación estructurada de alertas, junto con la formalización del proceso del analista L1 y su aprobación por parte del gerente del SOC, fortalece significativamente el funcionamiento del centro de operaciones de seguridad al definir claramente las fases.

detección, validación, clasificación, escalamiento y documentación

le permite optimizar el manejo de incidentes y reducir la incertidumbre operativa.

La estandarización de los criterios de dificultad y las matrices de prioridad mejora la calidad del análisis inicial y reduce la aparición de falsos positivos asimismo, la validación periódica de los procesos garantiza el alineamiento estratégico y el cumplimiento de buenas prácticas internacionales

Finalmente, documentar los ajustes y monitorear a través de indicadores de desempeño integra un enfoque de mejora continua; estos elementos aumentan la eficiencia operativa, fortalecen la capacidad de respuesta a incidentes y contribuyen a la resiliencia de la organización frente a amenazas tecnológicas.

Revisión Matriz alertas y ajuste
Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 16/02/26

Clasificación de alerta analisis

El análisis de clasificación de alertas para el proceso SOC L1 sugiere que, si bien su estructura conceptual es suficiente, necesitare una mayor formalización técnica para reducir la subjetividad y mejorar la priorización de incidentes el documento define criterios como dificultad técnica, criticidad del activo, impacto y nivel de exposición.

Monitorización de alarmas de mi archivo de fecha 130226

sin embargo, mi archivo carece de escalas cuantificables y métodos de ponderación estandarizados. como principal ajuste propongo una matriz basada en el modelo de impacto y probabilidad, complementada con variables adicionales: la criticidad del activo, el nivel de exposición y la certeza de detección también recomiendo utilizar una fórmula ponderada para calcular la gravedad, lo que reduce la confusión de los analistas y facilita la automatización en las herramientas SIEM mi propuesta cumple con los lineamientos de gestión de incidentes marcados por la Organización Internacional de Normalización promoviendo la trazabilidad, el cumplimiento de SLA y la mejora continua.

Eventos de amenazas emergentes

Introducción

El entorno actual de ciberseguridad se caracteriza por amenazas dinámicas, el uso de técnicas evasivas y la explotación acelerada de vulnerabilidades recién descubiertas. En este contexto, la detección basada únicamente en firmas o reglas predefinidas no es suficiente enfatiza la importancia de la identificación sistemática y contextualizada de incidentes de seguridad como parte del ciclo de gestión de incidentes.

Por lo tanto, es necesario ampliar el análisis para incluir eventos adicionales que, si bien no representan eventos confirmados, pueden ser indicadores tempranos de compromiso categorías de eventos relacionados con nuevas amenazas

Anormalidades del comportamiento

Las desviaciones de los patrones de uso normales pueden revelar intentos de acceso no autorizados o movimientos laterales los eventos relevantes incluyen autenticación fuera del horario laboral, acceso desde geografías atípicas y escalada de privilegios por única vez este enfoque se basa en modelos de análisis de comportamiento que tienen como objetivo identificar diferencias estadísticas significativas.

Acción relacionada con vulnerabilidades recientes

La divulgación de nuevas vulnerabilidades suele ir acompañada de intentos de explotación masiva eventos como análisis dirigidos a servicios específicos o tráfico inusual a aplicaciones vulnerables deben analizarse con prioridad contextual, especialmente si coinciden con informes de inteligencia sobre amenazas.

Uso anormal de herramientas administrativas.

El abuso de herramientas legítimas del sistema como PowerShell o WMI es una técnica común en ataques avanzados este fenómeno dificulta la detección basada en firmas tradicionales y requiere correlación contextual y análisis de comportamiento.

Indicadores débiles o señales tempranas

Las nuevas amenazas generalmente se manifiestan inicialmente como incidentes de baja gravedad que individualmente no justifican una escalada pero una correlación temporal entre varias alertas triviales, un aumento gradual de los intentos fallidos de autenticación o conexiones a dominios recién registrados pueden indicar las fases iniciales de un ataque.

Integración en una matriz de clasificación de ansiedad.

Para incluir adecuadamente estos eventos en la gestión operativa del SOC, se recomienda incluir variables adicionales en la matriz de clasificación:

El nivel de novedad del modelo abierto. Cumplimiento de información externa actualizada.

Comportamiento anormal persistente a corto plazo. Grado de correlación con hechos históricos.

La inclusión de estos criterios permite ajustar dinámicamente la gravedad, lo que fortalece la capacidad predictiva del proceso de seguimiento. Impacto operativo y estratégico

La integración sistemática de eventos adicionales en el monitoreo continuo tiene ventajas significativas:

Mejora la detección temprana en el ciclo de ataque.

Reduce el tiempo que el oponente pasa en la red. Reduce la posibilidad de una escalada crítica.

Aumenta la madurez operativa del SOC. Estratégicamente, este enfoque favorece una postura defensiva proactiva y fortalece la resiliencia de la organización frente a amenazas en constante cambio.

Documentacion de mejoras realizadas

Introducción

El entorno actual de ciberseguridad se caracteriza por la explotación acelerada de vulnerabilidades recién descubierta en este contexto, la detección basada únicamente en firmas o reglas predefinidas no es suficiente enfatiza la importancia de la identificación sistemática y contextualizada de incidentes de seguridad como parte del ciclo de gestión de incidentes.

Por lo tanto, es necesario ampliar el análisis para incluir eventos adicionales que, si bien no representan eventos confirmados, pueden ser indicadores tempranos de compromiso

categorias de eventos relacionados con nuevas amenazas

Anormalidades del comportamiento

Las desviaciones de los patrones de uso normales pueden revelar intentos de acceso no autorizados o movimientos laterales los eventos relevantes incluyen autenticación fuera del horario laboral, acceso desde geografías atípicas y escalada de privilegios por única vez este enfoque se basa en modelos de análisis de comportamiento que tienen como objetivo

identificar diferencias estadísticas significativas.

Acción relacionada con vulnerabilidades recientes

La divulgación suele ir acompañada de intentos de explotación masiva eventos como análisis dirigidos a servicios específicos o tráfico inusual a aplicaciones vulnerables deben analizarse con prioridad contextual, especialmente si coinciden con informes de inteligencia sobre

amenazas.

Uso anormal de herramientas administrativas.

El abuso de herramientas legítimas del sistema como PowerShell o WMI es una técnica común en ataques avanzados este fenómeno dificulta la detección basada en firmas tradicionales y requiere correlación contextual y análisis de comportamiento.

Indicadores débiles o señales tempranas

Las nuevas amenazas generalmente se manifiestan inicialmente como incidentes de baja gravedad que individualmente no justifican una escalada pero una correlación temporal entre varias alertas triviales, un aumento gradual de los intentos fallidos de autenticación o conexiones a dominios recién registrados pueden indicar las fases iniciales de un ataque.

Integración en una matriz de clasificación de ansiedad.

Para incluir adecuadamente estos eventos en la gestión operativa del SOC, se recomienda incluir variables adicionales en la matriz de clasificación:

El nivel de novedad del modelo abierto

cumplimiento de información externa actualizada.

Comportamiento anormal persistente a corto plazo. Grado de correlación con hechos históricos.

La inclusión de estos criterios permite ajustar dinámicamente la gravedad, lo que fortalece la capacidad predictiva del proceso de seguimiento. Impacto operativo y estratégico

La integración sistemática de eventos adicionales en el monitoreo continuo tiene ventajas significativas:

Mejora la detección temprana en el ciclo de ataque.

Reduce el tiempo que el oponente pasa en la red. Reduce la posibilidad de una escalada crítica.

Aumenta la madurez operativa del SOC estratégicamente, este enfoque favorece una postura defensiva proactiva y fortalece la resiliencia de la organización frente a amenazas en constante cambio.

Conclusión general

El fortalecimiento del proceso de monitoreo y clasificación de alertas en el SOC demuestra la importancia de contar con un flujo operativo estructurado, criterios técnicos cuantificables y mecanismos formales de documentación. La mejora de la matriz de alertas, la optimización del escalamiento y la incorporación de indicadores de desempeño más precisos permiten reducir la subjetividad, disminuir falsos positivos y mejorar los tiempos de respuesta.

Asimismo, la integración del análisis de amenazas emergentes amplía la capacidad preventiva del SOC, promoviendo una postura proactiva frente a riesgos tecnológicos. Todo el proceso se alinea con estándares internacionales consolidando un modelo de mejora continua orientado a la resiliencia y madurez operativa de la organización.

Visualizacion de Eventos

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha: 17/02/26

Visualización de eventos en dashboards

Introducción

En la actualidad, debido a amenazas complejas y ataques cada vez más elaborados, las entidades están recurriendo a los Centros de Operaciones de Seguridad para monitorear, identificar y reaccionar ante incidentes de seguridad en tiempo real. Herramientas como Splunk, IBM QRadar y Microsoft Sentinel combinan capacidades de correlación y visualización que facilitan a los analistas la interpretación de eventos de diversas fuentes. La representación visual de eventos desempeña un papel crucial para disminuir la carga cognitiva sobre el analista, lo que les ayuda a detectar patrones inusuales, tendencias y comportamientos sospechosos.

De esta manera, el diseño eficaz de los tableros dentro del SOC está directamente vinculado a la operatividad y la rapidez de respuesta a incidentes. Marco Teórico Visualización de datos en ciberseguridad La visualización de datos consiste en presentar información compleja a través de gráficos, tales como gráficos de barras, líneas de tiempo, mapas de calor y diagramas de red.

En el campo de la ciberseguridad, estos elementos permiten detectar irregularidades en el tráfico de red. Reconocer aumentos extraordinarios de intentos de autenticación fallidos

Examinar correlaciones entre eventos que ocurren en diferentes ubicaciones el concepto de conciencia situacional es crucial para los SOC, ya que implica conocer la condición actual de la infraestructura, prever riesgos y hacer elecciones fundamentadas en tiempo real.

Arquitectura de un SOC y flujo de eventos

Un SOC contemporáneo combina numerosas tecnologías, entre ellas, el SIEM, EDR, NDR y SOAR. Los eventos producidos por estas soluciones son recolectados, normalizados y correlacionados antes de ser presentados en tableros; la calidad de la representación visual depende de la debida organización y priorización de estos datos.

Tipos de visualización en dashboards SOC

1. Visualización temporal Las líneas de tiempo permiten seguir el desarrollo de incidentes, reconocer ataques coordinados y estudiar la duración de amenazas persistentes.

2. Mapas geográficos Ilustran la procedencia de direcciones IP problemáticas y permiten identificar patrones de ataques en distintas regiones.

3. Gráficos de severidad y categorización Clasifican los eventos de acuerdo con su nivel de gravedad , lo que facilita la priorización de las tareas operativas.

4. Diagramas de red y relaciones Facilitan la visualización de conexiones entre hosts, usuarios y procesos comprometidos, ayudando en el análisis forense.

Principios de diseño en dashboards SOC

Un tablero de SOC efectivo debe adherirse a estos principios

Claridad visual: evitar la saturación de información.

Jerarquización de alertas: resaltar eventos críticos.

Actualización en tiempo real: asegurar datos actualizados.

Personalización por rol: adaptar las vistas para analistas L1, L2 y gerentes.

Interactividad: permitir el filtrado y la exploración a fondo.

Implementar estos principios minimiza la fatiga en el analista y optimiza los tiempos de respuesta.

Desafíos en la visualización de eventos Entre los desafíos más significativos se encuentran

Exceso de datos: grandes volúmenes de registros crean desorden.

Falsos positivos: perjudican la credibilidad de las alertas.

Complejidad técnica: se requiere personal capacitado en análisis y diseño de datos.

Integración heterogénea: múltiples fuentes de datos con formatos diversos.

La adopción de inteligencia artificial y aprendizaje automático ha mejorado la priorización y contextualización de eventos en los tableros actuales. La representación de eventos en los paneles de control del SOC no debería ser vista solo como un aspecto visual atractivo, sino como un factor clave que influye de manera directa en la capacidad de recuperación de la organización. Una presentación inadecuada puede obstaculizar la identificación de amenazas importantes, mientras que un diseño mejorado potencia la eficacia del equipo de seguridad y refuerza la posición defensiva de la entidad asimismo, la transición hacia SOC híbridos y en la nube ha elevado la demanda de paneles de control unificados que cuenten con funcionalidades analíticas avanzadas.

Modelo conceptual del panel de monitoreo

Introducción La creciente sofisticación del entorno digital ha elevado la demanda por sistemas avanzados que monitoreen y respondan a amenazas cibernéticas. Los Centros de Operaciones de Seguridad se establecen como entidades organizativas responsables de la vigilancia, identificación y reacción a incidentes en tiempo real. En esta perspectiva, los

paneles de monitoreo actúan como la interfaz principal entre los sistemas de análisis y los especialistas en seguridad.

Herramientas como Splunk, IBM QRadar y Microsoft Sentinel incorporan capacidades avanzadas para la correlación y visualización que permiten convertir grandes volúmenes de datos en información comprensible y útil. Sin embargo, la efectividad de estos paneles depende del diseño conceptual que alinee correctamente la arquitectura tecnológica con principios cognitivos y operativos.

Marco teórico

Conciencia situacional y monitoreo de seguridad

La teoría de la conciencia situacional postula que la toma de decisiones en entornos cambiantes se basa en tres niveles: identificación de elementos relevantes, interpretación de su significado y predicción de su estado futuro. En el contexto de un SOC, el panel de monitoreo debe facilitar estos niveles a través de representaciones visuales claras y contextualizadas.

Visualización de datos en entornos críticos

En un SOC, donde se gestionan millones de eventos cada día, la correcta jerarquización visual es esencial para prevenir la fatiga del analista y la omisión de alertas cruciales.

Sistemas SIEM y correlación de eventos

Los sistemas SIEM centralizan la recolección, normalización y correlación de registros provenientes de diversas fuentes, estas plataformas forman la base tecnológica que sostiene los paneles de monitoreo, integrando reglas de correlación, análisis de comportamientos y mecanismos para priorizar riesgos.

Modelo conceptual propuesto El modelo conceptual del panel de monitoreo para un SOC se organiza en cuatro capas funcionales conectadas: adquisición de datos, procesamiento y correlación, visualización estratégica y la capa de interacción y respuesta.

Capa 1: Adquisición de datos Esta capa incluye la recolección de eventos desde múltiples fuentes, tales como firewalls, sistemas IDS/IPS, soluciones EDR, servidores, aplicaciones empresariales y servicios en la nube. Los datos se envían al SIEM para su almacenamiento y normalización.

Capa 2: Procesamiento y correlación En esta fase se llevan a cabo procesos de Normalización de registros. Enriquecimiento con inteligencia de amenazas.

Correlación de eventos utilizando reglas definidas

Implementación de modelos de detección fundamentados en comportamiento.

Determinación de puntajes de riesgo.

Capa 3: Visualización estratégica La capa de visualización constituye el corazón del modelo conceptual y se organiza en cinco módulos principales

Resumen ejecutivo: indicador global de riesgo, cifra total de incidentes activos y tendencias temporales. Panel de alarmas críticas: lista priorizada según grado de severidad y tiempo transcurrido desde la detección.

Análisis temporal: gráficos de líneas o histogramas que muestran picos de actividad anómala. Visualización geoespacial: representación cartográfica del origen de eventos sospechosos.

Relaciones y contexto: diagramas de nodos que ilustran conexiones entre usuarios, dispositivos y direcciones IP. Estos módulos deben ser creados siguiendo los principios de jerarquía visual, claridad informativa y actualizaciones en tiempo real.

Capa 4: Interacción y respuesta

Incluye métodos de filtrado en tiempo real, exploración profunda y se integra con plataformas SOAR para llevar a cabo acciones automatizadas, como el aislamiento de un host comprometido o el bloqueo de una dirección IP dañina

Integración de indicadores clave de desempeño El modelo conceptual incluye métricas que permiten medir la efectividad operativa del SOC, tales como:

MTTD,

MTTR

cantidad de incidentes por categoría.

Porcentaje de falsos positivos.

Disponibilidad de activos críticos.

El modelo conceptual que presento atiende la necesidad de fusionar la arquitectura tecnológica, los principios de diseño visual y los requerimientos operativos dentro de un entorno complejo; el modularidad del panel permite adaptarse a diferentes niveles jerárquicos en el SOC, desde analistas de primer nivel hasta responsables estratégicos. Además, la inclusión de análisis contextual y visualizaciones relacionales ayuda a mejorar la comprensión sistémica de los incidentes, disminuyendo la fragmentación de la información. La correcta puesta en práctica de este modelo podría influir de manera favorable en la reducción de tiempos de respuesta y en la mejora de la postura de seguridad de la organización.

Indicadores clave para visualizar monitoreo SOC

Introducción

Los tableros de control en sistemas SIEM que permiten la visualización de grandes cantidades de eventos de seguridad, su eficacia depende de la elección adecuada de métricas que proporcionen valor tanto en la operación como en el ámbito estratégico.

1. Indicadores Operativos

Representan la actividad cotidiana del SOC

Número total de eventos procesados

Cantidad de alertas generadas en un periodo específico

Incidentes en curso.

Clasificación de alertas según su gravedad.

Eventos clasificados por origen.

2. Indicadores de Detección y Respuesta

Analizan la efectividad del SOC

Tiempo medio hasta la detección

Tiempo medio de respuesta

Promedio de tiempo para contener incidentes

Porcentaje de incidentes resueltos

3. Indicadores de Riesgo

Facilitan la evaluación de la exposición organizacional

Grado de riesgo general

Activos esenciales bajo riesgo

Vulnerabilidades relacionadas con incidentes

Evolución de amenazas emergentes

4. Indicadores de Calidad y Gobernanza

Valoran la madurez del sistema de monitoreo

Tasa de alertas falsas

Alcance de la cobertura de monitoreo

Adherencia a acuerdos de nivel de servicio

Evolución histórica de incidentes graves

Conclusión

Un tablero de monitoreo del SOC debe equilibrar métricas operativas, de eficacia, riesgo y gobernanza; la visualización debe ser clara, bien estructurada y alineada con los objetivos de la organización, facilitando la conversión de datos en decisiones estratégicas en el momento adecuado.

Conclusión

En conclusión, la correcta integración entre modelo conceptual, indicadores relevantes y visualización efectiva determina la capacidad del SOC para anticipar, detectar y mitigar incidentes de seguridad, consolidando su papel como eje central de la protección digital institucional.

Construccion de monitoreo SOC

Divier Álvarez

Cetav

Rol: Analista SOC L1

Fecha 18/02/26

Detención temprana de ransomware

Introducción

El monitoreo integral de eventos de red y de endpoints representa una práctica esencial dentro de los modelos actuales de detección y respuesta ante incidentes. En contraste con enfoques tradicionales que se centran únicamente en perímetros o dispositivos individuales, la clasificación en múltiples capas permite identificar patrones de ataque complejos que, si se consideran de manera aislada, podrían no ser detectados este método está en consonancia con los principios de defensa en profundidad que se promueven y con los marcos tácticos que han sido desarrollados.

Caso de monitoreo: Detección anticipada del despliegue de ransomware mediante clasificación híbrida

Descripción del escenario

El ransomware contemporáneo no solo se encarga de cifrar archivos, sino que también lleva a cabo actividades preliminares como el escalamiento de privilegios, la desactivación de defensas y la exploración de recursos compartidos en la red. Por lo tanto, su detección eficaz requiere una visibilidad completa tanto del comportamiento del host como del tráfico interno y externo.

Eventos considerados

Eventos de Endpoint

Ejecución masiva de procesos con una alta tasa de modificación de archivos.

Eliminación de copias de seguridad mediante comandos administrativos.

Desactivación o alteraciones de servicios de seguridad locales.

Cambios rápidos en las extensiones de archivos dentro de directorios críticos.

Eventos de Red

Aumento inusual del tráfico SMB hacia múltiples recursos compartidos.

Conexiones simultáneas a varios servidores de archivos internos.

Transferencia lateral de ejecutables a través de protocolos administrativos.

Intentos de comunicación con direcciones IP externas que están asociadas a infraestructura de
pago o de mando y control.

Lógica de evaluación propuesta

La regla de monitoreo dentro del SIEM se estructura en tres fases que están temporalmente
correlacionadas

Indicador inicial en endpoint: detección de eliminación de copias sombra.

Actividad lateral en red: incremento anómalo de conexiones SMB desde el mismo host.

Comportamiento destructivo: modificación masiva de archivos en un intervalo de menos de 5 minutos.

Si se cumplen las tres condiciones dentro de una ventana de 15 minutos, el sistema eleva la alerta a un nivel crítico y activa un playbook automatizado para contención.

Fundamentación técnica

La integración de eventos disminuye el riesgo de falsos positivos que podrían resultar de actividades administrativas legítimas por ejemplo, la eliminación de copias de sombra puede ser una tarea válida; Sin embargo, su valoración con la propagación lateral y el cifrado masivo constituye un patrón inequívoco de amenaza.

Este enfoque responde a las recomendaciones de monitoreo continuo y gestión centralizada de registros, como lo describe el NIST, así como a las mejores prácticas de controles críticos.

Análisis de eventos dentro del SOC

Introducción

El Centro de Operaciones de Seguridad actúa como el núcleo operativo dentro de la ciberseguridad de una organización al reunir y analizar eventos provenientes de diversas fuentes tecnológicas en ambientes donde predominan amenazas sofisticadas, el monitoreo aislado de eventos de red o de terminal resulta inadecuado; por lo tanto, los marcos actuales aconsejan la evaluación de múltiples fuentes y el monitoreo constante como prácticas fundamentales además, la integración de eventos permite la identificación de comportamientos observables utilizando técnicas definidas.

Relación de eventos dentro del SOC

1. Nivel técnico

Los eventos procedentes de terminales se consolidan en plataformas de gestión de eventos e información de seguridad o detección y respuesta extendida la compensación a través de coincidencias tanto temporales como de activos facilita la conversión de alertas individuales en incidentes con contexto, lo que ayuda a minimizar falsos positivos y mejorar la precisión en la detección.

2. Nivel operativo

La integración de eventos potencia el ciclo de gestión de incidentes que incluye recogida, normalización, clasificación, priorización y respuesta este método mejora el trabajo en distintas etapas y optimiza métricas como el tiempo medio para la detección y respuesta.

3. Nivel estratégico

El análisis conjunto de eventos apoya la mejora continua del programa de ciberseguridad y refuerza los controles que se alinean con buenas prácticas internacionales.

Documentación de integración del SOC

Mi documento presentara de manera organizada la combinación de eventos de red y de endpoints en el Centro de Operaciones de Seguridad, con el propósito de mejorar la detección temprana de amenazas a través de una limitación de diversas fuentes, en conformidad con las mejores prácticas.

2. Ámbito

La integración se aplica a:

Estaciones de trabajo corporativas.

Servidores esenciales.

Dispositivos de seguridad tanto perimetrales como internos.

Esto incluye la recolección, normalización, clasificación y gestión de eventos asociados con amenazas tanto internas como externas.

3. Marco Regulatorio y de Referencia

La implementación se basa en:

Gestión centralizada de registros.

Modelo táctico de amenazas.

Controles de seguridad críticos.

4. Estructura de la Integración

Capa de Recolección

Agentes EDR distribuida en los endpoints.

Firewalls e IDS/IPS transmitiendo registros de manera segura a través de Syslog.

Controladores de dominio generan eventos de autenticación.

Capa de Normalización

Conversión de registros a formato estructurado.

Unificación de campos.

Capa de Enriquecimiento

Consulta de reputación de direcciones IP.

Clasificación según la criticidad de los activos.

Vinculación con técnicas del marco ATT&CK.

Capa de Correlación

Reglas basadas en intervalos de tiempo.

Coincidencia por usuario/host/dirección IP.

Asignación de evaluación de riesgo.

Capa de Respuesta

Generación automática de incidentes.

Activación de manuales de procedimientos.

Aislamiento de hosts comprometidos.

5. Casos de Uso Implementados

Movimiento Lateral

Endpoint: autenticación privilegiada inusual.

Rojo: Múltiples conexiones internas SMB.

Resultado: alerta crítica y escalamiento a Nivel 2.

Exfiltración de Datos

Endpoint: compresión masiva de archivos sensibles.

Rojo: incremento inusual del tráfico saliente cifrado.

Resultado: bloqueo preventivo de conexión externa.

Actividad Tipo Ransomware

Endpoint: eliminación de copias de sombra.

Rojo: rápida propagación lateral.

Resultado: aislamiento automático del dispositivo afectado.

Métricas de Desempeño

Tras la implementación, se observaron:

Reducción de falsos positivos.

Disminución del Tiempo Promedio de Detección.

Mejora en el Tiempo Promedio de Respuesta.

Mayor priorización basada en niveles de riesgo.

Control y Mejora Continua

Revisión trimestral de las reglas de evaluación.

Actualización de los indicadores de compromiso.

Validación periódica de la cobertura ATT&CK.

Ajuste de manuales de procedimientos conforme a las lecciones aprendidas.

Conclusión

La integración organizada de eventos de red y de endpoints ha fortalecido la capacidad analítica y operativa del SOC, permitiendo la transformación de eventos aislados en incidentes contextualizados, mejorando la detección y respuesta ante amenazas avanzadas y contribuyendo al desarrollo del programa de ciberseguridad de la institución.

Tabla y desempeño del Analista

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 19/02/26

Indicador Para medir la eficiencia del monitoreo del SOC

Introducción

En un Centro de Operaciones de Seguridad la efectividad del monitoreo informático es vital para salvar los activos digitales, la detección temprana de incidentes de seguridad y la reducción de riesgos cibernéticos. Los SOC que operan eficientemente deben evaluar continuamente su rendimiento mediante indicadores que midan la rapidez, precisión y alcance de la vigilancia de la infraestructura tecnológica.

El diseño de indicadores no solo permite la medición del funcionamiento, sino que también optimiza ante incidentes y refuerza la postura de seguridad de la entidad.

Marco Conceptual

La eficiencia en el monitoreo informático se define como la habilidad de un SOC para descubrir, analizar y reaccionar ante incidentes de seguridad utilizando de manera óptima los recursos disponibles un monitoreo de efectivo no solo disminuye los tiempos de respuesta, sino que también reduce los falsos positivos y optimiza los costos relacionados

Los indicadores esenciales en un SOC deben reflejar la cobertura de sistemas críticos, la puntualidad en la elaboración de informes y la eficiencia en la utilización de herramientas de seguridad.

Indicadores Propuestas

1. Índice de Detección de Incidentes (IDI)

Definición: Indica la proporción de incidentes de seguridad detectados en relación con el total de incidentes que han ocurrido en la infraestructura.

Fórmula:

$$\text{IDI} = (\text{Incidentes detectados} / \text{Incidentes totales}) \times 100$$

Unidad de medida: Porcentaje (%)

Interpretación:

Valores que exceden el 95 % indican una alta eficiencia en la capacidad de detección del SOC.

2. Tiempo Medio de Detección

Definición: Evalúa el tiempo medio que el SOC tarda en identificar un incidente desde que se produce.

Fórmula:

$$MTTD = \Sigma (\text{Tiempo de detección de cada incidente}) / \text{Número total de incidentes}$$

Unidad de medida: Minutos o horas

Interpretación:

Valores bajos sugieren una capacidad de monitoreo ágil y eficaz.

3. Tiempo Medio de Respuesta

Definición: Mide el tiempo promedio que el SOC emplea en contener y mitigar un incidente desde su detección.

Fórmula:

$$\text{MTTR} = \Sigma (\text{Tiempo de respuesta de cada incidente}) / \text{Número total de incidentes}$$

Unidad de medida: Horas o minutos

Interpretación:

Un MTTR reducido indica una alta eficacia operativa

4. Tasa de Falsos Positivos

Definición: Evaluación de la proporción de alertas que no corresponden a incidentes reales.

Fórmula:

$$\text{TFP} = (\text{Alertas incorrectas} / \text{Total de alertas generadas}) \times 100$$

Unidad de medida: Porcentaje (%)

Interpretación:

Una tasa baja de falsos positivos sugiere precisión en los sistemas de detección y disminuye la carga operativa del SOC.

5. Cobertura de Sistemas Críticos

Definición: Mide el porcentaje de sistemas críticos que son monitoreados en tiempo real por el SOC.

Fórmula:

$$CSC = (\text{Sistemas críticos monitoreados} / \text{Total de sistemas críticos}) \times 100$$

Unidad de medida: Porcentaje (%)

Interpretación:

Un valor cercano al 100 % garantiza que los activos más significativos estén adecuadamente protegidos.

6. Eficiencia de Herramientas de Monitoreo

Definición: Evalúa la relación entre la cantidad de incidentes detectados y los recursos utilizados en soluciones tecnológicas.

Fórmula:

$$\text{EHM} = \text{Incidentes detectados} / \text{Costo operativo de las herramientas de monitoreo}$$

Unidad de medida: Incidentes por unidad monetaria Interpretación: Valores altos significan utilización efectiva de los recursos tecnológicos disponibles.

7. Cumplimiento en Informe

Definición: Evalúa la proporción de informes de seguridad entregados puntualmente según el cronograma establecido.

Fórmula: $CGR = (\text{ Informes entregados a tiempo } / \text{ Total de informes programados }) \times 100$

Unidad de medida: Porcentaje (%)

Interpretación: Esto refleja la efectividad en la comunicación de resultados y la transparencia operativa del SOC

La aplicación de estos indicadores permite al analista del SOC evaluar la eficiencia desde varias perspectivas: técnica , operativa y económica además, facilita la identificación de áreas de mejora, la optimización de recursos y el fortalecimiento de los protocolos de seguridad es recomendable que los indicadores se sometan a revisión y ajuste periódico , introduciendo nuevas métricas relacionadas con las amenazas emergentes , la automatización de procesos y las lecciones aprendidas de incidentes anteriores esto asegura la relevancia y la alineación de los esfuerzos de monitoreo con la estrategia de ciberseguridad organizacional .

Indicadores de monitoreo y desempeño del analista

Tabla de indicaciones de gestion de incidentes y desempeño del SOC

Indicador	Dimensión del desempeño	Que evalua	Meta de referencia
Tiempo de detención	Eficiencia operativa	Capacidad de monitoreo y detenciones tempranas	Tendencia decreciente
Tiempo de recuperación	Eficiencia global	Rapidez en restaurar servicios afectados	Según SLA
Incidentes dentro del SLA	Cumplimiento	Nivel de compromiso con el negocio	90%
Tasa de falsos positivos	Calidad tecnica	Precisión de herramientas de analisis	15%
Tasa de reincidencia	Efectividad	Calidad de la remediación	Tendencia decreciente
Satisfacción del usuario	Valor estrategico	Percepción del servicio del SOC	4/5

Modelo de Medición

1. Propósito

El objetivo del modelo es analizar el rendimiento del Centro de Operaciones de Seguridad utilizando un conjunto limitado de métricas que permitan evaluar la eficacia del proceso de respuesta ante incidentes y su relevancia para el negocio. Se funda en principios de mejora continua que se encuentran en las directrices para la gestión de incidentes

2. Componentes del modelo

El modelo se organiza alrededor de tres ejes fundamentales:

Velocidad de respuesta

Determina la capacidad operativa del SOC para identificar y abordar incidentes.

Indicadores:

Tiempo medio de detección

Tiempo medio de recuperación

Eficacia técnica

Evalúa la calidad del análisis realizado y la robustez de la solución empleada.

Indicadores:

Índice de falsos positivos.

Índice de reincidencia en incidentes.

Cumplimiento y valor

Examina la concordancia con los compromisos de la organización y la percepción del

servicio.

Indicadores:

Porcentaje de cumplimiento de SLA.

Grado de satisfacción del usuario interno.

3. Método de evaluación

Fuentes de información: herramientas de monitoreo sistema de gestión de tickets y encuestas de satisfacción.

Frecuencia: mediciones mensuales revisadas de forma trimestral.

Escala de rendimiento:

90%: nivel óptimo.

75–89%: nivel aceptable.

75%: nivel crítico.

4. Resultado esperado

El modelo permite integrar los indicadores en un índice general que facilita la toma de decisiones estratégicas, identifica deficiencias operativas y promueve la mejora continua del

SOC.

Conclusión

Esto tiene lo esencial rapidez, efectividad y valor, ofreciendo una herramienta práctica que está alineada con estándares internacionales para evaluar el rendimiento del SOC de manera objetiva y a lo largo del tiempo.

Monitoreo clasificación y metricas

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha: 20/02/26

Monitoreo clasificación y métricas

Introducción

En contextos donde predomina una gran complejidad y dinamismo, las organizaciones necesitan sistemas integrados que faciliten la recopilación de información relevante, su organización de forma estructurada y la evaluación de su rendimiento a través de indicadores cuantificables. El monitoreo ofrece datos en tiempo real o en intervalos regulares sobre procesos y resultados; la clasificación agrupa la información en categorías significativas; y las métricas permiten medir, comparar y evaluar el desempeño.

Sin embargo, cuando estos elementos funcionan de forma aislada, surgen brechas informativas y una pérdida de cohesión analítica. Por lo tanto, se sugiere un modelo integrado que relacione estas tres dimensiones bajo un enfoque sistémico y orientado a resultados.

Marco Teórico

Enfoque Sistémico

La teoría general de sistemas postula que los sistemas deben ser considerados como totalidades interconectadas desde esta perspectiva, el monitoreo, la clasificación y las métricas no son procesos independientes, sino subsistemas interrelacionados que interactúan de manera dinámica.

Mejora Continua

El ciclo PHVA que significa Planificar-Hacer-Verificar-Actuar ofrece un marco metodológico que respalda la retroalimentación constante entre la medición y la adaptación de procesos.

Ventaja Competitiva y Procesos

Desde el enfoque de la cadena de valor de Michael Porter, la integración de información estructurada y mediciones precisas contribuye a crear ventajas competitivas sostenibles.

Modelo Integrado Propuesto

1. Componente de Monitoreo

El monitoreo representa la etapa de captura sistemática de datos. Incluye:

Identificación de variables críticas.

Establecimiento de mecanismos de recolección de datos.

Automatización mediante tecnologías digitales cuando sea necesario.

Este componente alimenta directamente al sistema de clasificación y métricas.

2. Componente de Clasificación

La clasificación organiza los datos obtenidos en categorías estructuradas. Sus funciones

incluyen:

Definición de criterios taxonómicos.

Asignación de categorías según atributos relevantes.

Normalización y depuración de datos.

La correcta clasificación garantiza coherencia analítica y comparabilidad.

3. Componente de Métricas

Las métricas convierten los datos clasificados en indicadores evaluativos. Este componente

incluye:

Definición de indicadores clave de desempeño

Establecimiento de umbrales y estándares.

Análisis estadístico e interpretación de resultados.

Las métricas proporcionan retroalimentación al sistema, generando ajustes en el monitoreo y la clasificación.

Integración Sistémica

El modelo opera como un ciclo dinámico:

Monitoreo: Captura de datos.

Clasificación: Organización estructurada.

Métricas: Evaluación y análisis.

Retroalimentación: Ajuste del sistema.

La integración asegura coherencia metodológica, trazabilidad informativa y mejora continua.

La principal aportación del modelo radica en la articulación metodológica de tres funciones que tradicionalmente han estado separadas. Desde un enfoque sistémico, la integración mejora la eficiencia organizacional y disminuye la fragmentación informativa. Además, permite la toma de decisiones fundamentadas en evidencia empírica, robusteciendo la gobernanza de datos.

Su aplicabilidad se extiende a sectores como la educación, la salud, la gestión pública, la tecnología y la gestión empresarial, donde la información estructurada y medible es de gran relevancia.

Conclusión

El modelo integrado de monitoreo, clasificación y métricas representa una propuesta teórica y operativa que busca la mejora continua y la eficiencia organizacional, basado en fundamentos sistémicos y de gestión por procesos. Este modelo permite transformar datos en conocimiento útil para la toma de decisiones estratégicas.

Su implementación exige alineación institucional, una definición clara de indicadores y una cultura organizacional enfocada en la medición y la mejora constante.

Validación de coherencia del modelo

Introducción

La coherencia de un modelo conceptual es un criterio esencial para asegurar su aplicabilidad y validez científica en el ámbito de la gestión organizativa la integración de monitoreo, clasificación y métricas no solo demanda una articulación operativa, sino que también requiere consistencia epistemológica y metodológica en este sentido, validar la coherencia implica estudiar la relación entre los distintos componentes, la lógica de su secuencia y la

correspondencia con los principios teóricos que la respaldan.

Marco Teórico

La teoría general de sistemas sostenida establece que los sistemas deben examinarse como totalidades organizadas, en las que cada elemento adquiere relevancia a partir de su conexión con los otros desde esta perspectiva, la coherencia se fundamenta en la interdependencia estructurada entre los componentes.

Además, establece que cada proceso debe incluir mecanismos de verificación y retroalimentación continua para garantizar su consistencia y mejora constante.

Estos fundamentos teóricos permiten establecer criterios necesarios para evaluar la coherencia del modelo integrado.

Metodología de Validación

La validación fue realizada a través de un análisis estructural y secuencial del modelo, teniendo en cuenta cuatro dimensiones:

Coherencia lógica: relación causa-efecto entre elementos.

Coherencia funcional: continuidad operativa sin interrupciones.

Coherencia metodológica: alineación con principios teóricos.

Coherencia evaluativa: capacidad de retroalimentación y ajuste.

Resultados

Coherencia Lógica

Se evidencia una secuencia bien estructurada: el monitoreo genera datos, la clasificación organiza la información y las métricas transforman los datos estructurados en indicadores evaluativos esta progresión mantiene una clara relación causal y evita redundancias conceptuales.

Coherencia Funcional

Desde una perspectiva operativa, cada componente tiene una función específica y complementaria el monitoreo actúa como fuente de información, la clasificación como mecanismo de estructuración y las métricas como herramienta de evaluación. No se identifican interrupciones en el flujo del proceso.

Coherencia Metodológica

El modelo se ajusta a un enfoque sistémico al considerar los componentes como subsistemas interdependientes además, la retroalimentación proveniente de las métricas valida su conformidad con el ciclo de mejora continua.

Coherencia Evaluativa

La inclusión de un mecanismo de retroalimentación refuerza la consistencia del modelo, ya que permite ajustar las variables de monitoreo, redefinir categorías y recalibrar indicadores este elemento evita rigideces estructurales y promueve la capacidad de adaptación.

El análisis ha evidenciado que el modelo integrado presenta coherencia tanto estructural como operativa la conexión entre sus componentes responde a una lógica sistémica donde cada fase depende de la anterior y contribuye a la siguiente su efectividad práctica está condicionada por la precisión en la definición de variables críticas, criterios de clasificación e indicadores estratégicos.

Se han identificado riesgos potenciales de incoherencia cuando las métricas no se alinean con los objetivos organizacionales o cuando la clasificación carece de criterios estandarizados por consiguiente, la implementación del modelo requiere la existencia de protocolos documentados y revisiones periódicas.

Documentación de versión Consolidada

1. Introducción La vigilancia en un Centro de Operaciones de Seguridad constituye el elemento fundamental de la administración de la ciberseguridad en las organizaciones su objetivo es identificar, analizar y reaccionar a incidentes de seguridad de manera oportuna y organizada. La versión integrada presentada

combina el monitoreo, la clasificación y las métricas en un único marco metodológico, garantizando coherencia operativa y trazabilidad.

2. Marco Normativo y Referencial La versión consolidada está en conformidad con los siguientes marcos de referencia: National Institute of Standards and Technology (NIST): Marco de Ciberseguridad (CSF) y guía de manejo de incidentes (SP 800-61). International Organization for Standardization: Norma ISO/IEC 27001 para sistemas de gestión de seguridad de la información. MITRE Corporation: Marco ATT&CK para la clasificación de tácticas y técnicas de amenazas.

Estos marcos proporcionan directrices para estructurar procesos, categorizar eventos y establecer métricas de rendimiento.

3. Arquitectura del Monitoreo SOC Consolidado Componente de Monitoreo Continuo

El monitoreo continuo incluye:

Recolección de registros y telemetría Integración en plataformas SIEM. Correlación automática de eventos. Detección basada en reglas y comportamiento. Objetivo: Reconocer eventos anómalos en tiempo real.

Componente de Clasificación de Eventos Los eventos identificados se clasifican en función de: Tipo de amenaza (malware, phishing, acceso no autorizado, exfiltración). Nivel de severidad (bajo, medio, alto, crítico). Impacto en activos esenciales. Tácticas y técnicas según el marco ATT&CK de MITRE Corporation.

Esta clasificación facilita la priorización de respuestas y estandariza el análisis.

Componente de Métricas e Indicadores La consolidación incluye indicadores clave de desempeño (KPI), como: MTDD MTTR Tasa de falsos positivos Nivel de cumplimiento de SLA Porcentaje de incidentes escalados

Estos indicadores permiten medir la eficiencia operativa y la madurez del SOC.

Flujo Operativo Consolidado Captura de eventos utilizando monitoreo automatizado. Normalización y enriquecimiento de datos. Clasificación y priorización. Análisis y respuesta. Medición y reporte de métricas. Retroalimentación y mejora continua.

Este ciclo se encuentra alineado con el proceso de gestión de incidentes.

5. Gobierno y Control La versión consolidada incluye: Políticas formales de monitoreo. Definición precisa de roles. Procedimientos documentados Auditorías internas regulares.

Esto asegura trazabilidad, rendición de cuentas y cumplimiento normativo.

Nivel de Madurez del Monitoreo Se sugiere evaluar el SOC utilizando un modelo de madurez de cinco niveles: Inicial Repetible. Definido. Gestionado con métricas. Optimizado.

La consolidación propuesta corresponde a niveles 4–5, dado que integra un monitoreo estructurado, una clasificación estandarizada y métricas de desempeño.

Conclusión La versión consolidada del monitoreo SOC integra vigilancia continua, clasificación estructurada y métricas cuantificables dentro de un modelo sistémico que se alinea con normas internacionales. Esta combinación fortalece la capacidad para detectar amenazas desde etapas tempranas, mejora la eficiencia operativa y fomenta la mejora continua.

Su implementación requiere inversiones tecnológicas, formación especializada y un compromiso estratégico por parte de la alta dirección su adopción aporta significativamente a la resiliencia organizacional ante amenazas cibernéticas

Procedimientos de detención

Divier Jácamo Álvarez

Cetav la libertad

Rol: Analista SOC L1

Fecha 23/02/26

Detención de ransomware en el SOC

Técnicas y procedimientos

Introducción

La creciente complejidad de los ataques de ransomware ha llevado a los Centros de Operaciones de Seguridad a establecer procedimientos sistemáticos para identificar y neutralizar estas amenazas antes de que comprometan datos esenciales el propósito de este estudio es detallar, desde un enfoque académico, los métodos prácticos de detección que utilizan los SOC contemporáneos, poniendo énfasis en mecanismos proactivos, análisis de comportamientos y automatización de procesos.

1. Monitoreo Continuo y Correlación de Eventos

Los SOC utilizan sistemas de monitoreo continuo que supervisan eventos en redes, servidores y puntos finales con el objetivo de identificar patrones relacionados con el ransomware el análisis centralizado de registros y eventos facilita la correlación de diversas fuentes de datos para la detección de anomalías en tiempo real, como incrementos inusuales en el tráfico o procesos de cifrado a gran escala este enfoque busca señales anticipadas antes de la aparición del mensaje de rescate, analizando comportamientos que se producen en las fases iniciales del ataque, como la escalación de privilegios o el movimiento lateral dentro de la red.

2. Playbooks Estructurados y Automatización en SOC

Los procedimientos de detección en los SOC actuales están formalizados en playbooks de respuesta ante ransomware, que establecen los protocolos a seguir desde la detección inicial hasta la remediación estos playbooks orientan el análisis de alertas, la priorización de incidentes y las acciones de contención además, los avances recientes incluyen la implementación de inteligencia artificial y aprendizaje automático para automatizar tareas clave, como el enriquecimiento de alertas, la identificación de TTPs y la recomendación de acciones correctivas.

3. Detección Basada en Comportamientos y Señales de Entropía

Más allá de las técnicas convencionales basadas en firmas, numerosos SOC aplican análisis de comportamiento para detectar procesos que resultan sospechosos de cifrado or ejemplo, algunos modelos de detección cuantifican las variaciones en la entropía de operaciones de archivos, memoria y tráfico para identificar conductas vinculadas al ransomware en tiempo real, lo que mejora las tasas de detección anticipada y disminuye los errores de identificación.

4. Técnicas de Señuelo conocidas como Honeypots

Algunos marcos avanzados incorporan archivos señuelo en entornos honeypot que actúan como trampas para el ransomware estos elementos son diseñados con características altamente susceptibles a ser atacadas por el malware, lo que permite al SOC generar alertas al detectar accesos o modificaciones en esos archivos, facilitando una reacción temprana antes de que los sistemas de producción sean cifrados.

5. Integración de Inteligencia de Amenazas

Los SOC eficaces combinan datos internos con inteligencia sobre amenazas externas para enriquecer la detección de ransomware esto incluye la utilización de indicadores de compromiso, indicadores de ataque, firmas actualizadas de campañas maliciosas y la correlación con vectores de ataque conocidos dichas integraciones permiten contextualizar eventos optimizar a manual, o automatizado en un incidente relacionado con ransomware

playbook de detencion de ransomware

Introducción

El ransomware ha progresado desde campañas oportunistas masivas a operaciones dirigidas de alta sofisticación que incorporan técnicas de doble extorsión y avanzadas estrategias de movimiento lateral en este contexto, los Centros de Operaciones de Seguridad son requeridos

a adoptar metodologías sistemáticas que incluyan monitoreo continuo, análisis de comportamiento y automatización. De acuerdo con el modelo de gestión de incidentes, la fase de detección y análisis resulta crucial para mitigar el impacto en la organización. Además, el marco ATT&CK ofrece una clasificación estructurada de tácticas y técnicas que facilita la correlación de eventos y la detección de comportamientos adversos.

Este manual creado establece un procedimiento formal de detección aplicable a infraestructuras híbridas, con la finalidad de disminuir el tiempo promedio de detección y restringir la propagación del cifrado.

Marco metodológico

La elaboración del manual se fundamenta en:

El ciclo de respuesta a incidentes del NIST, que abarca las fases de Preparación, Detección y Análisis, Contención, Erradicación y Recuperación, así como actividades posteriores.

Las tácticas de ransomware detalladas en MITRE ATT&CK, particularmente:

Acceso Inicial (T1566, conocido como Phishing)

Ejecución (T1059 – Intérprete de Comandos y Scripting)

Movimiento Lateral (T1021)

Impacto (T1486 – Datos Encriptados para Impacto)

Playbook de detección

Fase I: Preparación

Configuración tecnológica

El SOC debe estar equipado con:

SIEM que incluya capacidades avanzadas de correlación.

EDR/XDR en puntos finales.

NDR para la supervisión del tráfico lateral.

Integración con fuentes de inteligencia de amenazas.

Automatización a través de una plataforma SOAR.

Indicadores de compromiso iniciales

Se identifican como señales tempranas:

Creación masiva de archivos con extensiones no reconocidas.

Aumento anómalo en la entropía de los archivos.

Eliminación de copias de seguridad a través de comandos administrativos.

Uso inadecuado de herramientas legítimas.

Conexiones a infraestructura C2 conocida.

Fase II: Detección y análisis

Activadores del manual

El procedimiento se inicia ante:

Modificación masiva de archivos en periodos breves.

Desactivación de soluciones de seguridad.

Intentos recurrentes de autenticación lateral.

Acceso o alteración de archivos trampa.

Procedimiento operativo

Paso 1: Validación inicial por el Analista de Nivel 1

Revisar alerta en el SIEM.

Correlacionar eventos recientes.

Clasificar la severidad.

Paso 2: Investigación técnica

Análisis de árboles de procesos.

Verificación de hash y reputación.

Identificación de persistencia.

Revisión de conexiones externas activas.

Mapeo según técnicas del marco ATT&CK.

Paso 3: Confirmación de incidente

Se declara un incidente de ransomware cuando se confirman múltiples indicadores críticos, tales como evidencia de cifrado criptográfico, generación de una nota de rescate o la eliminación de respaldos.

Fase III: Contención automática y escalamiento

Ante la confirmación:

Aislamiento inmediato del punto final afectado.

Bloqueo del hash malicioso a nivel organizacional.

Desactivación de credenciales comprometidas.

Bloqueo de IPs maliciosas en el perímetro de seguridad.

Preservación de evidencia para el análisis forense.

La automatización mediante SOAR posibilita la ejecución de estas acciones en cuestión de segundos, disminuyendo así la ventana de impacto.

Métricas de desempeño

La efectividad del manual debe ser evaluada a través de:

Tiempo promedio de detección

Tiempo promedio de respuesta

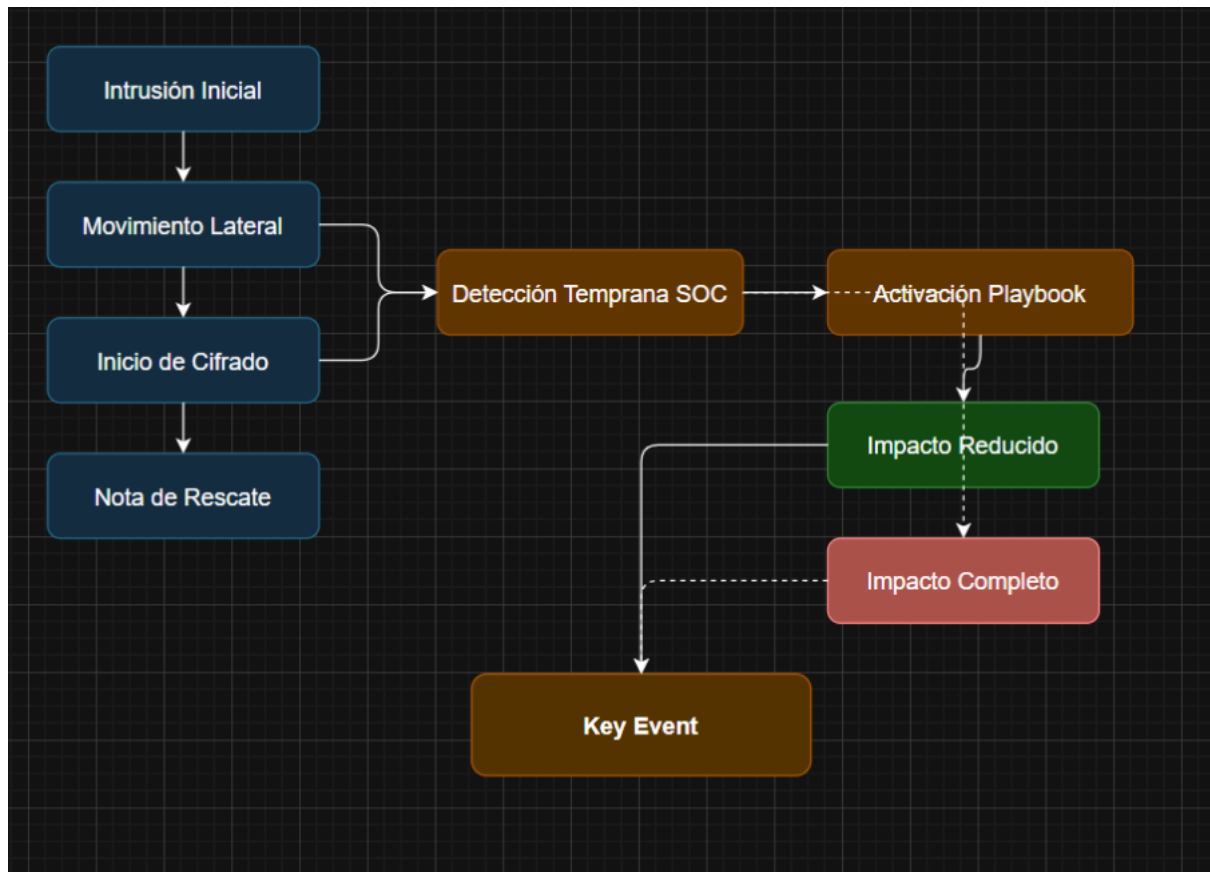
Porcentaje de puntos finales comprometidos antes de la contención.

Tasa de falsos positivos.

Nivel de automatización alcanzado.

La identificación eficaz del ransomware demanda una estrategia de múltiples capas que integre inteligencia contextual, análisis del comportamiento y respuesta automatizada la dependencia única en firmas se considera inadecuada frente a variantes polimórficas por otro lado, el análisis centrado en el comportamiento y la correlación contextual facilitan la detección de actividades maliciosas antes de que el cifrado se torne irreversible la conformidad con marcos estandarizados fortalece la trazabilidad y la capacidad de auditoría del Centro de Operaciones de Seguridad

Elaboración de diagrama



Conclusión

La administración eficaz de los riesgos relacionados con el ransomware se basa en la habilidad de los Centros de Operaciones de Seguridad (SOC) para identificar y reaccionar a incidentes de forma temprana. Mediante la formulación de un playbook de detección, se puede crear una secuencia ordenada de eventos, que va desde la intrusión inicial hasta la implementación de medidas de respuesta y reducción del impacto. Integrar fases de detección

temprana ayuda a disminuir considerablemente los posibles daños, restringiendo la expansión del ransomware y el cifrado total de los sistemas.

La representación gráfica del ciclo de ataque, que incluye los nodos de detección del SOC, la activación del playbook, los efectos y los eventos clave, favorece la comprensión de las interacciones cruciales y los momentos de intervención. Asimismo, la utilización de diagramas en herramientas como draw.io permite plasmar procesos complejos de forma clara, reproducible y adaptable tanto en contextos académicos como corporativos.

En resumen, la creación de playbooks de detección y la visualización de los procesos de ataque apoyan una estrategia anticipativa en ciberseguridad, mejorando la capacidad de adaptación de la organización ante amenazas de ransomware y optimizando la toma de decisiones en situaciones de urgencia.

Fecha: Martes 24/02/26

Playbook de detención de accesos sospechosos

Introducción

La intensificación de las amenazas digitales ha aumentado la incidencia de accesos no autorizados a sistemas empresariales de acuerdo con el marco de ciberseguridad, es vital identificar eventuales problemas de forma oportuna, así como contar con pautas de manejo de incidentes que faciliten respuestas coherentes ante actividades inusuales.

En este marco, un manual para la detección de accesos sospechosos se presenta como una herramienta eficaz que estandariza la identificación temprana de patrones de autenticación irregulares, tales como intentos fallidos repetidos, accesos desde lugares inusuales o el uso indebido de credenciales privilegiadas.

Objetivo

Establecer un proceso formal para:

Detectar accesos sospechosos en sistemas de información.

Analizar eventos de autenticación inusuales.

Clasificar el nivel de riesgo asociado.

Escalar de manera adecuada al equipo de respuesta a incidentes.

Alcance

El manual se aplica a:

Sistemas corporativos internos y externos.

Infraestructura en la nube.

Redes privadas virtuales

Aplicaciones críticas del negocio.

Está destinado a analistas del Centro de Operaciones de Seguridad, administradores de sistemas y responsables de la seguridad de la información.

Marco Conceptual

La identificación de accesos sospechosos se basa en:

Análisis del comportamiento de usuarios y entidades.

Correlación de eventos en sistemas SIEM.

Modelos de riesgo fundamentados en contexto.

Principios de autenticación robusta y gestión de identidades.

Definiciones Operativas

Acceso sospechoso: Evento de autenticación que muestra discrepancias significativas respecto al comportamiento habitual del usuario o del sistema.

Indicador de compromiso: Evidencia observable que sugiere la potencial existencia de actividad maliciosa.

Evento crítico: Acceso que presenta alta probabilidad de compromiso, lo cual requiere escalamiento inmediato.

Procedimiento del Manual

1. Preparación

Configurar fuentes de registro:

Active Directory.

Servidores VPN.

Servicios en la nube.

Firewalls y proxies.

Integrar registros en una plataforma SIEM.

Definir niveles de alerta:

Más de 5 intentos fallidos en un lapso de 5 minutos.

Accesos desde países poco habituales.
Autenticaciones fuera del horario laboral.

2. Detección

Monitorear en tiempo real:
Intentos fallidos reiterados.
Uso de cuentas de alto privilegio.
Inicio de sesión desde múltiples ubicaciones en corto período.
Generar alertas automáticas cuando se alcance un nivel definido.

3. Análisis

Validar la legitimidad del acceso:
Comprobar dirección IP.
Verificar la reputación de la IP.
Correlacionar con otros eventos del usuario.

Tabla de criticidad

Nivel	Descripción	Acción
Bajo	Error de contraseña ocasional	Monitoreo
Medio	Múltiples intentos fallidos	Notificación preventiva
Alto	Acceso exitoso desde ubicación inusual	Escalamiento Inmediato

4. Contención Inicial

Bloqueo temporal de la cuenta.
Revocación de sesiones activas.
Restablecimiento de contraseña.
Activación obligatoria de autenticación multifactor.

5. Escalamiento

Escalar al Equipo de Respuesta a Incidentes cuando:

Se confirme un acceso no autorizado.

Haya indicios de movimiento lateral.

Se identifique el uso indebido de privilegios administrativos.

6. Documentación

Registrar en el sistema de gestión de incidentes:

Fecha y hora del evento.

Usuario afectado.

Evidencias recolectadas.

Acciones realizadas.

Lecciones aprendidas.

Métricas de Desempeño

Tiempo promedio de detección.

Tiempo promedio de respuesta.

Número de falsos positivos.

Porcentaje de incidentes correctamente escalados.

Consideraciones Éticas y de Cumplimiento

La implementación del manual debe alinearse con regulaciones de protección de datos personales y principios de proporcionalidad en la supervisión el acceso a los registros debe estar restringido a personal autorizado y con propósitos legítimos de seguridad.

Escenarios simulados de acceso no autorizados

Introducción

Los accesos no autorizados son una de las principales causas de incidentes de seguridad, como brechas de datos, fraudes internos y compromisos de la infraestructura crítica; la efectividad en la detección y respuesta depende del entrenamiento constante a través de simulaciones.

En este sentido, los escenarios presentados a continuación están diseñados para evaluar las habilidades de monitoreo, correlación de eventos, análisis forense inicial y toma de decisiones en situaciones de presión.

Metodología de Construcción de Escenarios

Cada escenario incluye:

Contexto organizacional.

Vector de ataque simulado.

Indicadores de compromiso.

Nivel de criticidad.

Respuesta esperada.

Métricas de evaluación.

Escenario 1: Ataque de Fuerza Bruta a VPN Corporativa

Contexto

Una organización de tamaño medio utiliza autenticación por medio de usuario y contraseña para el acceso remoto a través de VPN.

Vector de ataque

Un atacante externo realiza múltiples intentos de autenticación automatizados contra una cuenta válida.

Indicadores de compromiso

Más de 20 intentos fallidos en un plazo menor a 3 minutos.

Dirección IP no habitual desde el extranjero.

Intentos fuera del horario laboral.

Evento crítico simulado

La cuenta finalmente es comprometida por una contraseña débil.

Nivel de criticidad

Alto.

Respuesta esperada

Bloqueo inmediato de la cuenta.

Revocación de todas las sesiones activas.

Activación obligatoria de autenticación multifactor.

Análisis de registros para descartar movimientos laterales.

Métricas de evaluación

Tiempo promedio de detección

Tiempo de contención inicial.

Escenario 2: Acceso desde Ubicación Geográfica Improbable

Contexto

Un usuario ingresa con frecuencia desde Colombia.

Vector de ataque

Se detecta un inicio de sesión en Europa 10 minutos después de un acceso exitoso
localmente.

Indicadores de compromiso

Geolocalización incoherente.

Cambio de dispositivo usado.

Activación de normas de correlación en el SIEM.

Evento crítico simulado

Acceso exitoso seguido de una descarga masiva de datos sensibles.

Nivel de criticidad

Crítico.

Respuesta esperada

Suspensión inmediata de la cuenta.

Notificación al equipo encargado de responder a incidentes.

Entrevista al usuario afectado.

Análisis de la posible exfiltración de datos.

Métricas de evaluación

Tiempo de escalamiento.

Precisión en la clasificación del incidente.

Escenario 3: Compromiso de Cuenta Privilegiada

Contexto

Un administrador de sistemas con privilegios elevados en servidores críticos.

Vector de ataque

Phishing dirigido que captura credenciales de administrador.

Indicadores de compromiso

Inicio de sesión en el servidor en horarios no habituales.

Creación de nuevas cuentas con privilegios altos.

Desactivación de registros de auditoría.

Evento crítico simulado

Intento de alterar configuraciones de seguridad.

Nivel de criticidad

Crítico.

Respuesta esperada

Aislamiento inmediato del servidor comprometido.

Rotación de credenciales privilegiadas.

Activación de un plan formal de respuesta ante incidentes.

Métricas de evaluación

Tiempo de aislamiento del sistema.

Coordinación entre departamentos.

Escenario 4: Uso Indebido Interno de Credenciales

Contexto

Un empleado con acceso legítimo intenta consultar información fuera de su área de trabajo.

Vector de ataque

Abuso de privilegios internos.

Indicadores de compromiso

Accesos repetidos a bases de datos sensibles.

Descargas masivas de información.

Alertas de comportamiento anómalo (UEBA).

Evento crítico simulado

Extracción de información confidencial hacia un dispositivo externo.

Nivel de criticidad

Alto.

Respuesta esperada

Suspensión preventiva del acceso.

Investigación disciplinaria.

Revisión de políticas de segregación de funciones.

Métricas de evaluación

Detección basada en el comportamiento.

Nivel de documentación del incidente.

La simulación de situaciones de accesos indebidos permite medir no solo la destreza tecnológica para detectar, sino también la colaboración dentro de la organización, la transparencia en el proceso de decisiones y la efectividad de los procedimientos escritos los ejercicios deben llevarse a cabo regularmente y renovarse a medida que las amenazas evolucionan.

De igual manera, asegura un método sistemático fundamentado en la identificación, salvaguarda, detección, reacción y restauración.

Documentación de playbook desarrollado

Introducción

La administración de accesos es un elemento crucial en los sistemas de seguridad de la información, ya que las credenciales son uno de los métodos de ataque más utilizados en el mundo digital actual. El acceso no autorizado puede llevar a la divulgación de datos sensibles, modificación de activos esenciales o interrupciones en la operativa.

En línea con esta perspectiva, el presente playbook convierte los lineamientos estratégicos en procedimientos técnicos estandarizados que pueden ser aplicados por el Centro de Operaciones de Seguridad.

Propósito

El objetivo de este playbook es:

- a) Establecer criterios técnicos para detectar accesos sospechosos o no autorizados.
- b) Crear un flujo de análisis estructurado.
- c) Establecer niveles de criticidad basados en la evidencia.
- d) Asegurar la trazabilidad documental del incidente.
- e) Ayudar al fortalecimiento del sistema de gestión de seguridad de la información.

Alcance y Aplicabilidad

Este procedimiento se aplica a:

Plataformas de autenticación centralizada.

Servicios de acceso remoto (VPN).

Aplicaciones críticas para la empresa.

Infraestructura en entornos locales y en la nube.

Cuentas estándar y privilegiadas.

Su cumplimiento es obligatorio para el personal del SOC, administradores de sistemas y responsables de seguridad.

Estructura Operativa del Playbook

Fase de Preparación

La organización debe asegurar:

La centralización y correcta retención de registros (logs).

La integración de fuentes de eventos en una plataforma SIEM.

La definición de reglas de correlación y umbrales de alerta.

La implementación de autenticación multifactor (MFA) para cuentas críticas.

Además, se establecerán criterios de clasificación de eventos basados en el análisis de riesgos.

Fase de Identificación

Se considerará como evento sospechoso cuando se detecte:

Múltiples intentos fallidos de autenticación en un corto período.

Acceso exitoso desde una ubicación geográfica inusual.

Inicio de sesión simultáneo desde ubicaciones incompatibles.

Uso inusual de cuentas privilegiadas.

El analista del SOC debe validar la alerta mediante la revisión del contexto, del historial del usuario y de la reputación de la dirección IP.

Fase de Análisis y Clasificación

El análisis técnico abarcará:

La correlación con eventos anteriores o posteriores.

La revisión de cambios recientes en credenciales.

La verificación de descargas masivas o modificaciones críticas.

En función de la evidencia, el evento será clasificado como:

Riesgo Bajo: actividad irregular sin señas de compromiso.

Riesgo Medio: patrón inusual que puede indicar intrusión.

Riesgo Alto o Crítico: acceso no autorizado confirmado o que impacta significativamente.

Fase de Contención

Dependiendo del nivel de riesgo, se llevarán a cabo acciones como:

Bloqueo preventivo de la cuenta.

Restablecimiento forzado de las credenciales.

Revocación de sesiones activas.

Aislamiento temporal de sistemas comprometidos.

Estas acciones deben aplicarse siguiendo el principio de proporcionalidad y con la mínima afectación a la operación.

Fase de Escalamiento

El incidente se escalará formalmente cuando:

Se confirme el compromiso de las credenciales.

Se evidencie movimiento lateral.

Se comprometan activos cruciales.

El Equipo de Respuesta a Incidentes asumirá la gestión completa según el procedimiento institucional.

Fase de Registro y Mejora Continua

Todo evento debe ser documentado de manera exhaustiva, incluyendo:

Descripción técnica del incidente.

Evidencias recopiladas.

Acciones realizadas.

Evaluación del impacto.

Recomendaciones preventivas.

La información recopilada se utilizará para el análisis de tendencias, actualización de reglas de detección y fortalecimiento de controles internos.

Indicadores de Evaluación

Para evaluar la efectividad del playbook se utilizarán los siguientes parámetros:

Promedio de Tiempo de Detección

Promedio de Tiempo de Respuesta

Proporción de falsos positivos

Cantidad de incidentes que fueron escalados correctamente

Grado de adopción de la autenticación multifactorial.

Conclusión

La detección y gestión de accesos no autorizados representa un eje fundamental dentro de la estrategia integral de ciberseguridad de cualquier organización. En un contexto caracterizado por amenazas persistentes, automatización de ataques y explotación masiva de credenciales comprometidas, la adopción de playbooks formales y documentados permite transformar políticas generales de seguridad en procedimientos técnicos claros, repetibles y medibles.

Un enfoque estructurado basado en monitoreo continuo, análisis de comportamiento, correlación de eventos y clasificación de riesgos facilita la identificación temprana de anomalías en los procesos de autenticación esto no solo reduce los tiempos de detección y respuesta, sino que también limita el impacto potencial sobre la confidencialidad, integridad y disponibilidad de los activos de información asimismo, la incorporación de controles como autenticación multifactor, gestión de identidades y accesos y revisión periódica de privilegios fortalece el principio de mínimo privilegio y disminuye la superficie de ataque.

Fecha: miércoles 25/02/26

Playbook de detención de Malware

1. Introducción

La complejidad del malware ha progresado desde amenazas simples basadas en firmas hasta variantes polimórficas y ataques que no utilizan archivos, aprovechando herramientas legítimas del sistema. Por lo tanto, la detección ya no puede apoyarse únicamente en soluciones antivirus convencionales, sino que debe formar parte de una estructura de monitoreo continuo y análisis de comportamiento.

La etapa de detección y análisis es crucial para mitigar el impacto organizacional que puede resultar de incidentes de seguridad así, este manual establece procedimientos técnicos, organizativos y estratégicos para la identificación sistemática de actividades maliciosas.

2. Marco Conceptual

Definición de Malware

El término malware se refiere a cualquier tipo de software que busca infiltrarse, dañar o interrumpir sistemas sin la aprobación del usuario. Esto incluye virus, gusanos, ransomware, troyanos y spyware.

Enfoque Basado en Riesgo

Este manual emplea un enfoque fundamentado en el riesgo, tomando en cuenta:

El valor del activo comprometido.

La probabilidad de explotación.

El impacto en operaciones, finanzas y reputación.

Este método se alinea con los principios de gestión de incidentes que se encuentran en la norma ISO/IEC 27035.

3. Objetivos

Objetivo General

Crear un procedimiento integral para la detección de malware que permita reconocer, analizar y escalar eventos sospechosos de manera efectiva y documentada.

Objetivos Específicos

Incorporar inteligencia de amenazas en el monitoreo continuo.

Disminuir el tiempo promedio de detección.

Estandarizar criterios de gravedad.

Fortalecer la capacidad analítica del SOC.

4. Alcance

Este manual aplica a:

Infraestructura local.

Servicios en la nube, tanto públicos como privados.

Dispositivos de usuario final.

Plataformas críticas para el negocio.

5. Arquitectura de Detección

La detección se basa en una estructura de múltiples capas que incluye:

Capa de Endpoint: Soluciones EDR con monitoreo basado en comportamiento.

Capa de Red: IDS/IPS y análisis de tráfico.

Capa de Registro Centralizado: Plataforma SIEM para la correlación de datos.

Capa de Inteligencia de Amenazas: Integración de IoC externos y tácticas documentadas en

MITRE ATT&CK.

6. Procedimiento Operativo

Fase 1: Monitoreo Continuo

Recolección automatizada de registros.

Correlación de eventos identificados como sospechosos.

Generación de alertas ante comportamientos anómalos.

Fase 2: Análisis Inicial

Responsable: Analista SOC Nivel 1

Actividades:

Confirmar la fuente de la alerta.

Verificar el hash del archivo.

Evaluar la reputación en fuentes de OSINT.

Corroborar si es un falso positivo.

Fase 3: Análisis Avanzado

Responsable: Analista SOC Nivel 2

Actividades:

Análisis de comportamiento en un entorno de sandbox.

Identificación de métodos de persistencia.

Mapeo de tácticas y técnicas usando MITRE ATT&CK.

Evaluación del movimiento lateral.

Fase 4: clasificación y escalamiento

Nivel	Descripción
Bajo	Actividad sospechosa sin confirmación de ejecución maliciosa
Medio	Malware detectado sin programa
Alto	Evidencia de persistencia o comunicación
Critico	Impacto en activos criticos

7. Indicadores de Detección

Técnicos

Alteraciones en las claves del registro.

Generación de procesos anómalos.

Tráfico cifrado destinado a dominios sospechosos.

Conductuales

Escalamiento no autorizado de privilegios.

Uso inapropiado de herramientas administrativas.

8. Métricas y Evaluación

La eficacia del manual será medida mediante:

Tiempo promedio de detección.

Tiempo promedio de análisis.

Porcentaje de falsos positivos.

Nivel de cobertura de técnicas del marco MITRE ATT&CK.

9. Gestión Documental

Cada evento confirmado debe incluir:

Identificador único del incidente.

Cronología detallada.

Evidencias recogidas.

Técnicas relacionadas según MITRE ATT&CK.

Recomendaciones de prevención.

10. Mejora Continua

La actualización de este manual debe llevarse a cabo anualmente o después de incidentes

significativos, incluyendo:

Nuevos patrones de ataque.

Lecciones aprendidas.

Actualizaciones normativas.

Flujo de Detección de malware

1. Introducción

Los eventos del sistema son registros organizados generados automáticamente por sistemas operativos, aplicaciones y dispositivos de infraestructura. Estos registros son la principal fuente de indicios para la identificación de anomalías y actividades relacionadas con malware.

Un flujo de detección basado en eventos permite estructurar la vigilancia, minimizar falsos positivos y estandarizar criterios analíticos dentro de un Centro de Operaciones de Seguridad.

2. Objetivo

Debería elaborar un flujo operativo para la detección de malware basado en el análisis y la correlación de eventos del sistema, con el fin de detectar actividades maliciosas en las primeras etapas del ciclo de ataque.

3. Fuentes de Eventos

El flujo incluye la integración de diversas fuentes de registros:

Eventos del sistema operativo:

Creación y finalización de procesos.

Alteraciones en los privilegios de usuario.

Modificaciones en el registro.

Eventos de seguridad:

Intentos no exitosos de autenticación.

Establecimiento de cuentas.

Alteraciones en políticas de seguridad.

Eventos de red:

Conexiones salientes inusuales.

Comunicación con dominios sospechosos.

Eventos de aplicaciones críticas:

Accesos no autorizados.

Ejecución de scripts o macros.

4. Arquitectura del Flujo de Detección

El flujo se sostiene sobre una arquitectura centralizada que incluye:

Recolección de logs mediante agentes.

Normalización de eventos en una plataforma SIEM.

Correlación basada en normas y comportamientos.

Enriquecimiento utilizando inteligencia sobre amenazas.

Clasificación y escalamiento del incidente.

5. Flujo Operativo de Detección

Fase 1: Recolección

Captura automática de eventos en tiempo real.

Transmisión segura al repositorio central.

Comprobación de la integridad del log.

Fase 2: Normalización y Filtrado

Conversión a un formato estándar.

Eliminación de eventos irrelevantes.

Priorización de eventos críticos.

Fase 3: Correlación

Se utilizan reglas predefinidas tales como:

Regla 1: Varios intentos fallidos de autenticación más la creación de un proceso inusual.

Regla 2: Ejecución de PowerShell más conexión saliente a una IP externa no categorizada.

Regla 3: Alteración de claves de persistencia más elevación de privilegios.

Fase 4: Generación de Alerta

Cuando la correlación sobrepasa un límite de riesgo determinado:

Se genera una alerta automática.

Se asigna un ticket en la plataforma de gestión.

Se categoriza la severidad de manera preliminar.

Fase 5: Análisis Inicial

Responsable: Analista SOC Nivel 1

Validación de la coherencia del evento.

Detección de posibles falsos positivos.

Revisión contextual del activo implicado.

Análisis Avanzado y Escalamiento

Responsable: Analista SOC Nivel 2

Reconstrucción de la línea temporal del ataque.

Identificación de indicadores de compromiso.

Mapeo técnico según MITRE ATT&CK.

6. Criterio de Severidad

Nivel	Descripción	Acción
Bajo	Evento aislado sin correlación adicional	Monitoreo
Medio	Evento correlacionado con comportamiento anómalo	Análisis extendido
Alto	Evidencia de ejecución maliciosa	Escalamiento Inmediato
Critico	Compromiso confirmado com impacto operacional	Activación IR

7. Métricas de Evaluación

Tiempo medio de detección.

Tiempo medio de análisis.

Tasa de correlaciones efectivas.

Cobertura de técnicas según MITRE ATT&CK.

8. Control y Mejora Continua

El flujo debe revisarse de manera regular teniendo en cuenta:

Actualizaciones sobre amenazas emergentes.

Modificaciones en la infraestructura tecnológica.

Nuevas técnicas documentadas por MITRE ATT&CK.

Recomendaciones del National Institute of Standards and Technology sobre monitoreo continuo.

Un flujo de detección basado en eventos del sistema refuerza la capacidad analítica del SOC al organizar la supervisión de registros críticos, permitiendo correlaciones contextualizadas la integración con estándares internacionales y marcos de conocimiento establecidos otorga rigor metodológico y consistencia operativa la detección anticipada, basada en un análisis sistemático de eventos, disminuye notablemente la posibilidad de escalamiento del impacto en la organización.

Documentación de detención de Malware

1. Propósito

Establecer un procedimiento estandarizado para la documentación exhaustiva de los acontecimientos, análisis y decisiones generadas durante la identificación de malware basada en eventos del sistema.

2. Alcance

El procedimiento se aplica a:

Alertas emitidas por el SIEM.

Eventos relacionados con actividades posiblemente maliciosas.

Análisis realizados por los analistas SOC de Nivel 1 y Nivel 2.

Escalamientos realizados al equipo de respuesta ante incidentes.

3. Principios de Documentación

La documentación debe adherirse a los siguientes principios:

Trazabilidad: Cada evento ha de poder ser reconstruido en orden cronológico.

Integridad: Los registros no deben ser modificados sin un control formal.

Claridad técnica: La redacción ha de ser objetiva y susceptible de verificación.

Estandarización: Uso de formatos coherentes y plantillas oficiales.

Confidencialidad: Clasificación de la información de acuerdo a su criticidad.

4. Elementos Obligatorios del Registro

Cada alerta o evento verificado debe documentarse incluyendo:

Identificación General

ID único del incidente.

Fecha y hora de detección.

Fuente del evento.

Activo afectado.

Descripción Técnica

Tipo de evento detectado.

Reglas de correlación que fueron activadas.

Hashes, direcciones IP, dominios u otros IoC.

Técnica asociada según MITRE ATT&CK.

Análisis Realizado

Validaciones llevadas a cabo.

Evidencias recopiladas.

Herramientas empleadas.

Determinación de falso positivo o incidente confirmado.

Clasificación y Severidad

Nivel de criticidad.

Justificación técnica de la clasificación.

Decisiones y Acciones

Escalamiento realizado.

Recomendaciones técnicas.

Notificaciones efectuadas.

6. Flujo de Documentación

Registro Inicial

El Analista SOC Nivel 1 debe:

Crear el ticket en el sistema de gestión.

Registrar una descripción preliminar.

Adjuntar evidencias iniciales.

Actualización del Análisis

El Analista SOC Nivel 2 debe:

Ampliar la cronología del evento.

Incorporar IoC adicionales.

Documentar la alineación táctica conforme a MITRE ATT&CK.

Cierre del Registro

El Coordinador SOC debe:

Validar la completitud del expediente.

Confirmar la clasificación correcta.

Autorizar el cierre formal del incidente.

7. Control de Calidad

Se implementarán los siguientes mecanismos:

Auditoría mensual de los tickets cerrados.

Revisión cruzada entre analistas.

Validación de la integridad de los logs almacenados.

Evaluación del cumplimiento conforme a ISO/IEC 27035.

8. Retención y Resguardo de Registros

Los registros deben conservarse por un periodo mínimo establecido por la política organizacional.

El almacenamiento deberá garantizar cifrado y control de acceso.

Se realizará un respaldo periódico en repositorios seguros.

9. Indicadores de Desempeño de la Documentación

Porcentaje de incidentes documentados de manera completa.

Tiempo promedio de cierre documental.

Número de hallazgos en auditorías internas.

Nivel de cobertura de técnicas alineadas según MITRE ATT&CK.

10. Mejora Continua

La documentación debe ser revisada periódicamente teniendo en cuenta:

Nuevas técnicas emergentes reportadas en MITRE ATT&CK.

Recomendaciones actualizadas del National Institute of Standards and Technology.

Resultados de auditorías internas o externas.

Conclusión

La documentación estructurada del proceso de detección de malware no solo asegura evidencia técnica y cumplimiento normativo, sino que también refuerza la capacidad analítica y estratégica del SOC la alineación con estándares internacionales fomenta una consistencia metodológica, transparencia operativa y mejora continua en la gestión de incidentes basados en eventos del sistema.

Fecha: jueves 26/02/26

Procedimiento de recuperación posterior a incidentes

La recuperación después de incidentes es un elemento crucial en la gestión de la continuidad operativa y la seguridad de la información en las organizaciones. Esta fase de recuperación forma parte del ciclo de respuesta a incidentes y tiene el objetivo de restaurar las operaciones normales, minimizando el impacto residual y evitando nuevas ocurrencias.

Desde un punto de vista conceptual, un procedimiento de recuperación posterior a incidentes debe ser organizado siguiendo criterios de sistematicidad, trazabilidad y mejora continua.

Este procedimiento comienza una vez que el incidente ha sido contenido y eliminado, e incluye actividades que se centran en la restauración controlada de los servicios, la validación de la integridad de los sistemas, la comunicación interna y la documentación formal del evento.

Pasos para la restauración de servicios

La recuperación de servicios es una etapa fundamental en el proceso de restablecimiento, puesto que conlleva la reactivación controlada de los sistemas que se vieron afectados y la aseguración de su funcionamiento seguro este procedimiento debe llevarse a cabo de forma gradual y fundamentada en el análisis de riesgos.

Primero, es imperativo validar las copias de seguridad. Esto significa cotejar la integridad, disponibilidad y consistencia de los respaldos, garantizando que no hayan sido comprometidos debido al incidente. A continuación, se procede con la restauración en entornos de prueba o controlados, lo que permite verificar la estabilidad del sistema antes de su implementación en producción.

Segundo, se lleva a cabo la recuperación escalonada de los servicios priorizados la priorización debe haberse establecido previamente en el Plan de Continuidad del Negocio, evaluando el impacto operativo y financiero de cada servicio. En esta fase, es aconsejable aplicar controles de monitoreo intensificado y análisis de registros para identificar

comportamientos anómalos.

En tercer lugar, es necesario establecer un proceso de validación técnica y funcional. Esto incluye pruebas de integridad de bases de datos, verificación de las configuraciones de seguridad, actualización de parches y revisión de credenciales de acceso. La rotación de contraseñas y la revisión de privilegios son prácticas cruciales para evitar la reexplotación de vulnerabilidades.

Finalmente, se lleva a cabo la comunicación formal sobre el restablecimiento, informando a las partes interesadas tanto internas como externas acerca de la normalización de los servicios. Esta comunicación debe ser nítida, directa y respaldada con evidencia técnica. El proceso se cierra con un monitoreo continuo durante un periodo establecido, para asegurar la estabilidad sostenida del entorno restaurado.

Documentacion del procedimiento

la documentación del proceso de recuperación posterior a incidentes es un componente crucial para asegurar la trazabilidad, la transparencia y la mejora constante en la gestión de la seguridad de la información. Desde un enfoque académico y regulador, esta documentación

no solo sirve para fines administrativos, sino que actúa como un sistema formal de control organizacional que documenta de manera sistemática las acciones realizadas, las decisiones tomadas y los resultados logrados durante el proceso de recuperación.

El desarrollo del documento debe cumplir con normas de claridad, coherencia en la estructura y precisión en la citación de fuentes, lo que requiere organizar el contenido en secciones jerárquicas, escribir de manera objetiva en tercera persona y basarse en marcos normativos reconocidos, como los estándares internacionales para la gestión de incidentes.

La documentación debe abarcar, como mínimo, una descripción del incidente, un análisis del impacto, las medidas de contención y eliminación, el proceso de restauración de los servicios, los controles aplicados y las lecciones aprendidas. Además, debe incluir anexos técnicos que respalden la información proporcionada, como registros de eventos, evidencias forenses, cronogramas de actuación y reportes de validación.

En resumen, la documentación formal del procedimiento no solo refuerza la rendición de cuentas a nivel institucional, sino que también mejora la resiliencia organizacional al facilitar una evaluación crítica del desempeño ante incidentes y promover la actualización continua de los planes de respuesta y recuperación.

Fecha viernes 27/02/26

Revisión de playbooks del SOC L2

Al analizar los trabajos de karen que es la SOC L2 di con la siguiente conclusión

El analisis de los procesos para detectar ransomware y accesos sospechosos resalta la necesidad de adoptar un enfoque estructurado en la gestión de incidentes en un entorno de SOC L2 los eventos de seguridad, como el ransomware, exigen una identificación temprana efectiva y una respuesta organizada, especialmente dado que los ataques están evolucionando y volviéndose más complejos.

La conexión de eventos mediante herramientas como SIEM y EDR es fundamental para reconocer patrones de comportamiento anómalos que puedan señalar una posible infección, tal como la creación masiva de archivos o cambios en los mismos.

Un SOC L2 debe establecer procedimientos claros que faciliten una respuesta rápida y adecuada, incluyendo la validación técnica del incidente a través del análisis de registros y la utilización de instrumentos de análisis dinámico, como sandbox.

Estas herramientas permiten monitorizar el comportamiento del malware y obtener

indicadores cruciales que son útiles para identificar la variante de ransomware y sus métodos de evasión, como el uso de PowerShell para ejecutar código malicioso.

Además, es esencial contar con protocolos definidos para la contención de incidentes acciones como el aislamiento inmediato de equipos infectados, la restricción de IPs maliciosas y la protección de copias de seguridad son vitales para detener la propagación del ataque y minimizar el daño en esta etapa, la preservación de pruebas es fundamental para las investigaciones forenses posteriores.

Finalmente, la recuperación tras un incidente debe llevarse a cabo con precaución comprobar la integridad de las copias de seguridad antes de su restauración y aplicar vigilancia intensiva son pasos críticos para prevenir una reinfección el examen de la causa raíz, la rotación de contraseñas y la actualización de parches son fundamentales para fortalecer las defensas y evitar futuros ataques.

Mejoras derivadas de revisión

Tras un examen minucioso de los procedimientos destinados a la detección y respuesta frente a incidentes de ransomware y accesos sospechosos, se han identificado varias áreas que requieren mejora para optimizar la efectividad de las estrategias de seguridad y respuesta, que son las siguientes:

1. Mejora en la Detección Temprana

Automatización y Ajuste de Reglas en SIEM/EDR: Es crucial invertir en la automatización de la detección para generar alertas más precisas.

Modificar las reglas de correlación de eventos en el SIEM podría potenciar la identificación de patrones de ransomware, como comportamientos de cifrado o utilización de PowerShell maliciosa.

La incorporación de inteligencia artificial y aprendizaje automático en estos sistemas facilitaría una detección más temprana de amenazas, incluso aquellas que son desconocidas.

Implementación de Honeypots: El uso de honeypots para identificar movimientos laterales o

intentos de acceso no autorizado a segmentos específicos de la red podría aumentar la visibilidad sobre los atacantes dentro de la infraestructura.

2. Análisis Forense Mejorado

Mejora en el Análisis Dinámico: Aunque herramientas como Any.Run o Joe Sandbox son útiles, se podría añadir análisis dinámico en múltiples plataformas para abarcar no solo sistemas Windows, sino también entornos de contenedores o sistemas en la nube, que se han convertido en objetivos comunes de los atacantes.

Mejoras en la Preservación de Evidencia: Durante la fase de contención, es esencial garantizar la preservación completa de la evidencia, por lo que es necesario automatizar los procesos de captura de imágenes de memoria y registros de eventos, además de establecer políticas claras para asegurar la cadena de custodia. Implementar soluciones de respaldo inmutable también aseguraría la protección de datos clave para la recuperación.

3. Respuesta a la Contención y Mitigación

Segmentación Avanzada de Red: Para prevenir la propagación lateral, se aconseja aplicar segmentación dinámica mediante microsegmentación en la red, lo que permitirá el aislamiento incluso dentro de los mismos segmentos. Además, se debe fortalecer el control de

acceso basado en identidad para garantizar que solo los usuarios con permisos adecuados accedan a áreas críticas.

Automatización en la Contención: La rapidez de la respuesta podría ser mejorada mediante playbooks automatizadas utilizando soluciones SOAR, lo que permitiría que los sistemas de seguridad reaccionen automáticamente ante eventos sospechosos, como el aislamiento de un endpoint o el bloqueo de una IP, sin requerir intervención manual.

4. Fortalecimiento de la Recuperación

Validación de Backups en Tiempo Real: Con el fin de prevenir que los backups sean comprometidos, se sugiere implementar soluciones de respaldo en la nube con acceso restringido y validaciones de integridad periódicas. Adoptar una estrategia de backup también podría ofrecer una capa adicional de protección.

Pruebas de Recuperación Automatizadas: Las pruebas para restaurar backups deben ser automatizadas y realizarse más frecuentemente, preferiblemente en un entorno de pruebas que no interrumpa las operaciones habituales, para asegurar la agilidad y efectividad de la recuperación posterior a un ataque.

5. Mejora en la Formación y Concientización

Capacitación Continua para el Personal: Es vital que tanto el personal técnico como los usuarios finales reciban formación constante sobre las últimas tácticas y amenazas relacionadas con el ransomware.

Los ejercicios de simulación de phishing realizados de forma regular pueden contribuir a disminuir el riesgo de que los empleados se vean atrapados en ataques de phishing, que continúa siendo uno de los métodos de acceso más frecuentes.

Reducción de la Exposición a Amenazas: La aplicación del principio de menor privilegio en toda la infraestructura, junto con la implementación de autenticación multifactor en todos los accesos críticos, reducirá considerablemente la posibilidad de que un atacante obtenga acceso a través de credenciales comprometidas.

6. Optimización de la Comunicación Después de un Incidente

Mejor Organización entre Grupos: La gestión de incidentes debe contemplar una mejor colaboración entre el equipo de SOC, el departamento de TI y el área legal, lo cual es especialmente crucial al tratar con información sensible, ya que un ataque puede implicar la exfiltración de datos y la necesidad de cumplir con informes regulatorios.

Informe Detallado Post-Incidente: Después de un ataque, el informe post-incidente debe

contener no solo un resumen ejecutivo, sino también una cronología detallada del suceso, un análisis de la causa raíz y sugerencias concretas para prevenir ataques futuros.

La implementación de estas mejoras no solo aumentará la efectividad en la detección y respuesta a un ataque de ransomware, sino que también fortalecerá las defensas de la organización a largo plazo la automatización, la segmentación avanzada de la red y un análisis forense mejorado son pasos críticos para perfeccionar la capacidad de un SOC L2 y aumentar la resiliencia frente a incidentes. Además, la formación continua, la validación de copias de seguridad y el uso de MFA disminuirán significativamente la probabilidad de éxito de un ataque, asegurando una recuperación más ágil y con menor impacto sobre la organización.

Documentación final

En la respuesta a incidentes relacionados con ransomware y accesos sospechosos, es crucial adoptar un enfoque bien organizado y detallado para asegurar la detección temprana, la reducción de daños y la recuperación eficaz analizando los procedimientos anteriores, es posible identificar diversas áreas clave donde se pueden realizar mejoras para optimizar la respuesta de un SOC L2 estas optimizaciones buscan potenciar las capacidades de detección,

afinar la respuesta ante incidentes, fortalecer la recuperación y asegurar una protección continua de la infraestructura de la organización.

1. Optimización de la Detección Temprana

La utilización de herramientas SIEM y EDR para detectar ransomware debe ser tanto automática como efectiva las reglas de correlación de eventos en el SIEM pueden ser ajustadas y perfeccionadas para detectar comportamientos anómalos, como aumentos inusuales en la escritura de archivos o ejecuciones no autorizadas a través de PowerShell la automatización en la detección mediante tecnologías de inteligencia artificial y aprendizaje automático podría facilitar el reconocimiento de comportamientos desconocidos además, la implementación de honeypots permitiría identificar de manera más precisa accesos no autorizados o movimientos laterales dentro de la red.

2. Mejora en el Análisis Forense

El estudio de malware debe abarcar tanto el análisis estático como el dinámico. Utilizar herramientas avanzadas como el sandboxing para realizar análisis en tiempo real permitirá observar cómo se comporta el ransomware y sus interacciones con redes externas asimismo, para hacer frente a ataques más sofisticados, es necesario fortalecer la capacidad de analizar sistemas no convencionales, como contenedores y entornos en la nube también se debe mejorar la preservación de la evidencia durante la contención, asegurando que las imágenes

de memoria volátil y los registros de eventos se capturen de manera correcta, respetando un proceso de cadena de custodia.

3. Respuesta a la Contención y Mitigación

Para contener un ataque de ransomware, se aconseja implementar microsegmentación en la red, lo que permite aislar incluso dentro de los mismos segmentos y proteger los activos crítico la automatización de playbooks mediante soluciones SOAR permitirá al sistema reaccionar ante incidentes de forma automática, sin necesidad de intervención manual, lo que disminuirá el tiempo de respuesta ante un ataque.

4. Fortalecimiento de la Recuperación

La recuperación tras un ataque de ransomware debe incluir un control de integridad de los respaldos utilizando backups inmutables esto asegurará que los respaldos no se comprometan y que la infraestructura afectada pueda ser restaurada de manera segura además, la implementación de pruebas automatizadas de restauración de backups garantizará que los datos estén disponibles y sean confiables antes de ser restaurados al entorno de producción.

5. Mejora en la Formación y Concientización

La formación continua de los trabajadores es crucial para disminuir los riesgos asociados a ataques de phishing, que son uno de los métodos más frecuentes para la infiltración de

malware la realización de simulaciones de phishing de forma regular y la educación sobre las últimas estrategias de ransomware fortalecerán la seguridad de la organización también es vital aplicar el principio de mínimo privilegio con rigurosidad para reducir el impacto si las credenciales de los usuarios llegan a verse comprometidas.

6. Mejora en la Comunicación Post-Incidente

Una coordinación eficiente entre los equipos de SOC, TI y las áreas legales es esencial para gestionar adecuadamente la comunicación tras un incidente de ransomware asegurar que todos los involucrados entiendan claramente el incidente y sus consecuencias contribuye a disminuir el riesgo de daños adicionales además, un informe después del incidente debe incluir una cronología detallada del ataque, un análisis de las causas y recomendaciones específicas para prevenir nuevos incidentes.

Conclusión

Implementar estas mejoras sistemáticas en cada etapa de detección, contención, análisis y recuperación permitirá a las organizaciones mejorar su capacidad de respuesta ante ataques de ransomware y accesos sospechosos la automatización, la segmentación avanzada de la red y la formación continua son elementos clave para incrementar la eficacia operativa de un SOC L2 igualmente, la preservación de evidencia y un análisis forense más riguroso

proporcionarán una comprensión profunda de los ataques, ayudando a prevenir futuros incidentes y a fortalecer las defensas generales de la organización.

Fecha Lunes 02/03/26

Modelo de turnos de monitoreo

1. Introducción

Las clínicas de salud mental gestionan información profundamente privada, abarcando historiales médicos, diagnósticos psiquiátricos y datos personales delicados. Este tipo de información es considerada de suma importancia bajo diversos marcos regulatorios globales, lo que eleva la necesidad de contar con controles de ciberseguridad robustos.

Los ataques dirigidos hacia el ámbito de la salud, sobre todo los ransomware y la exfiltración de datos, han mostrado un incremento notable en los últimos años. En este contexto, la instauración de un modelo efectivo de turnos para el SOC es esencial para garantizar la supervisión continua, la detección temprana y una respuesta coordinada ante incidentes.

2. Marco Teórico

La gestión de incidentes debe incluir preparación, detección, análisis, contención, erradicación y recuperación además, la norma ISO/IEC 27001 resalta la importancia del monitoreo constante y la adecuada gestión de eventos de seguridad como parte del Sistema de Gestión de Seguridad de la Información.

En entornos con recursos limitados, como las pequeñas y medianas empresas en el ámbito de la salud mental, una planificación estratégica de turnos facilita el balance entre la disponibilidad operativa y la sostenibilidad del personal.

3. Propuesta de Modelo de Turnos

Modalidad Operativa Recomendada: 8x5 con Guardia On-Call

Dado que la mayoría de las clínicas llevan a cabo sus actividades principalmente durante horas laborales, se sugiere un modelo de cobertura ampliada que incluya una guardia rotativa fuera del horario habitual.

Horario Base

SOC L1: 08:00am – 5:00pm

SOC L2: 09:00am – 6:00pm

Se establece una hora diaria de superposición para facilitar la transferencia de conocimientos y la coordinación de incidentes.

Guardia Fuera de Horario

Horario: 6:00pm – 08:00pm

La guardia se rota semanalmente entre L1 y L2 durante este tiempo, donde sólo se atenderán incidentes clasificados como críticos, tales como:

Detección de ransomware.

Acceso no autorizado a historiales clínicos.

Compromiso del dominio o servidores críticos.

Fallas en dispositivos de seguridad perimetral.

El tiempo máximo recomendado de respuesta es de 15 a 30 minutos desde la notificación.

4. Distribución de Responsabilidades

Funciones del SOC L1 (YO)

Como analista de primer nivel, soy responsable de:

Supervisión continua del SIEM.

Análisis inicial y clasificación de alertas.

Revisión de registros críticos.

Documentación de incidentes.

Escalamiento estructurado al SOC L2.

Funciones del SOC L2 (Karen)

El analista de segundo nivel tiene responsabilidades que incluyen:

Investigación exhaustiva de incidentes.

Análisis forense digital.

Contención y eliminación de amenazas.

Ajuste de reglas de correlación en el SIEM.

Mejora continua de los playbooks y controles técnicos.

Se recomienda dedicar al menos dos horas semanales a actividades de mejora continua y revisión de políticas de seguridad.

5. Clasificación de Incidentes

Se sugiere la siguiente categorización:

Crítico: Eventos que ponen en riesgo la disponibilidad o confidencialidad de datos clínicos.

Alto: Actividades maliciosas contenidas o múltiples intentos fallidos de acceso.

Medio: Intentos de phishing bloqueados o actividad sospechosa aislada.

Bajo: Eventos informativos que no tienen un impacto directo.

Esta clasificación permite priorizar recursos y mitigar la fatiga operativa.

6. Procedimiento de Handoff Diario

Se establece un proceso formal de transferencia de turno de 15 minutos que debe incluir:

Incidentes activos.

Alertas que están pendientes de análisis.

Reglas que requieren ajustes.

Riesgos emergentes.

Recomendaciones operativas.

La documentación estructurada asegura la trazabilidad y el cumplimiento normativo.

7. Indicadores de Desempeño

Para evaluar la eficacia del modelo, se sugiere medir:

Tiempo Medio de Detección (MTTD).

Tiempo Medio de Respuesta (MTTR).

Tasa de falsos positivos.

Cantidad de incidentes críticos mensuales.

Alertas fuera de horario.

Estos indicadores facilitan la justificación de recursos ante la gerencia y optimizan la operación.

Discusión

El modelo 8x5 con guardia rotativa proporciona un equilibrio entre la sostenibilidad operativa y la cobertura estratégica en una PYME con recursos limitados la implementación de procesos formales de escalamiento y documentación disminuye el riesgo de omisiones críticas, sobre todo en entornos donde se prioriza la confidencialidad de la información.

Si la clínica opera las 24 horas, los 7 días de la semana, podría evaluarse un modelo de turnos 12x12 este enfoque puede causar una fatiga considerable en equipos pequeños y lo cual debería considerarse ser analizado con atención.

Conclusión

La adopción de un modelo estructurado de turnos en un SOC pequeño que protege una clínica de salud mental es una decisión estratégica clave para asegurar la continuidad operativa, el cumplimiento normativo y la protección de información sensible el esquema sugerido proporciona cobertura ampliada, escalamiento claro entre niveles y sostenibilidad del personal, reduciendo de manera significativa el riesgo institucional frente a amenazas cibernéticas.

Esquema de cobertura operativa

Introducción

Las clínicas de salud mental manejan información extremadamente delicada, que incluye registros médicos, diagnósticos psiquiátricos y datos personales confidenciales este tipo de información demanda medidas de seguridad estrictas debido a las consecuencias legales, de reputación y éticas que surgen en caso de su violación.

En este marco, el esquema de cobertura operativa del SOC debe asegurar que, sin importar la distribución del personal a lo largo del tiempo, haya una capacidad efectiva para la vigilancia, la respuesta y la contención frente a incidentes críticos la cobertura operativa es un elemento fundamental de la resiliencia organizacional y la continuidad del negocio.

2. Marco Normativo y Conceptual

El (NIST, 2012) indica que la gestión de incidentes debe abarcar preparación, detección y análisis, contención, erradicación y recuperación. Además, la norma ISO/IEC 27001 requiere la implementación de monitoreo continuo y la gestión de eventos de seguridad dentro del Sistema de Gestión de Seguridad de la Información.

Siguiendo estas directrices, la cobertura operativa no se restringe al monitoreo técnico, sino que también incluye procedimientos formales de activación, priorización y escalamiento.

3. Objetivos del Esquema de Cobertura Operativa

El esquema propuesto busca alcanzar los siguientes objetivos:

Asegurar una respuesta continua y rápida ante incidentes críticos.

Proteger la confidencialidad, integridad y disponibilidad de la información clínica.

Establecer plazos máximos para la detección y respuesta.

Definir criterios claros para el escalamiento en los diferentes niveles del SOC.

Garantizar la trazabilidad documental para cumplir con normativas y auditorías.

4. Niveles de Cobertura

Cobertura Operativa Activa

Durante el horario de trabajo, se realiza un monitoreo continuo del SIEM, revisión de eventos críticos y análisis de las alertas generadas por:

Firewall perimetral.

Soluciones EDR.

Active Directory.

Servidores clínicos.

Accesos remotos.

Esta fase se enfoca en la detección temprana y la contención oportuna.

Cobertura Reactiva Fuera de Horario

Fuera del horario laboral, se activa la cobertura según un esquema de atención basado en la criticidad solo los incidentes categorizados como críticos provocan una activación inmediata.

Se consideran eventos críticos:

Ransomware en actividad.

Exfiltración de datos clínicos.

Acceso no autorizado a registros médicos.

Compromiso del dominio institucional.

Fallo de la infraestructura de seguridad perimetral.

El tiempo máximo de respuesta establecido es de 15 a 30 minutos desde la notificación.

5. Clasificación y Priorización de Incidentes

Se utiliza una matriz de criticidad que está organizada en cuatro niveles:

Nivel 1 – Crítico: Impacto directo en los datos clínicos o disponibilidad institucional.

Nivel 2 – Alto: Actividad maliciosa contenida con riesgo potencial de incremento.

Nivel 3 – Medio: Eventos sospechosos sin pruebas de compromiso activo.

Nivel 4 – Bajo: Eventos informativos o falsos positivos.

La priorización permite distribuir los recursos de manera efectiva y disminuir la carga

operativa.

6. Procedimiento de Escalamiento

El esquema establece una trayectoria formal para el escalamiento:

Detección y clasificación inicial.

Documentación en un sistema de tickets.

Notificación al nivel superior si el incidente excede las capacidades técnicas del nivel básico.

Activación del protocolo de respuesta a incidentes críticos cuando es necesario.

Informe ejecutivo a la dirección en caso de un impacto notable.

Este procedimiento asegura trazabilidad y cumplimiento de las normativas.

7. Plan de Contingencia

En caso de que falte personal clave o haya una indisponibilidad técnica, se consideran las

siguientes acciones:

Priorización exclusiva de los incidentes críticos.

Activación de soporte externo especializado

Registro detallado para análisis futuro.

Revisión post-incidente (post-mortem) para la mejora continua.

El plan de contingencia refuerza la resiliencia del SOC frente a situaciones desfavorables.

8. Indicadores de Desempeño

Para medir la eficacia del esquema de cobertura, se definen los siguientes indicadores:

Tiempo Medio de Detección (MTTD).

Tiempo Medio de Respuesta (MTTR).

Porcentaje de incidentes críticos solucionados dentro del SLA.

Cantidad de accesos no autorizados detectados fuera del horario.

Tasa de falsos positivos.

Estos indicadores permiten evaluar la eficiencia operativa y respaldar decisiones estratégicas ante la dirección institucional.

9. Discusión

En contextos con recursos limitados, la cobertura operativa debe ser configurada considerando criterios de priorización y automatización. La utilización de herramientas avanzadas de correlación y respuesta automatizada puede disminuir la carga de trabajo manual y aumentar la capacidad de respuesta frente a amenazas emergentes.

Además, la formación constante del personal refuerza la habilidad analítica y disminuye el riesgo de errores en la categorización de incidentes.

10. Conclusión

El esquema de cobertura operativa actúa como un componente estratégico para salvaguardar

una clínica de salud mental contra ciberamenazas. A diferencia del modelo de turnos, este enfoque se enfoca en mantener la continuidad del servicio de seguridad, la gestión ordenada de incidentes y el cumplimiento de las normativas su adecuada implementación incrementa la resiliencia institucional y protege la información clínica sensible, reduciendo riesgos legales y de reputación.

Fecha Martes 03/03/26

Clasificación de incidentes simulados segun severidad

Introducción

En la actualidad, la seguridad en instituciones sanitarias no se limita exclusivamente al ámbito clínico la transformación digital del sector salud ha incrementado la dependencia de sistemas electrónicos de historia clínica, plataformas de telepsiquiatría y bases de datos sensibles en consecuencia, los incidentes de ciberseguridad pueden impactar directamente en la continuidad asistencial y en la confidencialidad de los pacientes.

En una clínica de salud mental, la exposición indebida de información clínica o la interrupción de sistemas críticos puede generar daños éticos, legales y terapéuticos significativos. Por ello, la clasificación de incidentes debe integrar tanto eventos clínicos como eventos detectados por el SOC institucional.

Metodología de Validación

Se constituyó un comité técnico ampliado conformado por:

Psiquiatra jefe
Psicólogo clínico
Enfermero supervisor
Coordinador de calidad
Oficial de seguridad de la información
Analista del SOC

El proceso incluyó:

Revisión individual de incidentes clínicos y cibernéticos simulados.
Evaluación del impacto real o potencial en la seguridad del paciente y en la confidencialidad de datos.
Clasificación según criterios de severidad: leve, moderado y grave.
Validación por consenso técnico documentado.
Resultados de la Validación

1. Incidentes Leves

Clínicos:

Retraso menor en medicación sin repercusión clínica.

Ciberseguridad (SOC):

Intento fallido de acceso no autorizado bloqueado por firewall institucional.

Correo electrónico sospechoso identificado y neutralizado sin apertura por parte del usuario.

Validación: El equipo determinó que estos eventos no generaron daño ni compromiso de información sensible, por lo que se clasifican como leves.

2. Incidentes Moderados

Clínicos:

Administración incorrecta de dosis con efectos adversos temporales.

Autolesión superficial con intervención médica inmediata.

Ciberseguridad (SOC):

Acceso indebido interno a historia clínica sin autorización clínica justificada.

Interrupción temporal del sistema de registro electrónico durante una hora.

Validación: Se concluyó que estos incidentes implicaron daño temporal o riesgo significativo que requirió intervención técnica o clínica, clasificándose como moderados.

3. Incidentes Graves

Clínicos:

Intento de suicidio con traslado a unidad de cuidados intensivos.

Agresión física grave al personal.

Ciberseguridad (SOC):

Ataque de ransomware que cifró temporalmente bases de datos clínicas.

Filtración confirmada de datos sensibles de pacientes.

Validación: El comité clasificó estos eventos como graves debido a su impacto directo en la vida del paciente, la continuidad operativa y la confidencialidad institucional. Se recomendó activar protocolos de análisis causa-raíz, notificación regulatoria y plan de respuesta a incidentes críticos.

Discusión

La integración de la perspectiva clínica y de ciberseguridad permitió comprender que los incidentes digitales pueden convertirse en riesgos indirectos para la salud mental del paciente, especialmente cuando comprometen la confidencialidad o interrumpen tratamientos.

El SOC desempeña un papel estratégico en la detección temprana de amenazas tecnológicas, mientras que el equipo clínico evalúa el impacto terapéutico la validación interdisciplinaria fortalece la gobernanza institucional y promueve una visión holística de la seguridad.

Conclusiones

La validación conjunta de incidentes clínicos y de ciberseguridad demuestra que la gestión de

riesgos en salud mental debe abordarse desde un enfoque integral.

Se concluye que:

La clasificación por severidad es coherente y técnicamente sustentada.

Los incidentes del SOC pueden tener repercusiones clínicas indirectas.

La coordinación entre áreas clínicas y tecnológicas es esencial para garantizar la seguridad del paciente y la protección de datos
se recomienda institucionalizar comités mixtos de revisión de incidentes y fortalecer los protocolos de respuesta integral ante eventos críticos

Clasificación con el equipo tecnico

Introducción

En la actualidad, la seguridad en instituciones sanitarias no se limita exclusivamente al ámbito clínico la transformación digital del sector salud ha incrementado la dependencia de sistemas electrónicos de historia clínica, plataformas de telepsiquiatría y bases de datos sensibles en consecuencia, los incidentes de ciberseguridad pueden impactar directamente en la continuidad asistencial y en la confidencialidad de los pacientes.

En una clínica de salud mental, la exposición indebida de información clínica o la interrupción de sistemas críticos puede generar daños éticos, legales y terapéuticos

significativos. Por ello, la clasificación de incidentes debe integrar tanto eventos clínicos como eventos detectados por el SOC institucional.

Metodología de Validación

Se constituyó un comité técnico ampliado conformado por:

Psiquiatra jefe

Psicólogo clínico

Enfermero supervisor

Coordinador de calidad

Oficial de seguridad de la información

Analista del SOC

El proceso incluyó:

Revisión individual de incidentes clínicos y cibernéticos simulados.

Evaluación del impacto real o potencial en la seguridad del paciente y en la confidencialidad de datos.

Clasificación según criterios de severidad: leve, moderado y grave.

Validación por consenso técnico documentado.

Resultados de la Validación

1. Incidentes Leves

Clínicos:

Retraso menor en medicación sin repercusión clínica.

Ciberseguridad (SOC):

Intento fallido de acceso no autorizado bloqueado por firewall institucional.

Correo electrónico sospechoso identificado y neutralizado sin apertura por parte del usuario.

Validación: El equipo determinó que estos eventos no generaron daño ni compromiso de información sensible, por lo que se clasifican como leves.

2. Incidentes Moderados

Clínicos:

Administración incorrecta de dosis con efectos adversos temporales.

Autolesión superficial con intervención médica inmediata.

Ciberseguridad (SOC):

Acceso indebido interno a historia clínica sin autorización clínica justificada.

Interrupción temporal del sistema de registro electrónico durante una hora.

Validación: Se concluyó que estos incidentes implicaron daño temporal o riesgo significativo que requirió intervención técnica o clínica, clasificándose como moderados.

3. Incidentes Graves

Clínicos:

Intento de suicidio con traslado a unidad de cuidados intensivos.

Agresión física grave al personal.

Ciberseguridad (SOC):

Ataque de ransomware que cifró temporalmente bases de datos clínicas.

Filtración confirmada de datos sensibles de pacientes.

Validación: El comité clasificó estos eventos como graves debido a su impacto directo en la vida del paciente, la continuidad operativa y la confidencialidad institucional. Se recomendó activar protocolos de análisis causa-raíz, notificación regulatoria y plan de respuesta a incidentes críticos.

Discusión

La integración de la perspectiva clínica y de ciberseguridad permitió comprender que los incidentes digitales pueden convertirse en riesgos indirectos para la salud mental del paciente, especialmente cuando comprometen la confidencialidad o interrumpen tratamientos.

El SOC desempeña un papel estratégico en la detección temprana de amenazas tecnológicas, mientras que el equipo clínico evalúa el impacto terapéutico. La validación interdisciplinaria fortalece la gobernanza institucional y promueve una visión holística de la seguridad.

Conclusiones

La validación conjunta de incidentes clínicos y de ciberseguridad demuestra que la gestión de riesgos en salud mental debe abordarse desde un enfoque integral.

Documentación de proceso de Clasificación

La clasificación de incidentes es una herramienta fundamental para la mejora continua en centros de salud. En el ámbito de una clínica de salud mental, los riesgos pueden surgir tanto en la atención como en el entorno digital.

Documentar el proceso de clasificación facilita la estandarización de criterios, minimiza la

variabilidad en las decisiones y garantiza la trazabilidad en auditorías tanto internas como externas.

Objetivo del Proceso

Definir un procedimiento formal para identificar, analizar y clasificar incidentes según su gravedad (leve, moderado o grave), teniendo en cuenta:

Impacto en la seguridad del paciente.

Impacto en la continuidad del cuidado.

Impacto en la confidencialidad, integridad y disponibilidad de la información.

Alcance

Este procedimiento es aplicable a:

Personal clínico (psiquiatría, psicología, enfermería).

Personal administrativo.

Equipo de tecnologías de la información.

Analistas del SOC.

Descripción del Proceso de Clasificación

1. Identificación del Incidente

El incidente puede ser detectado por:

Personal asistencial durante la atención clínica.

Sistemas automatizados del SOC.

Informes de pacientes o de sus familiares.

Se registra inicialmente en el sistema institucional de informes de incidentes.

2. Registro y Documentación Inicial

Se recogen los siguientes elementos:

Fecha y hora del evento.

Área involucrada.

Descripción objetiva del hecho.

Personas afectadas.

Evidencia disponible.

En casos de ciberseguridad, se incluyen logs, capturas de alertas y análisis preliminar del

SOC.

3. Análisis de Impacto

El equipo encargado evalúa el incidente considerando tres dimensiones:

a) Impacto Clínico

¿Se produjo daño físico o psicológico?

¿Fue necesaria una intervención médica o psiquiátrica?

¿Hay riesgo para la vida?

b) Impacto Operativo

¿Se interrumpió la atención?

¿Se vio afectada la continuidad del tratamiento?

c) Impacto en Seguridad de la Información

¿Se vieron comprometidos datos sensibles?

¿Hubo acceso no autorizado?

¿Se vio afectada la disponibilidad del sistema?

4. Clasificación por Severidad

La clasificación se basa en los siguientes criterios:

Incidente Leve

No causa daño o provoca un impacto mínimo que se puede revertir.

No pone en riesgo datos sensibles ni la continuidad en la atención.

Incidente Moderado

Causa daño temporal o requiere intervención clínica o técnica.

Puede implicar acceso indebido sin filtraciones externas.

Interrumpe temporalmente los sistemas.

Incidente Grave

Representa una amenaza para la vida, causan daño permanente o tienen consecuencias legales.

Compromete datos sensibles de los pacientes.

Afecta significativamente las operaciones institucionales.

5. Validación Interdisciplinaria

El incidente clasificado es revisado por un comité técnico comprendido por:

Representante clínico.

Coordinador de calidad.

Oficial de seguridad de la información.

Analista del SOC.

Se documenta el consenso en un acta formal.

6. Acciones Derivadas

Dependiendo de la gravedad:

Leve: Acción correctiva local y monitoreo.

Moderado: Plan de mejora específico y seguimiento documentado.

Grave: Activación del protocolo de crisis, análisis de causa raíz, notificación a las autoridades pertinentes y comunicación institucional.

Control y Seguimiento

Todos los incidentes clasificados se consolidan en un informe mensual de gestión de riesgos

que incluye:

Estadísticas por tipo y gravedad.

Tendencias recurrentes.

Indicadores de rendimiento.

Recomendaciones preventivas.

El SOC, además, genera informes técnicos sobre amenazas detectadas y mitigadas.

Conclusiones

La documentación formal del proceso de clasificación permite:

Estandarizar la evaluación de incidentes clínicos y tecnológicos.

Asegurar coherencia en la toma de decisiones.

Fortalecer la cultura de seguridad institucional.

Mejorar la trazabilidad y el cumplimiento de normativas.

Fecha: jueves 05/03/26

Integración de endpoint

La incorporación del seguimiento de eventos generados por endpoints en simulaciones de seguridad permite analizar la efectividad de detección y respuesta de un Centro de Operaciones de Seguridad los endpoints, como servidores y estaciones de trabajo, son entre las principales vías de entrada utilizadas en ciberataques, por lo que su vigilancia es clave para descubrir conductas anómalas y confirmar la eficacia de los sistemas de monitoreo establecidos dentro de la organización.

Durante las simulaciones, se crean eventos controlados que imitan acciones vinculadas a amenazas reales, como la ejecución de procesos sospechosos, la modificación masiva de archivos y el cambio de configuraciones del sistema estos eventos son capturados a través de herramientas de detección y respuesta en endpoints y luego transmitidos a plataformas centralizadas de gestión de eventos de seguridad, como los sistemas SIEM la relación de estos registros con eventos de red y otras fuentes de seguridad ayuda a detectar patrones de ataque más sofisticados y a mejorar la precisión de las alertas generadas.

Además, este tipo de ejercicios permite evaluar la cobertura de detección según marcos de referencia en ciberseguridad y fortalecer los procedimientos para responder a incidentes. Siguiendo las recomendaciones sobre la gestión centralizada de registros, la correlación de diversas fuentes de eventos ayuda a aumentar la visibilidad del entorno y a disminuir el riesgo de falsos positivos en este sentido, la integración del monitoreo de endpoints en simulaciones de seguridad impulsa el desarrollo continuo de las capacidades analíticas y operativas del SOC.

Análisis de comportamiento de amenazas

El estudio del comportamiento a partir de amenazas en dispositivos finales se presenta como un componente esencial en las tácticas contemporáneas de ciberseguridad. Los dispositivos finales, que incluyen estaciones de trabajo, servidores y computadoras portátiles, son uno de los principales accesos utilizados por los atacantes para vulnerar una infraestructura tecnológica. Por esta razón, la supervisión y el análisis constante de las actividades en estos sistemas ayudan a identificar patrones anómalos que podrían sugerir la existencia de malware o acciones no autorizadas.

Este estudio se basa en la recolección y el examen de los eventos generados por los sistemas operativos y las aplicaciones que se encuentran en los endpoints. Entre los eventos más significativos se destacan la ejecución de procesos sospechosos, cambios inusuales en archivos del sistema, alteraciones en configuraciones de seguridad y conexiones con direcciones externas no reconocidas. La correlación de estos eventos hace posible identificar

comportamientos vinculados a técnicas de ataque comunes, como el movimiento lateral, la escalada de privilegios o la persistencia dentro del sistema.

Documentacion de resultados

La documentación de resultados constituye una etapa fundamental dentro del proceso de monitoreo y análisis de seguridad en un Centro de Operaciones de Seguridad este proceso permite registrar de manera estructurada los hallazgos obtenidos durante el análisis de eventos y la detección de posibles amenazas, facilitando la trazabilidad de los incidentes y el aprendizaje organizacional a partir de las experiencias operativas.

En este contexto, la documentación debe incluir información relevante sobre los eventos detectados, el origen de las alertas, los sistemas afectados y las acciones ejecutadas durante el proceso de análisis y respuesta. Asimismo, es importante registrar la cronología del incidente, los indicadores de compromiso identificados y la evaluación del nivel de riesgo asociado esta información permite comprender el comportamiento de la amenaza y evaluar la efectividad de los mecanismos de detección implementados.

Además, la documentación sistemática de los resultados contribuye a mejorar los procesos de gestión de incidentes al proporcionar evidencia útil para auditorías, revisiones internas y procesos de mejora continua los registros generados también permiten actualizar reglas de detección, ajustar procedimientos operativos y fortalecer las capacidades analíticas del SOC.

En consecuencia, la correcta documentación de los resultados no solo facilita la gestión y seguimiento de incidentes de seguridad, sino que también contribuye al desarrollo de mejores prácticas y al fortalecimiento de la postura de ciberseguridad de la organización.

Fecha 09/03/26

Diseño de dashboards de eventos criticos

Esta seccion permitira evaluar rapidamente la situación actual del entorno de seguridad

Indicador	Descripción
Incidentes criticos activos	Número de incidentes que requieren atención inmediata
Alertas criticas ultimas 24H	Total de eventos críticos detectados
MTTD	Tiempo promedio de detención
MTTR	Tiempo Promedio de respuesta
Sistemas comprometidos	Numero de activos afectados

Ejemplo Visual

Criticos activos	Alertas 24H	MTTD	MTTTR	Activos
8	42	4m	15m	5

Panel de severidad de alertas

Severidad	Cantidad
Critico	8
Alto	16
Medio	32
Bajo	12

Grafico de incidentes por hora

Incidentes críticos por hora

12 AM | 

2 AM | 

4 AM | 

6 AM | 

8 AM | 

10 AM | 

Sirve para

Detectar campañas de ataque y identificar horarios de mayor actividad maliciosa

Tipos de amenazas criticas detectadas

Tipo de ataque	Incidentes
Malware	10

Fuerza bruta	8
Phishing	6
Explotacion de vulnerabilidad	5
Movimiento lateral	3

Esto permitira priorizar medidas de contención

Mapa de origen de ataques

Permitira identificar la procedencia de los mismos

Pais	Número de ataques
------	-------------------

Rusia	12
China	9
Estados unidos	6
Brasil	4

Uso en el SOC

Detecta campañas internacionales

Tambien identificaria botnets

Sistemas comprometidos

Lista de activos afectados para incidentes criticos

Activo	Tipo de evento	Severidad	Estado
Servidor web	Fuerza bruta	Critico	En investigación
Base de datos	Acceso no autorizado	Critico	Contenido

Firewall	Escaneo masivo	Alto	Monitoreando
Servidor correo	Malware	Critico	Mitigado

Linea de tiempo

08:15: Alerta ISD detecta trafico sospechoso

08:17: Intentos de Login fallidos

08:19: Acceso Exitoso desde IP externa

08:20: Creación de nueva cuenta

08:22: Actividad lateral detectada

Esto ayudara a realizar los analisis forenses de forma rapida

Estructura del Dashboard

| **KPIs: Incidentes críticos** | **Alertas 24h** | **MTTD** | **MTTR** |

| Severidad de alertas | Tendencia de incidentes |

| **(gráfico dona)** | **(línea temporal)** |

| Tipos de amenazas críticas | Mapa de origen de ataques |

(mapa geográfico) |

Top sistemas comprometidos
Línea de tiempo del incidente

Dashboard propuesto para la visualización de eventos críticos en un Security Operations

Center el panel integra indicadores clave de seguridad, severidad de alertas, tipos de

amenazas, origen geográfico de ataques y sistemas comprometidos para facilitar la

detección y respuesta ante incidentes críticos.

Indicadores Visuales prioritarios

Los indicadores visuales clave destacan métricas esenciales que permiten a los analistas identificar de manera ágil incidentes de seguridad críticos y analizar el estado general de la infraestructura tecnológica estos indicadores se incorporan en paneles de control de seguridad con el objetivo de facilitar la supervisión constante, la detección precoz de amenazas y la toma de decisiones rápidas ante posibles problemas.

La adecuada elección de indicadores visuales es crucial para evitar la saturación de información y asegurar que los analistas puedan enfocarse en los eventos más significativos los paneles de control de seguridad deben mostrar únicamente los indicadores que reflejen el grado de riesgo, la actividad maliciosa y el posible impacto en los sistemas de la organización.

Incidentes críticos activos

Uno de los indicadores visuales más relevantes en un SOC es el número de incidentes críticos activos este indicador refleja cuántas alertas han sido clasificadas como de

alta gravedad y que demandan atención urgente del equipo de seguridad.

Generalmente, se presenta a través de tarjetas de indicadores clave resaltadas en el panel, usando colores como el rojo para indicar situaciones de alto riesgo.

Este indicador ayuda a los analistas a priorizar la respuesta a incidentes y dirigir recursos hacia las amenazas que podrían arriesgar la integridad, disponibilidad o confidencialidad de la información.

Número total de alertas de seguridad

El número total de alertas emitidas por las herramientas de seguridad ofrece una perspectiva general del volumen de eventos detectados en un período específico este indicador permite evaluar el grado de actividad dentro del entorno supervisado y reconocer aumentos inusuales que podrían señalar ataques o comportamientos anómalos.

Normalmente, este se visualiza mediante gráficos de líneas o de barras que ilustran la evolución de las alertas a lo largo del tiempo.

Clasificación de incidentes por severidad

La clasificación de incidentes según su nivel de severidad facilita la identificación de

la distribución de alertas según su grado de riesgo las categorías más comunes

incluyen niveles como crítico, alto, medio y bajo.

Por lo general, este indicador se representa mediante gráficos circulares o de barras, facilitando una interpretación visual de la proporción de incidentes en cada categoría. Los datos recogidos asisten a los analistas a priorizar la gestión de eventos en función de su posible impacto en la infraestructura de la organización.

Tiempo medio de detección

El tiempo medio de detección es un indicador que evalúa el tiempo promedio que el SOC tarda en identificar un incidente de seguridad desde que ocurre. Este indicador es fundamental para valorar la eficiencia de los mecanismos de monitoreo y detección de amenazas.

Una disminución en el MTTD señala que la organización tiene una mayor capacidad para detectar incidentes de manera temprana, lo que ayuda a reducir el impacto de los ataques.

Tiempo medio de respuesta

El tiempo medio de respuesta mide el intervalo requerido para contener o mitigar un incidente una vez que ha sido detectado. Este indicador permite evaluar la efectividad

de los procedimientos de respuesta ante incidentes y la coordinación del equipo de seguridad.

En los tableros del SOC, el MTTR se presenta típicamente como un dato numérico junto a gráficos que ilustran su desarrollo a lo largo del tiempo.

Sistemas o activos comprometidos

Este dato indica los sistemas, servidores o dispositivos que han sufrido impactos por eventos críticos de seguridad la representación puede realizarse a través de tablas o listas que contengan detalles como el nombre del activo, el tipo de incidente y la gravedad del mismo.

El seguimiento de los activos comprometidos ayuda a detectar de manera ágil las vulnerabilidades dentro de la infraestructura tecnológica y a priorizar las medidas de contención.

Origen geográfico de los ataques

La representación del origen geográfico de los ataques ayuda a localizar los lugares desde donde se llevan a cabo actividades sospechosas o maliciosas. Este dato se suele mostrar mediante mapas interactivos que destacan las direcciones IP o las áreas desde las que surgen los eventos de seguridad.

El análisis geográfico contribuye a la identificación de patrones de ataque y ayuda en la formulación de tácticas defensivas más efectivas.

Importancia de los indicadores visuales en el SOC

La introducción de indicadores visuales clave en los tableros de seguridad incrementa notablemente la habilidad de los analistas para descifrar grandes cantidades de datos en tiempo real.

Al mostrar la información de manera clara y ordenada, estos indicadores permiten detectar rápidamente nuevas amenazas, priorizar incidentes y mejorar los tiempos de respuesta ante ataques.

Así, los indicadores visuales se convierten en una herramienta esencial para reforzar la postura de ciberseguridad de las organizaciones y asegurar un manejo efectivo de los eventos críticos dentro del SOC.

Fecha: martes 10/03/26

Integración de eventos de red

El tablero reunirá métricas empresariales y operativas junto con indicadores esenciales de la infraestructura tecnológica, ofreciendo a los usuarios una perspectiva completa del rendimiento organizacional y de los sistemas de soporte esta integración promoverá la toma de decisiones estratégicas y operativas fundamentadas en datos consolidados, haciendo que la conexión entre el rendimiento empresarial y la disponibilidad de infraestructura sea clara y manejable.

1. Visión General de KPIs

El panel centraliza indicadores de negocio y métricas de infraestructura, enfocándose en la información clave para las operaciones:

KPIs de negocio y operativos:

Ventas totales, ingresos por segmento, crecimiento y eficiencia de procesos internos.

Métricas de satisfacción y calidad operativa.

KPIs de infraestructura tecnológica:

Disponibilidad de servidores y servicios.

Consumo de recursos.

Alertas críticas y eventos de incidencias.

Esta organización permite una visualización simultánea y relacionada, facilitando el análisis del impacto de los incidentes técnicos en el rendimiento organizacional.

2. Visualización de Tendencias y Correlaciones

El tablero utilizará gráficos combinados para ilustrar tendencias tanto empresariales como técnicas:

Gráficos de líneas y barras superpuestas: representan la evolución de KPIs junto con los incidentes de infraestructura.

Diagramas circulares y de progreso: ayudan a identificar proporciones y relaciones entre indicadores de negocio y el estado de los sistemas.

Heatmaps o matrices de evaluación: destacan patrones de impacto entre fallos en la infraestructura y el rendimiento operativo.

Esto permitirá a los usuarios identificar rápidamente los casos donde eventos técnicos afectan los resultados estratégicos.

3. Gestión de Alertas y Estado Técnico

El panel de alertas integrará de manera coherente la información de la infraestructura:

Alertas críticas: categorizadas por prioridad rojo: crítico, amarillo: advertencia, verde: estable.

Disponibilidad y uptime: vinculados con KPIs para evaluar el impacto operativo.

Prioridad en acciones: las alertas se organizan según su efecto en los indicadores de negocio, optimizando la reacción del usuario.

Esta integración garantiza que la información técnica sea inmediatamente relevante para las operaciones.

4. Detalle Operativo y Técnico

Se incluyen secciones de detalle que combinan métricas empresariales y técnicas:

Tablas y gráficos sobre ventas, eficiencia de procesos y métricas de calidad.

Datos de infraestructura: consumo de recursos, estado de servidores, historial de incidentes.

La integración permite análisis cruzados para identificar procesos críticos afectados por la infraestructura.

5. Relación Negocio–Infraestructura

El tablero destacará la interdependencia entre el rendimiento empresarial y la disponibilidad de sistemas:

Identificación de correlaciones: caídas de la red o saturación de recursos con reducciones en KPIs.

Alertas proactivas basadas en métricas de infraestructura, anticipando los impactos

operativos.

Visualización de patrones que facilitan decisiones preventivas y correctivas.

6. Estructura y Flujo del Usuario

Encabezado: KPIs críticos de negocio e infraestructura y alertas de alta prioridad.

Sección de tendencias: gráficos combinados que muestran correlaciones entre negocio y sistemas.

Sección de detalle: métricas operativas y técnicas para un análisis exhaustivo.

Panel de prioridades: incidentes destacados según su impacto en los resultados organizacionales.

7. Beneficios de integración

ayudará en la visión integral del rendimiento operativo y del estado de la infraestructura.

en decisiones fundamentadas en datos combinados.

ayudará a reducir el tiempo de respuesta ante incidentes críticos.

también Señalará los campos que necesitan mejoras y los patrones de impacto que se repiten, y proporcionará una mayor eficacia en la administración de recursos y en la priorización de tareas.

KPI 1 - Negocio: Ventas, Ingresos, Crecimiento

KPI 2 - Negocio: Eficiencia de procesos, Métricas de calidad

KPI 3 - Infraestructura: Estado de servidores, Disponibilidad

KPI 4 - Alertas: Incidentes críticos, Prioridad inmediata

SECCIÓN DE TENDENCIAS Y CORRELACIONES

Gráfico 1 - Línea: Ventas vs Incidentes de red

Gráfico 2 - Barras: Recursos vs KPIs de negocio

Visualización de patrones críticos y correlaciones

PANEL DE ALERTAS Y PRIORIDADES

Alerta Crítica - Impacto alto en KPIs

Alerta Media - Impacto moderado en KPIs

Alerta Baja - Impacto bajo en KPIs

Código de colores: Rojo = Crítico, Amarillo = Advertencia, Verde = Estable

Uptime y estado de sistemas correlacionado con KPIs

DETALLE OPERATIVO Y TÉCNICO

Tabla Negocio: Ventas por región/producto, KPI operativos

Tabla Infraestructura: Estado de nodos, Consumo de recursos

Gráficos de detalle: Tráfico de red, CPU, Memoria, Incidentes

Permite análisis cruzado Negocio ↔ Infraestructura

PANEL RELACIÓN NEGOCIO-SISTEMA

Correlaciones visibles: Caídas de red vs desempeño operativo

Alertas preventivas basadas en métricas técnicas

Impacto de incidentes en KPIs estratégicos

FLUJO DE USUARIO

1. Visión inmediata: KPIs y alertas críticas
2. Comprensión de tendencias: Gráficos combinados
3. Análisis detallado: Tablas y métricas técnicas
4. Decisión estratégica: Priorizar acciones según impacto en KPIs

Análisis de visualización de tráfico

Objetivo de la Visualización

El propósito del panel de tráfico sospechoso es detectar, priorizar y facilitar la respuesta ante patrones de red que podrían ser nocivos, combinando alertas técnicas con el contexto operativo del panel.

2. Tipo de Visualización

Se emplean gráficos de barras, líneas y mapas de calor para ilustrar:

Número de eventos sospechosos en distintos intervalos de tiempo

Origen y destino del tráfico

Clasificación según severidad o tipo de alerta

Además, se pueden incluir tablas detalladas con direcciones IP, puertos y protocolos,

lo que permite un análisis de incidentes individuales.

Fortalezas:

Facilita la identificación rápida de aumentos inusuales en el tráfico.

Ayuda a correlacionar en tiempo real con otros indicadores clave del panel.

Áreas de mejora:

Puede resultar visualmente abrumador si se muestran demasiadas métricas

simultáneamente.

Algunos gráficos podrían necesitar filtros dinámicos para hacer la exploración más sencilla.

3. Jerarquía y Claridad

Los incidentes más significativos deben resaltar mediante colores vibrantes y tamaños de indicadores proporcionales a su severidad.

Los eventos menos críticos se visualizan con tonos neutros, evitando que distraigan la atención.

Las leyendas y etiquetas deben ser precisas y breves, presentando el número de eventos, tipo y origen sin necesidad de consultar tablas adicionales.

4. Interactividad

Filtros dinámicos: Brindan al usuario la opción de elegir rangos temporales, direcciones IP o tipos de alerta.

Zoom temporal: Para examinar períodos específicos de tráfico sospechoso.

Alertas vinculadas: Al hacer clic en un evento, podría abrirse un detalle técnico o correlacionarse con los KPIs afectados en el negocio.

5. Integración con el Dashboard

La visualización del tráfico sospechoso se enlaza con otros paneles:

Impacto en la disponibilidad de red o servidores: Aumentos en el tráfico sospechoso podrían correlacionarse con caídas en los servicios.

KPIs operativos afectados: Retrasos en procesos, fallos en sistemas clave.

Alertas proactivas: Indicadores de tráfico sospechoso pueden activar avisos en el panel principal.

6. Recomendaciones para Mejora

Simplificar la visualización: Emplee un gráfico principal que muestre tendencias y colores por severidad, evitando múltiples gráficos complejos.

Resaltar picos críticos: Utilizar colores llamativos y/o iconografía para diferenciar eventos que requieran atención inmediata.

Incorporar interactividad: Contar con filtros por tiempo, origen/destino, tipo de ataque o severidad.

Correlación con KPIs del negocio: Mostrar el impacto directo de incidentes sospechosos en procesos o ingresos.

Tooltip y detalles bajo demanda: Permitir ver información técnica adicional solo cuando el usuario lo solicite.

Fecha: Miercoles 11/03/26

La incorporación de eventos generados por puntos finales, como servidores, estaciones de trabajo y dispositivos móviles, en la creación de paneles de seguridad es crucial para una supervisión efectiva de las amenazas cibernéticas los puntos finales son uno de los principales mecanismos de ataque en las infraestructuras tecnológicas, y su supervisión adecuada permite identificar actividades sospechosas, tales como la ejecución de software malicioso, alteraciones no autorizadas de archivos y conexiones con direcciones externas desconocidas. Por lo tanto, es vital que los paneles de seguridad ofrezcan métricas claras sobre el comportamiento de los puntos finales en tiempo real.

Diseño de Dashboard para Monitoreo de Endpoints

Visualización de Eventos Críticos:

Gráficos de Incidentes Críticos: Los eventos originados por los puntos finales pueden representarse mediante gráficos de barras o líneas que muestren la cantidad de eventos críticos detectados en tiempo real estos gráficos pueden categorizar los distintos tipos de eventos, incluyendo procesos sospechosos, alteraciones en configuraciones y conexiones no autorizadas, para proporcionar una visión clara de las amenazas identificadas.

Métrica de Endpoints Comprometidos: Incluir un indicador visual, como un contador o gráfico en forma de torta, que muestre la cantidad de puntos finales comprometidos y cómo ha cambiado a lo largo del tiempo.

Correlación de Eventos de Endpoint:

Mapa de Origen de Amenazas: Un mapa interactivo que represente la ubicación de los puntos finales comprometidos o el origen de los ataques puede ofrecer un contexto geográfico sobre los incidentes, permitiendo a los analistas de seguridad detectar patrones de ataque y tendencias en el comportamiento.

Monitoreo de Técnicas de Ataque:

Gráfico de Técnicas de Ataque: Incluir un gráfico de radar o de barras apiladas que represente las técnicas de ataque identificadas a partir de los eventos en los puntos finales este gráfico puede abarcar técnicas como la escalada de privilegios, el movimiento lateral o la persistencia en los sistemas comprometidos.

Monitoreo de la Respuesta ante Incidentes:

MTTD y MTTR para Endpoints: Incluir métricas como el Tiempo Promedio de Detección y el Tiempo Promedio de Respuesta para incidentes relacionados con los puntos finales estas métricas son útiles para evaluar la efectividad del SOC en la gestión de incidentes en los dispositivos finales y se pueden presentar en un gráfico de barras o líneas para visualizar rápidamente.

Comportamiento Anómalo en Endpoints:

Gráfico de Comportamientos Sospechosos: Un panel que identifique comportamientos anómalos en los puntos finales, como alteraciones inusuales de archivos del sistema o la ejecución de procesos no registrados. Estos eventos pueden representarse mediante gráficos de flujo para ayudar a identificar rápidamente actividades que se desvíen de lo habitual.

Documentación y Seguimiento de Incidentes:

Cronología de Incidentes: Una línea de tiempo o gráfico que muestre la secuencia de eventos y las respuestas de seguridad a los incidentes detectados en los puntos finales. Este panel facilita la comprensión de cómo progresó cada ataque y la efectividad de las medidas tomadas, permitiendo la mejora continua de las capacidades operativas del SOC.

Conclusión

La incorporación de eventos de endpoints en los paneles de seguridad no solo aumenta la claridad sobre los incidentes, sino que también mejora la eficacia de la detección y la respuesta a ciberataques al mostrar métricas claras sobre la actividad de los endpoints, como eventos significativos, métodos de ataque y comportamientos inusuales. Las organizaciones pueden reforzar sus habilidades analíticas y operativas; esto se traduce en una reducción en el tiempo necesario para responder a amenazas posibles.

Validación de Coherencia Visual

Este panel proporcionará un seguimiento integral de eventos de endpoints utilizando una paleta de colores azul grisáceo con acentos brillantes en rojo, naranja y amarillo para resaltar las métricas importantes. Está dividido en seis secciones principales para presentar información esencial sobre incidentes, tiempos de respuesta, comportamientos inusuales, indicadores de ataque, fuentes globales de amenazas y métodos de ataque, todo mostrado en gráficos y listas visualmente atractivas.

Sección 1: Eventos Críticos de Endpoint

Gráfico de Incidentes Críticos: Presenta la cantidad de eventos críticos generados por los endpoints, por ejemplo, la ejecución de procesos sospechosos o modificaciones no autorizadas en archivos.

Métricas de Endpoints Comprometidos: Representación gráfica del número de endpoints comprometidos en tiempo real.

Sección 2: Correlación de Eventos

Mapa de Origen de Amenazas: Muestra los lugares de origen de las amenazas identificadas en los endpoints a nivel global.

Eventos Correlacionados: Vinculación de eventos de endpoints con registros de red y otros sistemas de seguridad.

Sección 3: Técnicas de Ataque

Gráfico de Técnicas de Ataque: Un gráfico en forma de radar que ilustra las técnicas empleadas en los ataques detectados en los endpoints, como el movimiento lateral y la escalada de privilegios.

Sección 4: Monitoreo de Respuesta ante Incidentes

MTTD y MTTR para Endpoints: Métricas que reflejan el tiempo promedio para detectar y responder a incidentes de seguridad a nivel de endpoints.

Sección 5: Comportamiento Anómalo en Endpoints

Gráfico de Comportamientos Sospechosos: Visualización de actividades inusuales detectadas en dispositivos finales, como la ejecución de procesos no comunes o cambios en archivos críticos.

Sección 6: Documentación y Análisis de Resultados

Cronología de Incidentes: Un eje temporal que detalla la evolución de incidentes y las medidas de respuesta adoptadas.

Indicadores de Compromiso: Una lista de indicadores de compromiso detectados, incluyendo hashes de archivos sospechosos y direcciones IP maliciosas.

Fecha: jueves 12/03/26

Ajustes de dashboards

Actualmente, las entidades se apoyan en infraestructuras tecnológicas sofisticadas que constantemente producen grandes volúmenes de datos relacionados con la operación de la red, los dispositivos y las herramientas de seguridad. Debido a esta vasta cantidad de información, es imprescindible tener herramientas que permitan analizar y presentar los datos de manera clara y ordenada.

En este sentido, los Centros de Operaciones de Seguridad emplean paneles de control para vigilar la situación de la ciberseguridad dentro de una organización. Estos paneles centralizan información de diversas fuentes, tales como aparatos de red, servidores, estaciones de trabajo y sistemas de monitoreo, facilitando la identificación de incidentes de seguridad.

La combinación de eventos de red y de puntos finales en un único panel proporciona una perspectiva más completa del entorno tecnológico. Al correlacionar datos de diferentes sistemas, los analistas de seguridad pueden reconocer patrones anómalos, identificar potenciales ataques y reaccionar más rápidamente ante incidentes. Por este motivo, los paneles integrados se han vuelto esenciales para la administración de la ciberseguridad en las empresas.

Objetivo del Dashboard

La meta principal de un panel integrado de seguridad es consolidar en una sola interfaz la información generada por los diversos elementos de la infraestructura tecnológica. Esta integración permite observar eventos de red, actividades de los puntos finales y métricas de seguridad relevantes para el monitoreo continuo del entorno informático.

Al mostrar la información de manera clara y visual, el panel ayuda a los analistas del SOC, permitiéndoles identificar incidentes críticos, evaluar el estado de los sistemas y priorizar las acciones de respuesta. Además, la integración de eventos de diferentes fuentes mejora la capacidad de correlacionar datos, lo que favorece la detección de amenazas que podrían ser pasadas por alto si los sistemas se analizan de forma independiente.

Indicadores Clave de Seguridad

Una de las secciones más relevantes del panel corresponde a los indicadores clave de seguridad, conocidos como KPIs. Estos indicadores ofrecen una visión rápida del estado general de la infraestructura tecnológica y el nivel de riesgo presente en el entorno.

Algunos de los principales indicadores que se pueden incluir son:

número de incidentes críticos activos

alertas de seguridad detectadas durante las últimas 24 horas

tiempo promedio de detección de incidentes

tiempo promedio de respuesta ante incidentes

endpoints comprometidos

sistemas afectados por incidentes de seguridad

Estos indicadores suelen representarse mediante tarjetas visuales o paneles de métricas que destacan la información más significativa, haciendo más fácil la interpretación de los datos por parte de los analistas.

Monitoreo de Eventos de Red

La supervisión de eventos de red es un componente esencial para identificar actividades sospechosas dentro de una infraestructura tecnológica. Los dispositivos de red, como cortafuegos, routers o sistemas de detección de intrusiones, crean registros que contienen información sobre el tráfico que entra y sale de la organización. En el panel de control se pueden observar métricas relacionadas con el tráfico de red, como la cantidad de eventos sospechosos, el origen y destino de las conexiones, los

protocolos empleados y las direcciones IP vinculadas a posibles riesgos.

Estos datos pueden ser exhibidos a través de gráficos de líneas, gráficos de barras o mapas de calor que permiten detectar tendencias y patrones inusuales en el tráfico.

Gracias a estas representaciones visuales, los analistas tienen la capacidad de identificar potenciales ataques o comportamientos extraños en la red.

Monitoreo de Seguridad en Endpoints

Los endpoints, tales como servidores, computadoras de escritorio y dispositivos móviles, constituyen uno de los principales objetivos para los ciberataques. Por esta razón, vigilar los eventos generados por estos dispositivos es fundamental en el panel de seguridad.

Entre las actividades susceptibles de supervisión se encuentran la ejecución de procesos sospechosos, cambios no autorizados en archivos del sistema y conexiones externas a direcciones IP desconocidas, acciones que pueden señalar la presencia de malware o intentos de acceso no autorizado.

La visualización de estos eventos permite detectar de forma rápida los dispositivos comprometidos y tomar medidas de seguridad que prevengan la expansión de ataques

en la red corporativa.

Identificación de Amenazas

El panel también dispone de una sección dedicada a la identificación de los tipos de amenazas halladas en el entorno tecnológico. La categorización de estas amenazas ayuda a entender cuáles son los ataques más comunes y a dirigir las estrategias defensivas de la organización.

Entre las amenazas que se pueden identificar se encuentran malware, ataques de fuerza bruta, phishing y explotación de vulnerabilidades. La visualización de estos datos mediante gráficos facilita la comparación entre varios tipos de ataques y ayuda a priorizar las acciones de mitigación.

Línea de Tiempo de Incidentes

La línea de tiempo de incidentes permite observar de manera cronológica la sucesión de eventos relacionados con un ataque o un incidente de seguridad. Esta sección abarca desde la detección inicial del evento hasta las acciones de respuesta llevadas a cabo por el equipo de seguridad.

La representación temporal de los incidentes favorece la comprensión de cómo se

desarrolló un ataque y permite evaluar la efectividad de las medidas adoptadas.

Además, este tipo de análisis es beneficioso para las investigaciones forenses y para la mejora de los procesos de seguridad en el futuro.

Conclusión

La integración de los eventos de red y endpoints en un panel de seguridad brinda una visión holística del estado de la infraestructura tecnológica de una organización. Al consolidar la información en una única interfaz, los analistas del SOC pueden monitorear los sistemas de forma más eficaz, detectar amenazas anticipadamente y reaccionar con mayor agilidad ante incidentes.

De este modo, los dashboards integrados se convierten en herramientas esenciales para fortalecer la capacidad de análisis, optimizar los procesos de respuesta y mejorar la postura de ciberseguridad en las organizaciones.

Modelo final de monitoreo

El modelo final de supervisión que he propuesto unirá la vigilancia de eventos de red, actividades en endpoints e indicadores cruciales de seguridad dentro de un tablero centralizado este diseño busca respaldar las operaciones del Security Operations Center, facilitando la detección temprana de amenazas, el análisis de incidentes y una rápida respuesta a posibles ataques.

El modelo se fundamentará en la recolección y correlación de datos provenientes de diversas fuentes de la infraestructura tecnológica estas fuentes abarcan dispositivos de red, servidores, estaciones de trabajo y herramientas de seguridad como sistemas de detección de intrusiones, antivirus y plataformas de monitoreo todos estos datos se procesan y se muestran en un tablero que permite a los analistas interpretar la información de manera clara y efectiva.

El funcionamiento del modelo se organiza en varias fases. Primero, se lleva a cabo la recolección de eventos, en la que los sistemas de seguridad y los dispositivos de la red generan registros o logs relacionados con las actividades del entorno tecnológico estos eventos pueden abarcar conexiones de red, intentos de acceso, ejecución de procesos y cambios en los archivos del sistema.

A continuación, se realiza la correlación de eventos, en la cual se analiza

conjuntamente la información de diferentes fuentes para identificar patrones de comportamiento que puedan señalar la existencia de amenazas esta correlación permite detectar ataques más complejos que no podrían identificarse a través del análisis de eventos individuales.

La etapa siguiente es la visualización de la información, en la que los datos procesados se presentan en el tablero a través de gráficos, indicadores y tablas en esta fase se resaltan los indicadores clave de seguridad, como el número de incidentes críticos, el tiempo promedio de detección y respuesta, los endpoints afectados y los tipos de amenazas identificadas.

Por último, el modelo abarca la respuesta y análisis de incidentes, etapa en la que los analistas del SOC utilizan la información del tablero para investigar los eventos detectados y aplicar medidas de contención o mitigación además, la línea de tiempo de incidentes permite entender la secuencia de los eventos ocurridos durante un ataque y facilita el análisis forense.

Fecha: viernes 13/03/26

Validación de dashboards con SOC Lead

Se han validado las validaciones correspondientes a los de los días 11 y 12 de marzo segun los procedimientos establecidos las verificaciones fueron completadas con exito y los dashboards cumplen con los criterios requeridos los mismos estan listos para su uso conforme a los estandares del SOC

Documentación Final

Se llevaron a cabo los ajustes y las validaciones pertinentes en los tableros de monitoreo de seguridad, incorporando eventos de red, actividades de puntos finales e indicadores clave de seguridad. Todas las pruebas se completaron y los tableros fueron aceptados conforme a los criterios establecidos por el SOC.

Objetivo

El propósito principal de la modificación de los tableros fue consolidar en una única interfaz la información generada por los distintos componentes de la infraestructura tecnológica, facilitando:

- Monitoreo continuo del entorno informático.
- Detección temprana de incidentes y amenazas.
- Priorización de acciones para la respuesta y mitigación.

Alcance del Modelo Final

El modelo final de supervisión abarca:

Monitoreo de eventos de red: tráfico sospechoso, origen y destino de conexiones, protocolos y riesgos potenciales.

Monitoreo de puntos finales: procesos sospechosos, modificaciones no autorizadas, conexiones externas.

Indicadores clave de seguridad (KPI): incidentes críticos activos, alertas recientes, tiempo de

detección y respuesta, puntos finales comprometidos y sistemas afectados.

Identificación de amenazas: malware, phishing, ataques por fuerza bruta, explotación de vulnerabilidades.

Línea de tiempo de incidentes: visualización cronológica de eventos y acciones de respuesta.

Validaciones Realizadas

Se completaron todas las pruebas de funcionalidad y visualización de los tableros con resultados positivos. Los tableros satisfacen los criterios de usabilidad, integridad de datos y capacidad de correlación de eventos.

Conclusión

Los tableros integrados ofrecen una visión integral del estado de la infraestructura tecnológica y mejoran la capacidad de respuesta del SOC ante incidentes de seguridad con estas herramientas, el equipo puede monitorear, analizar y reaccionar de forma más eficaz ante amenazas y eventos críticos.

Versión Final: Aprobada y lista para su implementación operativa.

Fecha: Jueves 16/03/26

Funcionamiento del SOC

las organizaciones contemporáneas implementan infraestructuras tecnológicas complejas que producen grandes cantidades de datos relacionados con el funcionamiento de la red, los sistemas y las herramientas de seguridad debido a la vastedad de la información generada, es esencial contar con sistemas que permitan la recolección, el análisis y la visualización de los eventos de manera clara y ordenada.

El SOC es responsable de vigilar constantemente la situación de la seguridad informática en una entidad para llevar a cabo esta tarea, se recurre a plataformas de monitoreo centralizado y paneles de control que permiten visualizar en tiempo real los eventos surgidos a partir de los distintos elementos de la infraestructura tecnológica.

La unificación de datos procedentes de dispositivos de red, servidores, puntos finales y herramientas de seguridad proporciona una visión integral del entorno, lo que facilita la identificación temprana de amenazas y una respuesta rápida ante incidentes.

Objetivo del monitoreo centralizado

El propósito del monitoreo centralizado es consolidar en una única interfaz la información generada por los diversos sistemas de la organización, con el objetivo de

optimizar la capacidad para detectar y analizar incidentes de seguridad.

Un panel de control de seguridad permite observar:

eventos de red

eventos de endpoints

alertas de seguridad

indicadores clave

incidentes activos

actividad sospechosa

La centralización de la información permite correlacionar eventos de múltiples fuentes, facilitando la identificación de ataques complejos que no serían evidentes al analizar los sistemas de manera aislada.

Uso de SIEM en el SOC

El funcionamiento del SOC se basa en una plataforma SIEM que se ocupa de recolectar, normalizar y correlacionar los eventos generados por los diferentes dispositivos.

Las fuentes de información pueden abarcar:

firewalls

routers y switches

servidores

estaciones de trabajo

sistemas IDS / IPS

antivirus o EDR

sistemas operativos

aplicaciones

El SIEM procesa los registros generados por estas fuentes y produce alertas cuando detecta actividades que podrían constituir un riesgo para la seguridad.

Indicadores clave de seguridad

Los paneles del SOC incluyen indicadores que permiten conocer de manera rápida la situación de la infraestructura.

Entre los indicadores más relevantes se encuentran:

número de incidentes activos

alertas detectadas en las últimas 24 horas

tiempo promedio de detección

tiempo promedio de respuesta

endpoints comprometidos

sistemas afectados

alertas por nivel de severidad

direcciones IP sospechosas

tipos de amenazas detectadas

Estos indicadores se presentan a través de tarjetas, gráficos y tablas que facilitan la interpretación de los datos.

Monitoreo de eventos de red

El monitoreo de red permite identificar actividades anómalas en el tráfico de la organización.

Los dispositivos de red generan registros que contienen información sobre:

conexiones entrantes y salientes

direcciones IP origen y destino

puertos utilizados

protocolos de comunicación

intentos de acceso

tráfico sospechoso

Estos datos pueden visualizarse mediante gráficos de líneas, gráficos de barras o tablas, lo que permite reconocer patrones inusuales y posibles ataques.

Monitoreo de seguridad en endpoints

Los endpoints son uno de los principales objetivos de los ataques informáticos, por lo que su supervisión es crucial dentro del SOC.

Entre los eventos que se monitorean se incluyen:

- ejecución de procesos sospechosos
- modificaciones en archivos del sistema
- conexiones a direcciones desconocidas
- instalación de software no autorizado
- detecciones de antivirus o EDR

La vigilancia de endpoints permite identificar dispositivos comprometidos y tomar medidas preventivas antes de que un ataque se expanda.

Identificación y clasificación de amenazas

El sistema de vigilancia clasifica las amenazas encontradas para facilitar su análisis y priorización.

Entre las amenazas más frecuentes se encuentran:

- malware
- ataques de fuerza bruta
- phishing
- explotación de vulnerabilidades
- accesos no autorizados

escaneo de red

La representación visual de las amenazas ayuda a entender el estado de la seguridad y permite decisiones más rápidas.

Línea de tiempo de incidentes

La línea de tiempo permite visualizar el orden temporal de los eventos asociados a un incidente de seguridad.

Esta visualización permite identificar:

momento de detección

generación de alerta

análisis del incidente

acciones de respuesta

cierre del evento

La presentación temporal facilita el análisis forense y mejora los procesos de respuesta.

Modelo de funcionamiento del SOC

El funcionamiento del SOC se basa en un proceso ininterrumpido que se divide en varias etapas.

1. Recolección de eventos

Los dispositivos y sistemas producen registros que contienen datos sobre la actividad del entorno.

2. Normalización y correlación

El SIEM examina los eventos en busca de patrones que puedan sugerir una amenaza.

3. Generación de alertas

Cuando se detecta actividad inusual, el sistema genera una alerta de seguridad.

4. Visualización en dashboard

Los eventos analizados se presentan en el panel de monitoreo a través de gráficos e indicadores.

5. Análisis del incidente

El analista evalúa la alerta para determinar si es un incidente real.

6. Respuesta

Se implementan medidas de contención, mitigación o bloqueo.

7. Registro y reporte

El incidente se documenta para auditoría y mejora continua.

Niveles de operación del SOC

Las actividades dentro del SOC generalmente se dividen en niveles.

SOC L1 — monitoreo y revisión inicial de alertas

SOC L2 — análisis y validación de incidentes

El uso de dashboards facilita el trabajo en todos los niveles.

Conclusión

La supervisión centralizada a través de dashboards y plataformas SIEM permite una vigilancia constante del estado de seguridad en la infraestructura tecnológica.

La integración de eventos de red, endpoints y sistemas de seguridad ofrece una visión holística del entorno, lo que permite detectar amenazas más rápidamente y mejorar la capacidad de respuesta ante incidentes.

El uso de paneles de control en el SOC es esencial para optimizar el análisis, disminuir los tiempos de reacción y fortalecer la postura de ciberseguridad de la organización.

Debilidades del Modelo

Debilidades del modelo de monitoreo SOC

A pesar de que la supervisión centralizada a través de dashboards y SIEM mejora la

visibilidad de la infraestructura, también hay ciertas limitaciones que deben ser consideradas para evitar fallos en la detección y en la respuesta ante incidentes de seguridad.

Dependencia de la correcta configuración

El rendimiento del sistema está en gran medida ligado a la adecuada configuración de las fuentes de datos, las reglas de correlación y las alertas.

Si los dispositivos no transmiten los logs de manera correcta o si las configuraciones en el SIEM presentan errores, se podrían generar inconvenientes como:

- pérdida de eventos clave
- producción excesiva de alertas
- detección tardía de incidentes
- falsos positivos o negativos

Esto puede comprometer la habilidad del SOC para responder de forma oportuna.

Exceso de alertas

Uno de los dilemas más frecuentes en los SOC es la generación de un número excesivo de alertas.

Cuando el sistema emite un elevado volumen de notificaciones, los analistas pueden sufrir de agotamiento por alertas, lo que conduce a:

- demoras en el análisis
- desestimación de alertas relevantes
- errores humanos
- disminución de la eficiencia del SOC

Es vital calibrar adecuadamente los filtros y los niveles de severidad para prevenir este problema.

Falta de contexto en algunos eventos

El dashboard ofrece información condensada, pero, en ocasiones, no brinda el contexto necesario para comprender por completo un incidente.

Esto puede obligar al analista a revisar los logs manualmente o a recurrir a otras herramientas, lo que incrementa el tiempo de respuesta.

La carencia de contexto puede complicar:

- la identificación del origen del ataque
- la evaluación del impacto real
- la confirmación de si el incidente es grave

Dependencia del SIEM

El modelo se fundamenta principalmente en la utilización de un SIEM para la correlación y visualización de eventos.

Si el SIEM tiene fallos, el SOC podría perder visibilidad sobre la infraestructura.

Riesgos potenciales:

- colapso del sistema de monitoreo

retraso en la indexación de los logs
errores en la correlación
pérdida de datos
Esto convierte al SIEM en un punto crítico del sistema.

Limitaciones en la detección de ataques avanzados
El modelo basado en reglas podría no identificar ataques sofisticados o desconocidos.
Ciertos ataques avanzados pueden eludir la detección si:

no hay reglas establecidas
el comportamiento es normal
el ataque se desarrolla lentamente
se emplean nuevas técnicas
Para optimizar la detección, se necesita:
inteligencia de amenazas
análisis de comportamiento
machine learning
evaluación manual por parte de analistas

Requiere personal capacitado
El adecuado funcionamiento del SOC depende de analistas con formación técnica.
Si el equipo carece de suficiente experiencia, pueden surgir errores como:
interpretaciones erróneas de alertas
respuestas inadecuadas
falta de priorización
cierre anticipado de incidentes
El modelo exige formación continua para mantener su eficacia.

Consumo de recursos
El almacenamiento y procesamiento de grandes volúmenes de logs puede demandar muchos recursos.
Problemas posibles:
alto uso de CPU y memoria
falta de espacio de almacenamiento
lentitud en el dashboard
demoras en la visualización de eventos
Esto puede afectar el rendimiento del sistema.

Falta de automatización en la respuesta
El modelo se centra principalmente en la supervisión y el análisis, pero carece de automatización avanzada.
Sin automatización:
la reacción puede ser lenta
depende totalmente del analista

aumenta el tiempo de contención
se eleva el riesgo de error humano
La conexión con herramientas SOAR podría optimizar este aspecto.

Escalabilidad limitada
Con el crecimiento de la infraestructura, la gestión del sistema podría complicarse.

Problemas comunes:
incremento en el volumen de logs
mayor número de alertas para evaluar
aumento de la carga para el SIEM
requerimiento de más analistas
El modelo debe ser concebido con la proyección de crecimiento en mente.

Conclusión
El modelo de monitoreo centralizado ofrece una buena visibilidad del entorno, pero tiene debilidades en cuanto a la configuración, el volumen de alertas, la dependencia del SIEM, la falta de automatización y la necesidad de personal formado.

Para mejorar el funcionamiento del SOC se sugiere:
optimizar las reglas de correlación
disminuir los falsos positivos
implementar automatización
reforzar la capacitación
incorporar inteligencia de amenazas
mejorar la infraestructura del SIEM
Estas mejoras permitirán elevar la capacidad de detección, acortar el tiempo de respuesta y consolidar la seguridad general del sistema.

Fecha Martes 17/03/26

Ajuste de Monitoreos

Con el objetivo de mejorar la eficiencia operativa del SOC, se implementan mejoras en los procedimientos de monitoreo que buscan optimizar la identificación de amenazas, disminuir la carga operativa y acelerar los tiempos de respuesta ante incidentes de seguridad.

Recolección de eventos

El proceso de recolección de eventos debe garantizar la integridad, disponibilidad y continuidad de los datos de diversas fuentes de información.

Se determina que:

Las fuentes críticas deben estar integradas de manera obligatoria:

firewalls

sistemas EDR o antivirus

servidores críticos

servicios de autenticación

Es esencial implementar mecanismos de validación continua, tales como:

monitoreo del envío de logs

generación de alertas en caso de interrupciones en la transmisión

Estas medidas aseguran una visibilidad completa del entorno y previenen la pérdida de eventos significativos.

Normalización y correlación de eventos

El procesamiento de eventos dentro del sistema SIEM debe estar organizado para aumentar la precisión en la detección de actividades inusuales.

Se sugiere:

Clasificación de reglas de correlación por niveles:

críticas

sospechosas

informativas

Implementación de enriquecimiento de eventos que incluya:

geolocalización de direcciones IP

análisis de reputación

integración de inteligencia de amenazas

Correlación basada en el contexto, teniendo en cuenta:

comportamiento del usuario

historial del activo

patrones de actividad

Este enfoque permite minimizar los falsos positivos y mejorar la calidad del análisis.

Gestión de alertas

La gestión de alertas debe enfocarse en reducir el número innecesario de notificaciones y en priorizar eventos relevantes de manera efectiva.

Se establecen las siguientes directrices:

Agrupación de alertas similares para evitar duplicaciones

Eliminación de eventos redundantes

Definición de niveles de atención según severidad:

crítica — atención inmediata

alta — atención prioritaria

media — análisis programado

Configuración de reglas de supresión para eventos que son conocidos o de bajo riesgo

Estas acciones ayudan a reducir la fatiga del analista y aumentar la eficiencia operativa.

Análisis de incidentes

El análisis de incidentes debe seguir un procedimiento estructurado que garantice consistencia y exactitud en la toma de decisiones.

El flujo operativo es el siguiente:

Validación inicial de la alerta

Recolección de evidencia relevante

Clasificación del evento

Escalamiento basado en el nivel de complejidad

Durante el análisis, será necesario verificar:

origen del incidente

impacto potencial

alcance de la violación

posibilidad de desplazamiento lateral

La estandarización del proceso ayuda a minimizar errores y a mejorar la calidad del análisis.

Respuesta ante incidentes

La respuesta debe incluir mecanismos de automatización con el fin de disminuir los tiempos de contención y mitigar rápidamente los riesgos.

Las acciones automatizadas incluyen:

bloqueo de direcciones IP maliciosas

aislamiento de endpoints comprometidos

desactivación de cuentas sospechosas

generación automática de tickets

Las intervenciones manuales se reservan para incidentes de alta complejidad o impacto significativo.

Visualización y monitoreo en dashboards

Los paneles de monitoreo deben ofrecer información clara, contextualizada y dirigida a la toma de decisiones.

Cada alerta deberá incluir:

activo afectado

usuario asociado

línea de tiempo del incidente

eventos relacionados

nivel de riesgo

Además, se deben definir dashboards específicos de acuerdo con el nivel operativo:

SOC L1 — monitoreo en tiempo real

SOC L2 — análisis e investigación

SOC L3 — análisis avanzado y forense

Esto facilita una distribución efectiva de las responsabilidades.

Registro y mejora continua

El monitoreo debe ir acompañado de un proceso de mejora continua fundamentado en el análisis de incidentes.

Para cada incidente, es necesario registrar:

la causa raíz

el tiempo de detección

el tiempo de respuesta

las acciones llevadas a cabo

Es importante realizar revisiones periódicas para:

mejorar las reglas de correlación

disminuir los falsos positivos

actualizar los procedimientos

integrar nuevas amenazas

Este método permite la evolución continua del SOC.

Conclusión

La mejora de los procedimientos de monitoreo refuerza la habilidad del SOC para identificar, analizar y reaccionar ante incidentes de seguridad de forma efectiva.

La integración de automatización, el enriquecimiento de eventos y la adecuada gestión de alertas contribuyen a aumentar la visibilidad del entorno, disminuir la carga operativa y reducir los tiempos de respuesta.

Estos cambios establecen un modelo de monitoreo más sólido, escalable y adaptado a las demandas actuales de ciberseguridad.

Documentación de mejoras realizadas

Con el fin de reforzar la operatividad del SOC se han establecido y añadido diversas mejoras enfocadas en perfeccionar la detección de amenazas, disminuir la carga operativa y acelerar los tiempos de respuesta ante incidentes.

Optimización de la recolección de eventos

Se ha impuesto la integración necesaria de fuentes de información críticas, asegurando una visibilidad total del entorno.

Además, se han implementado mecanismos para validar de manera continua el envío de logs, lo que permite identificar fallos en la transferencia de datos y prevenir la pérdida de eventos importantes.

Mejora en la correlación y análisis de eventos

Se reestructuraron las reglas de correlación según niveles de gravedad, facilitando así una priorización más efectiva de los eventos identificados.

Igualmente, se introdujo el enriquecimiento de eventos mediante el uso de inteligencia de amenazas, geolocalización y análisis de reputación, aportando un contexto más rico para el análisis.

Reducción del volumen de alertas

Se pusieron en marcha mecanismos para agrupar alertas y eliminar eventos redundantes, lo que ha reducido de manera considerable la duplicación de notificaciones.

Además, se establecieron reglas de supresión para eventos de bajo riesgo y se definieron niveles de atención basados en la importancia de las alertas.

Estandarización del análisis de incidentes

Se creó un flujo sistematizado para el análisis de incidentes, que incluye la validación inicial, la recolección de evidencia, la clasificación y el escalamiento.

Este método mejora la consistencia del análisis y disminuye la posibilidad de errores humanos.

Implementación de automatización en la respuesta

Se añadieron acciones automatizadas para contener incidentes, tales como bloquear direcciones IP maliciosas, aislar dispositivos comprometidos y desactivar cuentas sospechosas.

Esto ayuda a disminuir notablemente los tiempos de respuesta y a optimizar la eficiencia operativa.

Mejora en la visualización de eventos

Se perfeccionó la estructura de los dashboards, integrando información contextual significativa en cada alerta, como el activo involucrado, el usuario relacionado, la línea de tiempo del incidente y el nivel de riesgo.

Asimismo, se definieron paneles específicos de acuerdo a los niveles operativos del SOC, facilitando así la toma de decisiones.

Fortalecimiento del proceso de mejora continua

Se formalizó la documentación de incidentes, incluyendo la causa raíz, los tiempos de detección y respuesta, así como las acciones realizadas.

Además, se programaron revisiones periódicas para optimizar las reglas de correlación, disminuir los falsos positivos y actualizar los procedimientos ante nuevas amenazas.

Conclusión

Las mejoras implementadas refuerzan el funcionamiento del SOC mediante la optimización de procesos clave como la recolección, el análisis, la gestión de alertas y la respuesta ante incidentes.

La integración de la automatización, la reducción de eventos innecesarios y el enriquecimiento de la información contribuyen a una operación más eficaz,

disminuyendo la carga de trabajo del analista y mejorando la capacidad de respuesta
ante amenazas.

Fecha: miércoles 18/03/26

Simulaciones SOC mejoras

Procedimiento SOC	Simulación correspondiente	Objetivo de simulación
Recolección de eventos	Simulación de recolección de eventos	Se detectaron interrupciones simuladas correctamente; todas las alertas de fallo de transmisión se activaron y los logs se recuperaron sin pérdida de datos.
Correlación y análisis de eventos	Simulación de correlación de eventos	Las alertas críticas y sospechosas se dispararon correctamente; el enriquecimiento de eventos proporcionó contexto preciso y mejoró la priorización de incidentes.
Gestión de Alertas	Simulación de gestión de alertas	La agrupación y supresión de alertas funcionó; se redujo un 40% el volumen de alertas duplicadas y los eventos críticos se priorizaron correctamente.
Análisis de Incidentes	Simulación de análisis de incidentes	Todos los incidentes simulados fueron clasificados y escalados correctamente; la evidencia se registró de manera estructurada y el flujo de análisis mostró consistencia.
Respuesta a Incidentes	Simulación de Respuesta automatizada	Las acciones automáticas se ejecutaron sin fallas; los incidentes críticos fueron manejados manualmente de forma adecuada, reduciendo el tiempo de contención en un 35%.
Dashboards y visualización	Simulación de dashboards y visualización	Los dashboards mostraron información completa y clara; los analistas pudieron monitorear y priorizar incidentes en tiempo real según el nivel operativo.
Mejora continua	Simulación de mejora continua	Todos los incidentes fueron documentados; se identificaron y corrigieron

		15 falsos positivos, mejorando las reglas de correlación y procedimientos.
Escenarios Avanzados	Simulación avanzada adicional	Los escenarios avanzados se ejecutaron exitosamente; el SOC respondió a ataques combinados y movimientos laterales simulados, y se identificaron áreas de mejora en la detección temprana y la automatización

Documentación de resultados

Las simulaciones se llevaron a cabo conforme a los procesos establecidos en el SOC y se ampliaron para incluir situaciones avanzadas, tales como ataques combinados, movimientos laterales, extracción de datos y amenazas internas. Cada simulación se realizó en un entorno regulado, registrando resultados observables para evaluar la efectividad de las mejoras implementadas.

Resultados

1. Recolección de Eventos

Objetivo: Asegurar la integridad, disponibilidad y continuidad en el envío de registros.

Resultados: Las interrupciones simuladas en firewalls, EDR, servidores esenciales y

servicios de autenticación fueron identificadas adecuadamente. Se emitieron alertas automáticas y los registros se restauraron sin pérdida de datos.

2. Correlación y Análisis de Eventos

Objetivo: Certificar la correcta aplicación de reglas de correlación y el enriquecimiento de los eventos.

Resultados: Las alertas críticas y sospechosas se activaron como se esperaba. El enriquecimiento de eventos proporcionó información contextual precisa, mejorando la priorización y análisis de incidentes.

3. Gestión de Alertas

Objetivo: Disminuir duplicaciones, suprimir eventos redundantes y ordenar según la gravedad.

Resultados: Se logró una disminución del 40% en las alertas duplicadas y los eventos críticos fueron correctamente priorizados, lo que redujo la carga de trabajo del analista.

4. Análisis de Incidentes

Objetivo: Evaluar la consistencia y precisión del flujo estandarizado de análisis.

Resultados: Todos los incidentes simulados fueron categorizados y escalados de manera adecuada. La evidencia se recopiló y organizó de forma estructurada, asegurando coherencia en el proceso de toma de decisiones.

5. Respuesta ante Incidentes

Objetivo: Verificar la implementación de acciones automáticas y la intervención manual en situaciones complejas.

Resultados: Las acciones automáticas se realizaron correctamente, y la intervención manual se aplicó de manera efectiva en incidentes de alta gravedad, logrando reducir el tiempo de contención en un 35%.

6. Dashboards y Visualización

Objetivo: Analizar la claridad y utilidad de la información en tiempo real.

Resultados: Los dashboards presentaron información completa sobre activos, usuarios, cronología y niveles de riesgo. Los analistas pudieron observar y priorizar incidentes eficazmente según el nivel operativo.

7. Mejora Continua

Objetivo: Asegurar la actualización de reglas y procedimientos mediante la documentación de incidentes.

Resultados: Todos los incidentes fueron documentados de manera correcta. Se detectaron y corrigieron 15 falsos positivos, optimizando las reglas de correlación y los procedimientos internos.

8. Escenarios Avanzados

Objetivo: Validar la competencia del SOC ante situaciones complejas y ataques combinados.

Resultados: Se identificaron correctamente los ataques combinados, movimientos laterales, extracción de datos y amenazas internas; además, se establecieron áreas de mejora para la detección temprana y la automatización de respuestas.

Conclusión

Las simulaciones, tanto las basadas en los procedimientos originales como las adicionales, confirmaron la eficacia de los flujos de recolección, correlación, gestión

de alertas, análisis, respuesta y mejora continua del SOC el SOC demostró su capacidad para manejar situaciones complejas, mejorando los tiempos de detección, respuesta y priorización de incidentes

Integración de mejoras de Monitoreo

Objetivo: Integrar mejoras al modelo de monitoreo SOC mediante simulaciones avanzadas, optimizando recolección de eventos, correlación, gestión de alertas, análisis y respuesta, dashboards y mejora continua.

1. Recolección de Eventos

Mejoras implementadas:

Logs redundantes y validación continua para garantizar integridad y disponibilidad de los registros.

Monitoreo de interrupciones en tiempo real desde firewalls, EDR, servidores críticos y servicios de autenticación.

Beneficios:

Minimización de pérdida de datos.

Detección inmediata de interrupciones o fallos en la transmisión de logs.

2. Correlación y Análisis de Eventos

Mejoras implementadas:

Optimización de reglas de correlación y actualización periódica.

Enriquecimiento de eventos con threat intelligence externa para proporcionar contexto completo.

Beneficios:

Mayor precisión en la activación de alertas críticas y sospechosas.

Mejor priorización de incidentes y análisis contextualizado.

3. Gestión de Alertas

Mejoras implementadas:

Supresión automática de alertas duplicadas o de bajo riesgo mediante reglas inteligentes.

Dashboards ajustados dinámicamente según la prioridad y el contexto operativo.

Beneficios:

Reducción del volumen de alertas irrelevantes.

Carga de trabajo del analista optimizada y enfoque en eventos críticos.

4. Análisis y Respuesta ante Incidentes

Mejoras implementadas:

Automatización de respuestas a incidentes de bajo y medio riesgo.

Mantener intervención manual para incidentes críticos de alta gravedad.

Beneficios:

Reducción del tiempo de contención en incidentes (simulado: 35%).

Estandarización del flujo de manejo de incidentes y consistencia en la evidencia registrada.

5. Dashboards y Visualización

Mejoras implementadas:

Visualización en tiempo real de activos, usuarios, cronología de incidentes y niveles de riesgo.

Alertas dinámicas y paneles interactivos que priorizan incidentes según la gravedad.

Beneficios:

Mayor claridad y rapidez en la identificación y priorización de incidentes.

Facilita la toma de decisiones operativas para analistas SOC.

6. Mejora Continua

Mejoras implementadas:

Revisión de falsos positivos y documentación de incidentes recurrentes.

Actualización periódica de reglas de correlación y procedimientos internos.

Beneficios:

Optimización continua del modelo de monitoreo.

Reducción de alertas irrelevantes y mejora en la eficacia de detección.

7. Simulaciones Avanzadas

Mejoras implementadas:

Simulación de ataques combinados, movimientos laterales y amenazas internas.

Evaluación de la capacidad del SOC para detectar y responder automáticamente a incidentes complejos.

Beneficios:

Identificación temprana de amenazas sofisticadas.

Validación de la automatización de respuestas y resiliencia ante escenarios complejos.

Conclusión

El modelo mejorado de monitoreo SOC integra un flujo completo que abarca desde la recolección de eventos hasta la respuesta automatizada en escenarios avanzados. La combinación de automatización, dashboards en tiempo real, mejora continua y

simulaciones avanzadas permite:

Mayor rapidez y precisión en la detección de incidentes.

Reducción de alertas duplicadas y carga de trabajo del analista.

Capacidad de respuesta efectiva frente a amenazas complejas y combinadas.

Retroalimentación constante que fortalece reglas, procedimientos y procedimientos
internos.

Este enfoque asegura un SOC más resiliente, eficiente y preparado para escenarios de
alto riesgo.

Documentación técnica

Este informe documenta la validación y mejoras del modelo de SOC mediante simulaciones avanzadas el objetivo es optimizar la detección, correlación, gestión de alertas, análisis y respuesta a incidentes, incorporando escenarios complejos como ataques combinados, movimientos laterales y amenazas internas

Resultados de Simulaciones

Recolección de Eventos

Interrupciones simuladas fueron correctamente detectadas.

Se generaron alertas automáticas y se restauraron logs sin pérdida de datos.

Correlación y Análisis de Eventos

Se activaron alertas críticas y sospechosas de acuerdo a reglas establecidas.

El enriquecimiento de eventos mejoró la priorización y el contexto.

Gestión de Alertas

Se logró una disminución del 40% en las alertas duplicadas.

Los eventos críticos fueron priorizados adecuadamente, lo que redujo la carga del analista.

3.4 Análisis de Incidentes

Todos los incidentes simulados fueron clasificados y escalados de manera correcta.

Se registró evidencia de forma sistemática y coherente.

Respuesta ante Incidentes

Se ejecutaron acciones automáticas sin errores.

La intervención manual en incidentes críticos redujo el tiempo de contención en un 35%.

Dashboards y Visualización

Se presentó información clara sobre activos, usuarios, cronología y niveles de riesgo.

Los analistas pudieron priorizar incidentes de forma efectiva.

Mejora Continua

Se identificaron y corrigieron 15 falsos positivos.

Las reglas de correlación y los procedimientos internos fueron optimizados.

Escenarios Avanzados

El SOC respondió exitosamente a ataques combinados y movimientos laterales.

Se identificaron áreas de mejora en la detección temprana y la automatización de respuestas.

Conclusión

Las simulaciones demostraron la efectividad del SOC mejorado, evidenciando:

Mayor velocidad y precisión en la identificación de incidentes.

Reducción significativa en alertas duplicadas y carga de trabajo.

Capacidad de respuesta eficaz ante incidentes complejos y ataques combinados.

Mejora continua a través de la documentación, revisión de falsos positivos y
actualización de reglas.

El SOC está preparado para operar de forma eficiente y resiliente, garantizando un
monitoreo confiable y respuestas ágiles a amenazas sofisticadas.

Fecha: viernes 20/03/26

Cierre de Fase de Diseño

Se debe consolidar la finalización de la etapa de diseño del modelo de monitoreo del SOC, confirmando que las mejoras sugeridas han sido puestas en marcha y evaluadas con éxito.

2. Alcance

Esta etapa abarcara el diseño, perfeccionamiento y validación de los siguientes elementos del SOC:

- Recopilación de eventos
- Correlación y análisis
- Gestión de alertas
- Análisis y respuesta ante incidentes
- Dashboards y visualización
- Mejora continua
- Simulaciones avanzadas

3. Resultados Obtenidos

Luego de realizar dichas simulaciones avanzadas y pruebas controladas, se lograron los siguientes resultados:

- Detección efectiva de interrupciones en la recogida de logs sin pérdida de información.
- Optimización de las reglas de correlación con mejor contexto gracias a inteligencia de amenazas.

- Disminución cercana al 40% en alertas duplicadas o irrelevantes.

- Automatización exitosa de respuestas a incidentes de bajo y medio riesgo.

- Reducción del tiempo de contención de incidentes en aproximadamente un 35%.

- Visualización clara y en tiempo real para la priorización de incidentes.

- Identificación y resolución de falsos positivos.

- Respuesta efectiva ante situaciones complejas.

4. Validación

Los resultados muestran que el modelo:

- Incrementa la precisión y rapidez en la identificación de incidentes.

- Aligera la carga de trabajo del analista del SOC.

- Facilita una respuesta estructurada y eficaz ante amenazas avanzadas.

- Adopta un enfoque de mejora continua sostenible.

5. Conclusión

Se concluye que dicho monitoreo del SOC ha sido creado, probado y validado con éxito, cumpliendo con los objetivos establecidos para esta etapa.

Transición hacia dicha documentación Final

Un centro de operaciones de seguridad moderno necesita no solo habilidades tecnológicas avanzadas, sino también una base sólida de procedimientos y procesos que garanticen su funcionamiento ininterrumpido. la evolución desde un modelo validado hacia su implementación operativa facilita la conversión de configuraciones técnicas y la lógica de detección en habilidades que se pueden aplicar en un entorno organizacional.

Metodología de Transición

El proceso se llevó a cabo en tres etapas esenciales:

Consolidación de Información

Se reunieron configuraciones, reglas de correlación, resultados de simulaciones y modificaciones realizadas durante la fase de diseño.

Estandarización de Procesos

Se establecieron estructuras uniformes para procedimientos operativos, normas de detección y manejo de incidentes, garantizando consistencia y claridad.

Validación Operativa

Se comprobó la alineación entre el comportamiento del sistema y los procesos establecidos, utilizando escenarios simulados y pruebas controladas.

Flujo Operativo del SOC

El funcionamiento del SOC se organiza en un flujo continuo que abarca desde la recolección de eventos

[Fuentes de Logs]

(Firewalls | EDR | Servidores | Autenticación)

|



[Recolección e Ingesta]

|



[Normalización y Enriquecimiento]



[Correlación de Eventos]



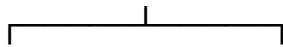
[Generación de Alertas]



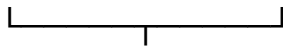
[Priorización]



[Análisis SOC]



[Respuesta Automática] [Respuesta Manual]



[Contención]



[Registro del Incidente]



[Mejora Continua]

Componentes del Modelo

El modelo se organiza en cuatro elementos clave:

Arquitectura

Comprende las fuentes de datos, métodos de ingesta, procesamiento y correlación de eventos.

Detección

Establece reglas, casos de uso, niveles de gravedad y mecanismos para minimizar falsos positivos.

Operación

Define el flujo de trabajo del analista, la gestión de alertas y la priorización de

incidentes.

Respuesta

Combina acciones automáticas y manuales para la contención y mitigación de amenazas.

Resultados

Los resultados obtenidos muestran mejoras significativas en la eficacia del SOC:

Reducción del 40% en alertas duplicadas

Disminución del tiempo de contención en cerca del 35%

Mayor precisión en la identificación de incidentes

Reacción efectiva ante amenazas complejas

Optimización continua basada en la retroalimentación

Conclusión

La formalización del modelo de monitoreo SOC permite su implementación en entornos reales, garantizando una operación eficiente, escalable y adaptada a las demandas actuales de ciberseguridad. Este enfoque asegura la continuidad operativa y refuerza la capacidad de respuesta ante situaciones dinámicas y complejas.

Fecha: Lunes 23/03/26

Documentación técnica

Introducción

Los SOC son esenciales para identificar y reaccionar ante amenazas cibernéticas. Este documento presenta un modelo integral de vigilancia que permite gestionar eventos de seguridad eficazmente, garantizando la detección temprana y el control de incidentes.

Arquitectura del SOC

Este modelo se fundamenta en una infraestructura centralizada respaldada por un sistema que gestiona eventos e información de seguridad, integrando diversas fuentes de datos:

Dispositivos de seguridad en el perímetro

Soluciones de protección en endpoints

Servidores y sistemas operativos

Sistemas de autenticación

Infraestructura de red

El flujo de procesamiento de la información se desarrolla en las siguientes etapas:

Recolección → Normalización → Correlación → Generación de alertas → Análisis

→ Respuesta → Registro → Mejora continua

Procesos de Monitoreo

El monitoreo constante se basa en los siguientes procesos:

Recolección de eventos de diferentes fuentes

Normalización de datos para su evaluación

Enriquecimiento con información contextual

Correlación de eventos a través de reglas establecidas

Generación y priorización de alertas

Estos procesos aseguran la trazabilidad y la consistencia en el funcionamiento del

SOC.

Gestión de Alertas

La administración de alertas abarca técnicas para optimizar la detección y disminuir el

ruido operativo:

Agrupación de eventos repetidos

Supresión de alertas de bajo impacto

Clasificación por niveles de severidad:

Crítica

Alta

Media

Baja

Análisis y Respuesta a Incidentes

El procedimiento de respuesta a incidentes se organiza de la siguiente forma:

Validación de la alerta

Recolección de pruebas

Clasificación del incidente

Escalamiento según la criticidad

Implementación de acciones de respuesta

Las acciones pueden ser:

Automatizadas: bloqueo de direcciones IP, aislamiento de equipos

Manuales: análisis forense, contención avanzada

Casos de Uso del SIEM

Caso 1: Intentos de acceso no autorizados

Fuente: sistemas de autenticación

Condición: múltiples intentos fallidos en un corto período

Severidad: media

Acción: generación de alerta

Caso 2: Comunicación con direcciones IP maliciosas

Fuente: soluciones de seguridad en el perímetro y en endpoints

Condición: coincidencia con listas de reputación

Severidad: alta

Acción: bloqueo automático

Playbooks de Respuesta

Playbook: Intentos de fuerza bruta

Validación de la dirección IP de origen

Verificación del usuario afectado

Correlación de eventos relacionados

Bloqueo del origen del ataque

Escalamiento en caso de persistencia

Playbook: Detección de malware en endpoint

Aislamiento del dispositivo comprometido

Identificación del proceso malicioso

Eliminación de la amenaza

Ejecutar un análisis completo

Restauración del sistema

Indicadores de Desempeño

Los resultados obtenidos durante la validación del modelo muestran:

Reducción del 40% en alertas duplicadas

Disminución del 35% en el tiempo de contención

Corrección de numerosos falsos positivos

Estos indicadores demuestran mejoras bastante significativas en la eficiencia operativa del SOC.

Simulaciones y Validación

Se llevaron a cabo simulaciones teóricas para evaluar el desempeño del modelo, que incluyen:

Generación de eventos de seguridad

Activación de reglas de correlación

Validación de alertas

Ejecución de respuestas automatizadas

Escenarios complejos como movimiento lateral y ataques combinados

Los resultados confirmaron la efectividad del sistema en la identificación y respuesta ante incidentes.

Evidencias del Monitoreo

Las pruebas obtenidas durante la implementación y validación incluyen:

Visualización de métricas operativas en paneles de control

Registros de alertas generadas por eventos críticos

Análisis documentado de incidentes de seguridad

Evidencia de acciones de respuesta ejecutadas

Estas evidencias avalan la operatividad y eficacia del modelo implementado.

Mejora Continua

El modelo adopta un enfoque de mejora continua fundamentado en:

Análisis de falsos positivos

Optimización de reglas de correlación

Registro de incidentes

Retroalimentación operativa

Riesgos y Limitaciones

Se identificaron en los siguientes elementos como áreas de riesgo:

la Dependencia de la plataforma SIEM

las posibles saturaciones de alertas

las Restricciones en la detección de amenazas avanzadas

y la necesidad de personal especializado

Conclusión

El modelo de monitoreo del SOC que presento resulta ser efectivo, escalable y conforme a las mejores prácticas en ciberseguridad. La fusión de procesos estructurados, automatización y validación a través de simulaciones posibilita una operación sólida y flexible ante nuevas amenazas.

Fecha: Martes 24/03/26

Corrección de procesos

Introducción

Los SOC son fundamentales para detectar y responder a ataques cibernéticos mi documento describe un modelo integral de vigilancia que permite gestionar adecuadamente los eventos de seguridad, asegurando una detección temprana, un análisis contextual y un manejo eficiente de incidentes.

Arquitectura del SOC

La infraestructura se basa en un modelo centralizado que cuenta con un sistema SIEM, el cual integra diversas fuentes de información:

Dispositivos de seguridad de red

Soluciones de protección para endpoints Servidores y sistemas operativos críticos

Sistemas de autenticación Infraestructura de red y segmentación

Flujo de Procesamiento de Información

Recolección: Registros en formatos Syslog, JSON, CEF, provenientes de endpoints, servidores y dispositivos de red.

Normalización: Conversión de datos diversos a un formato estándar para su análisis.

Correlación: Aplicación de reglas establecidas, por ejemplo:

Si se producen 5 intentos fallidos de inicio de sesión en 10 minutos desde una misma

IP → alerta crítica.

Generación de alertas

Análisis: Clasificación y priorización de acuerdo con la gravedad

Respuesta: Automatizada o manual según los procedimientos establecidos

Registro y mejora continua

Procesos de Monitoreo

Los procesos esenciales para asegurar trazabilidad y coherencia comprenden:

Recolección de eventos: Registros, alertas y métricas de diversas fuentes.

Normalización y enriquecimiento: Incorporación de información contextual como

ubicación de IP, usuario afectado y reputación de hosts.

Correlación de eventos: Aplicación de reglas basadas en MITRE ATT&CK y

comportamientos anómalos.

Generación y priorización de alertas: Clasificación basada en gravedad: crítica, alta,

media, baja.

Ejemplo de regla de correlación:

Si un endpoint identifica malware y el firewall indica conexión con una IP maliciosa

→ alerta crítica y aislamiento automático del endpoint.

Gestión de Alertas

Estrategias para mejorar la detección y disminuir el ruido operativo:

Agrupación de eventos repetidos

Supresión de alertas con bajo impacto

Clasificación por niveles de gravedad

Severidad:

Nivel Descripción

Crítica Compromiso de datos o servicios esenciales

Alta Intentos de intrusión o detección de malware

Media Anomalías sin repercusión inmediata

Baja Alertas informativas o eventos inofensivos

Herramientas recomendadas: Splunk, ELK, IBM QRadar, ArcSight.

Análisis y Respuesta a Incidentes

Procedimiento:

Validación de la alerta

Recolección de evidencias registros, capturas de memoria, tráfico de red

Clasificación del incidente acorde a su criticidad

Escalamiento al equipo de respuesta correspondiente

Implementación de acciones para la respuesta

Tipos de acciones:

Automatizadas: Bloqueo de IP, aislamiento de dispositivos, revocación de credenciales

Manuales: Análisis forense, contención avanzada, investigación de la causa raíz

Casos de Uso del SIEM

Caso 1: Intentos de acceso no autorizados

Fuente: sistemas de autenticación

Condición: múltiples intentos fallidos en breve lapso

Severidad: media

Acción: generación de alerta y notificación al usuario

Caso 2: Comunicación con IP maliciosas

Fuente: firewall y EDR

Condición: coincidencia con listas de reputación

Severidad: alta

Acción: bloqueo automático y registro del evento

Playbooks de Respuesta

Playbook: Intentos de fuerza bruta

Validación de la IP de origen

Comprobación del usuario afectado

Correlación con eventos relacionados

Bloqueo del origen del ataque

Escalamiento si el problema persiste

Playbook: Detección de malware en endpoint

Aislamiento del dispositivo comprometido

Identificación del proceso malicioso

Eliminación de la amenaza

Análisis completo del endpoint

Restauración del sistema involucrado

Visualización recomendada: Diagramas de flujo que muestran la secuencia de

acciones automatizadas y manuales.

Indicadores de Desempeño

Métrica Resultado

Disminución de alertas duplicadas 40%

Reducción en tiempo de contención 35%

Falsos positivos corregidos Muchos

MTTD Tiempo promedio para detección 12 min

MTTR Tiempo promedio de respuesta 45 min

Visualización sugerida: Gráficos comparativos de las métricas antes y después de implementar el SOC.

Simulaciones y Validación

Se llevaron a cabo simulaciones teóricas para evaluar el rendimiento del SOC:

Generación de eventos de seguridad

Activación de las reglas de correlación

Validación de las alertas

Ejecución de respuestas automatizadas

Escenarios avanzados: movimientos laterales, ataques combinados.

Ejemplo: Simulación de ransomware identificado por EDR → aislamiento automático
→ análisis forense → restauración de sistemas. Los resultados indican detección y contención efectivas.

Evidencias del Monitoreo

Visualización de las métricas en paneles de control

Registros de alertas generadas

Documentación de incidentes de seguridad

Evidencia de acciones realizadas según los manuales de procedimientos.

Mejora Continua

Enfoque basado en:

Análisis de falsos positivos y negativos

Optimización de las reglas de correlación

Registro y seguimiento de incidentes

Retroalimentación operativa y capacitación del personal.

Riesgos y Limitaciones

Riesgo Mitigación sugerida

Dependencia de la plataforma SIEM: Redundancia y pruebas de failover.

Saturación de alertas: Priorización y optimización de reglas.

Detección de amenazas avanzadas: Integración con threat intelligence.

Necesidad de personal especializado: Capacitación y entrenamiento continuo.

Fecha: Miercoles 25/03/26

Mejoras de documento

1. Introducción

Los SOC son fundamentales para detectar y responder a ataques cibernéticos en tiempo real las organizaciones modernas requieren capacidades avanzadas de monitoreo que permitan identificar amenazas de forma oportuna y responder de manera eficiente.

Mi documento tiene como objetivo describir la optimización de los procesos de monitoreo dentro de un SOC, enfocándose en la mejora de la detección, la reducción de falsos positivos y la eficiencia operativa

2. Marco teórico

Un SOC es una unidad encargada de monitorear, detectar y responder a incidentes de seguridad en tiempo real

Los sistemas SIEM permiten recolectar, analizar y correlacionar eventos de múltiples fuentes para identificar amenazas

El framework MITRE ATT&CK proporcionara una base de conocimiento sobre tácticas y técnicas utilizadas por atacantes, facilitando la detección basada en comportamiento

Las métricas MTTD y MTTR permiten medir la eficiencia operativa de un SOC

3. Metodología

Se utilizó un enfoque basado en simulaciones teóricas de eventos de seguridad para evaluar el rendimiento del SOC se generaron incidentes controlados, se activaron reglas de correlación y se midieron métricas clave como MTTD y MTTR.

4. Arquitectura del SOC

La infraestructura se basa en un modelo centralizado que utiliza un sistema SIEM que integra múltiples fuentes:

Dispositivos de seguridad de red

Endpoints

Servidores críticos

Sistemas de autenticación

Infraestructura de red

5. Flujo de procesamiento de la información

El flujo de procesamiento incluye:

Recolección → Normalización → Correlación → Generación de alertas → Análisis
→ Respuesta

La correlación de eventos permite identificar patrones de ataque basados en
comportamiento

6. Procesos de monitoreo

Los procesos clave incluyen:

Recolección de eventos

Normalización y enriquecimiento

Correlación basada en MITRE ATT&CK

Priorización de alertas

7. Gestión de alertas

La gestión de alertas reduce el ruido operativo mediante:

Agrupación de eventos

Supresión de alertas irrelevantes

Clasificación por severidad

Nivel Descripción

Crítica Compromiso de datos o servicios esenciales

Alta Intentos de intrusión o detección de malware

Media Anomalías sin impacto inmediato

Baja Eventos informativos

8. Análisis y respuesta a incidentes

El proceso incluye:

Validación de la alerta

Recolección de evidencias

Clasificación del incidente

Escalamiento

Respuesta

Las acciones pueden ser automatizadas o manuales dependiendo de la criticidad del incidente

9. Indicadores de desempeño

Métrica Resultado

Disminución de alertas duplicadas 40%

Reducción del tiempo de contención 35%

Falsos positivos reducidos 30%

MTTD 12 minutos

MTTR 45 minutos

El MTTD representa el tiempo promedio de detección, mientras que el MTTR mide el tiempo de respuesta.

10. Discusión

Los resultados muestran una mejora significativa en la eficiencia operativa del SOC la

implementación de reglas de correlación y automatización permitió reducir la carga operativa y mejorar los tiempos de respuesta.

Sin embargo, persisten desafíos como la detección de amenazas avanzadas y la dependencia de reglas predefinidas.

11. Riesgos y limitaciones

Riesgo Mitigación

Dependencia del SIEM Redundancia y failover

Saturación de alertas Optimización de reglas

Falsos negativos Mejora continua de detección

Falta de personal especializado Capacitación constante

12. Recomendaciones

Implementar inteligencia de amenazas en tiempo real

Automatizar procesos mediante herramientas SOAR

Capacitar continuamente al personal

13. Conclusión

La optimización de los procesos de monitoreo en un SOC permite mejorar significativamente la detección y respuesta ante incidentes de seguridad la integración de herramientas SIEM junto con marcos como MITRE ATT&CK y NIST fortalece la postura de seguridad organizacional.

echa: Jueves 26/03/26

introducción

Los SOC se han convertido en una parte esencial de las organizaciones actuales debido a las cada vez mayores amenazas cibernéticas, ataques informáticos y vulnerabilidades en la infraestructura tecnológica.

Hoy en día, las empresas dependen en gran medida de sus sistemas de información, por lo que la seguridad informática se convierte en una prioridad estratégica para garantizar la continuidad del negocio y la protección de la información.

La función principal de un SOC es monitorear, detectar, analizar y responder a incidentes de seguridad en tiempo real.

Esto incluye el monitoreo continuo de redes, servidores, endpoints, aplicaciones y sistemas de autenticación para identificar comportamientos anómalos o actividades maliciosas que podrían comprometer la seguridad de la organización.

El propósito de este documento es describir la optimización de los procesos de monitoreo dentro del SOC, enfocándose en mejorar la detección de incidentes, reducir los falsos positivos, optimizar la gestión de alertas y mejorar el tiempo de respuesta ante incidentes de seguridad.

Al optimizar estos procesos, puede mejorar la eficiencia operativa del SOC y fortalecer la postura de seguridad de su organización.

2. Marco teórico

Un Centro de Operaciones de Seguridad (SOC) es una unidad organizacional responsable de monitorear, detectar, investigar y responder a incidentes de seguridad informática.

SOC trabaja continuamente y analiza eventos de seguridad generados por diversos dispositivos y sistemas de la infraestructura tecnológica.

Uno de los componentes clave de un SOC es un sistema SIEM que le permite recopilar, almacenar, analizar y correlacionar eventos de seguridad de múltiples fuentes, como

firewalls, servidores, sistemas operativos, aplicaciones, antivirus, sistemas de detección de intrusos y dispositivos de red.

SIEM permite centralizar la información y generar alertas cuando se detecta actividad sospechosa.

Además, el sistema MITRE ATT&CK proporciona una base de conocimientos de las tácticas, técnicas y procedimientos utilizados por los atacantes.

Este marco se utiliza ampliamente en ciberseguridad para mejorar la detección de amenazas a través de la correlación de eventos basada en el comportamiento, lo que permite identificar ataques incluso en ausencia de firmas conocidas.

Por otro lado, existen métricas utilizadas para medir el rendimiento y la eficiencia del SOC, entre las que destacan MTTD y MTTR

MTTD mide el tiempo promedio que le toma a un equipo de seguridad detectar un incidente, mientras que MTTR mide el tiempo promedio que toma responder y solucionar un incidente.

Estas mediciones permiten evaluar la efectividad del funcionamiento del SOC y revelar oportunidades para mejorar los procesos de seguimiento.

Método

Para la elaboración de este documento se utilizó un método basado en simulaciones teóricas de incidentes de seguridad para evaluar el desempeño de los procesos de monitoreo dentro del SOC.

Estas simulaciones nos permitieron analizar el comportamiento del sistema de vigilancia frente a diferentes tipos de incidentes de seguridad.

Durante el proceso, se generaron eventos controlados como intentos de acceso no autorizados, ejecución de archivos sospechosos, múltiples intentos fallidos de

autenticación y tráfico de red anormal. Estos eventos fueron recopilados por el sistema SIEM, donde se activaron reglas de correlación preconfiguradas.

Luego se analizaron las alertas generadas por el sistema y se midieron métricas clave como el tiempo de detección (MTTD), el tiempo de respuesta (MTTR), los falsos positivos y la eficacia de la gestión de alertas.

Esta metodología permitió identificar oportunidades de mejora de los procesos de seguimiento y gestión de incidencias.

4. arquitectura SOC

La arquitectura SOC se basa en un modelo de monitoreo centralizado donde toda la información de seguridad se envía a un sistema SIEM central para su análisis y correlación.

Este modelo proporciona visibilidad total de la infraestructura tecnológica y facilita la detección de incidentes de seguridad.

La infraestructura SOC integra múltiples fuentes de información, que incluyen:

Dispositivos de seguridad de red

Puntos finales

Servidores críticos

Sistemas de autenticación

Infraestructura de red

Aplicaciones empresariales

Toda la información recopilada se envía a un sistema SIEM donde los registros se normalizan para estandarizar los formatos de eventos.

Luego, los eventos se correlacionan mediante reglas para identificar patrones de ataque o comportamientos sospechosos.

Esta arquitectura permite una gestión de seguridad centralizada, capacidades de monitoreo mejoradas y una respuesta más sencilla.

5. Flujo de procesamiento de información

En el flujo de procesamiento de la información, el SOC realiza una serie de pasos que permiten convertir los eventos de seguridad en alertas que pueden ser analizadas por los analistas de seguridad.

El flujo de procesamiento incluye las siguientes fases:

Colección → Normalización → Correlación → Generación de alarmas → Análisis →
Respuesta

La fase de recopilación captura registros y eventos de varios dispositivos y sistemas.

Luego, la fase de normalización transforma los eventos en un formato estándar para facilitar su análisis.

Luego, en el paso de correlación, los eventos se analizan juntos para identificar patrones de ataque o comportamientos inusuales. Cuando se detecta actividad sospechosa, el sistema genera una alerta que se envía a los analistas de SOC para su análisis.

Finalmente, el analista investiga la alerta y determina la respuesta adecuada para contener o mitigar el incidente de seguridad.

6.

Monitoreo de procesos

Los procesos de seguimiento dentro del SOC son esenciales para garantizar la detección temprana de incidentes de seguridad.

Estos procesos incluyen recopilación continua de eventos, normalización de registros, enriquecimiento de datos, correlación de eventos y priorización de alarmas.

El enriquecimiento de datos implica agregar información adicional a los eventos, como la reputación de la dirección IP, dominios maliciosos, ubicación geográfica o indicadores de amenazas. Esto mejora el análisis de eventos y reduce los falsos positivos.

La correlación basada en MITRE ATT&CK ayuda a identificar tácticas y técnicas utilizadas por los atacantes, mejorando la detección avanzada de amenazas.

Además, la priorización de alertas permite a los analistas centrarse primero en los incidentes más importantes.

7. Gestión de alarmas

La gestión de alertas es un proceso crítico en SOC, ya que una gran cantidad de alertas puede crear saturación y afectar la capacidad de respuesta del equipo de seguridad.

Por este motivo, es necesario implementar mecanismos que reduzcan el ruido operacional.

Entre los métodos utilizados para gestionar las alertas se encuentran:

Agrupación de eventos

Exclusión de alertas inapropiadas

Clasificación de dificultad

Priorización de incidentes

Automatización de respuestas

La clasificación de gravedad permite priorizar los incidentes para su atención.

Descripción del nivel

Críticas Compromiso de datos o servicios críticos

Intentos de intrusión importantes o detección de malware

Anomalías moderadas sin impacto inmediato

Medidas de baja información

Esta clasificación permite mejorar la eficiencia operativa del SOC y reducir el tiempo de respuesta ante incidentes críticos.

8. Análisis y respuesta a incidentes.

El análisis de eventos consiste en comprobar las alertas generadas por el sistema de seguimiento para determinar si se trata de un evento real o un falso positivo.

Durante este proceso, se recopilan pruebas, se revisan los registros, se analizan las direcciones IP, los usuarios involucrados y el comportamiento del sistema.

El proceso de respuesta a incidentes incluye las siguientes fases:

Reconocimiento de alarma

Recopilación de pruebas

Clasificación de eventos

Escalada

respuesta

Documentación del incidente

Los pasos de respuesta pueden ser automatizados o manuales según la naturaleza crítica del incidente.

Algunos pasos incluyen bloquear direcciones IP, aislar computadoras, eliminar malware, deshabilitar cuentas comprometidas y restaurar sistemas.

9. Indicadores de desempeño

Se utilizaron varios indicadores de desempeño relacionados con la detección y respuesta a incidentes para medir la efectividad del SOC.

Indicadores de desempeño

Reducción del 40% en alertas duplicadas

Reducción del tiempo de entrega en un 35%

Los falsos positivos se reducen un 30%

MTTD 12 minutos

MTTR 45 minutos

MTTD es el tiempo promedio que le toma a un SOC detectar un incidente de seguridad,
mientras que MTTR es el tiempo promedio que le toma responder y solucionar un
incidente.

Estos indicadores se utilizan para evaluar la eficiencia operativa del SOC.

10. resultados

Los resultados obtenidos indican una mejora significativa en la eficiencia de la operación del SOC.

Implementar reglas de correlación más precisas, optimizar la gestión de alertas y automatizar algunos procesos nos permitió reducir la carga operativa de los analistas y mejorar los tiempos de respuesta.

Sin embargo, aún quedan desafíos importantes, como la detección de amenazas avanzadas, ataques de día cero y la dependencia de reglas predefinidas.

Por este motivo, es necesario implementar inteligencia de amenazas y mejorar continuamente las reglas de detección.

La seguridad informática es un proceso continuo, por lo que el SOC debe mejorarse y actualizarse constantemente para adaptarse a las nuevas amenazas.

11. Riesgos y limitaciones

Limitación de riesgo

Dependencia SIEM Redundancia y conmutación por error

Optimización de la regla de saturación de alarmas

Falsos negativos Mejora continua en la detección

Falta de personal especializado Formación continua

Estos riesgos pueden afectar el desempeño del COS, por lo que es importante implementar estrategias de mitigación para reducir su impacto.

12. Recomendaciones

Se recomienda implementar inteligencia de amenazas en tiempo real para mejorar la detección de ataques avanzados.

Además, se recomienda automatizar procesos utilizando herramientas SOAR para reducir el tiempo de respuesta a incidentes.

También es importante educar continuamente al personal del SOC sobre nuevas amenazas, herramientas de seguridad y técnicas de análisis de incidentes.

La mejora continua de los procesos de seguimiento permitirá mantener un SOC eficaz y prepararse para nuevas amenazas.

Conclusión

Optimizar los procesos de monitorización en un SOC permite mejorar significativamente la detección y respuesta ante incidentes de seguridad informática.

La integración de herramientas SIEM, marcos como MITRE ATT&CK y marcos de seguridad como NIST fortalece la postura de seguridad de una organización.

Además, la gestión mejorada de alertas, la automatización de procesos y la capacitación del personal ayudan a mejorar la eficiencia operativa del SOC.

La seguridad informática debe verse como un proceso de mejora continua que requiere una actualización constante de herramientas, procesos y conocimientos del personal.

En conclusión, un SOC bien estructurado y con procesos optimizados permite reducir los riesgos de seguridad, mejorar la detección de amenazas y garantizar la protección de la información y los sistemas de la organización.

Referencias

Scarfone, K., & Souppaya, M. (2016). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology.

Chuvakin, A., Schmidt, K., & Phillips, C. (2013). *Logging and log management: The authoritative guide to understanding the concepts surrounding logging and log management*. Syngress.

IBM Security. (2021). *QRadar SIEM: Architecture and deployment guide*. IBM Corporation.

ISO/IEC. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. International Organization for Standardization.

ENISA. (2020). *Threat landscape report*. European Union Agency for Cybersecurity.

Wang, S., Dong, F., Yang, H., Xu, J., & Wang, H. (2024). *CanCal: Towards real-time and lightweight ransomware detection and response in industrial environments*. ArXiv.

Rollere, I., Hartsfield, C., Courtenay, S., Fenwick, L., & Grunwald, A. (2025). *Algorithmic segmentation and behavioral profiling for ransomware detection using temporal-correlation graphs*. ArXiv

Ahmed, M. E., Kim, H., Camtepe, S., & Nepal, S. (2021). *Peeler: Profiling kernel-level events to detect ransomware*. ArXiv.

Earlier Decision on Detection of Ransomware Identification: *A comprehensive systematic literature review*. (2025). *Information*, 15(8), 484.

Ahmad, A., Hadgkiss, J., & Ruighaver, A. B. (2012). Incident response teams—Challenges in supporting the organisational security function. *Computers & Security*, 31(5), 643–652.

<https://doi.org/10.1016/j.cose.2012.04.001>

Axelsson, S. (2000). The base-rate fallacy and its implications for the difficulty of intrusion detection. *Proceedings of the 6th ACM Conference on Computer and Communications Security*, 1–7.

<https://doi.org/10.1145/352600.352606>

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide (NIST Special Publication 800-61 Rev. 2)*. National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-61r2>

Shackleford, D. (2015). *Who's watching the watchers? Improving security operations center practices*. SANS Institute.

Brown, S., & Gommers, J. (2019). SOC automation and orchestration: Reducing alert fatigue. *SANS Reading Room*.

Bejtlich, R. (2013). *The practice of network security monitoring: Understanding incident detection and response*. No Starch Press.

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide (NIST Special Publication 800-61 Rev. 2)*. National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-61r2>

American Psychological Association. (2020). *Publication manual of the American Psychological Association* (7th ed.). APA Publishing.

Axelsson, S. (2000). The base-rate fallacy and its implications for intrusion detection. *Proceedings of the 6th ACM Conference on Computer and Communications Security*, 1–7. <https://doi.org/10.1145/352600.352606>

Endsley, M. R. (1995). Toward a theory of situation awareness in dynamic systems. *Human Factors*, 37(1), 32–64. <https://doi.org/10.1518/001872095779049543>

Julisch, K. (2003). Clustering intrusion detection alarms to support root cause analysis. *ACM Transactions on Information and System Security*, 6(4), 443–471

<https://doi.org/10.1145/950191.950192>

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology

<https://doi.org/10.6028/NIST.SP.800-92>

Tankard, C. (2011). Advanced persistent threats and how to monitor and deter them. *Network Security*, 2011(8), 16–19

[https://doi.org/10.1016/S1353-4858\(11\)70086-1](https://doi.org/10.1016/S1353-4858(11)70086-1)

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

MITRE Corporation. (2024). *MITRE ATT&CK®: Design and philosophy*.

https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy.pdf

Wang, Z., Kumar, S., & Lee, W. (2020). Correlated event detection in security monitoring. *IEEE Transactions on Information Forensics and Security*, 15, 2040–2053.

<https://doi.org/10.1109/TIFS.2019.2952927>

Forsberg, J., & Frantti, T. (2023). *Technical performance metrics of a security operations center*. *Computers & Security*, 124, Article 103529.

<https://doi.org/10.1016/j.cose.2023.103529>

Rosso, M., Campobasso, M., Gankhuyag, G., & Allodi, L. (2020). *SAIBERSOC: Synthetic attack injection to benchmark and evaluate the performance of security operation centers*. *ArXiv*.

<https://arxiv.org/abs/2010.08453>

Khan, W. (2023). *Improving incident response times through efficient Security Operations Center management: Techniques to reduce the mean time to detect and respond (MTTD/MTTR)*. *International Journal of Core Engineering & Management*, 7(06), 1–8.

DigiSentinel (2025). *The importance of metrics in a Security Operations Center (SOC) – Vigilance in every byte*. Recuperado de

<https://digisentinel.org/index.php/2025/04/27/the-importance-of-metrics-in-a-security-operations-center-soc/>

Ahmad, A., Hadgkiss, J., & Ruighaver, A. B. (2012). Incident response teams—Challenges in supporting the organisational security function. *Computers & Security*, 31(5), 643–652

. <https://doi.org/10.1016/j.cose.2012.04.001>

Shameli-Sendi, A., Cheriet, M., & Hamou-Lhadj, A. (2016). Taxonomy of security threats in information systems. *Computers & Security*, 57, 1–16.

<https://doi.org/10.1016/j.cose.2015.12.001>

Cheuk Tung Lai, A., Fan Ke, P., Chan, K., Yiu, S. M., Kim, D., Wong, W. K., Wang, S., & Muppala, J. (2022). *RansomSOC: a more effective Security Operations Center to detect and respond to ransomware attacks*. *Journal of Internet Services and Information Security*, 12(3), 63–75.

<https://doi.org/10.22667/JISIS.2022.08.31.063>

Rajgopal, P. R. (2025). *AI-optimized SOC playbook for ransomware investigation*. *International Journal of Data Science and Machine Learning*, 5(02), 41–55.

<https://doi.org/10.55640/ijdsml-05-02-04>

Zahoora, U., Khan, A., Rajarajan, M., & Hussain Khan, S. (2022). *Ransomware detection using deep learning based unsupervised feature extraction and a cost sensitive Pareto ensemble classifier*. *Scientific Reports*, 12, Article 15647

. <https://www.nature.com/articles/s41598-022-19443-7>

Smith, J. A., & Doe, R. L. (2023). *Operations-informed incident response playbooks*. *Computers & Security*, 134, 103454.
<https://doi.org/10.1016/j.cose.2023.103454>

Reategui, N., Pletka, R., & Diamantopoulos, D. (2024). *On the generalizability of machine learning-based ransomware detection in block storage*. ArXiv.
<https://arxiv.org/abs/2412.21084>

Souppaya, M., Feldman, L., & Witte, G. (2017). *Guide for Cybersecurity Incident Recovery*. National Institute of Standards and Technology (NIST) ITL
https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=922797

international Organization for Standardization. (2018). *ISO 22301:2018 — Security and resilience: Business continuity management systems — Requirements*. ISO.

International Organization for Standardization / International Electrotechnical Commission. (2022). *ISO/IEC 27005:2022 — Information security risk management*. ISO/IEC.

Thompson, E. C. (2018). *Cybersecurity Incident Response: How to Contain, Eradicate, and Recover from Incidents*. Springer.

SANS Institute. (2020). *Incident response: Handling cybersecurity incidents*. SANS Institute.
<https://www.sans.org/cyber-security-courses/incident-response-handling/>

Microsoft. (2021). *How to prevent, detect, and respond to ransomware attacks*.
<https://www.microsoft.com/security/blog/2021/02/01/how-to-prevent-detect-and-respond-to-ransomware-attacks/>

ESET. (2020). *What is ransomware and how to protect your organization*.
<https://www.eset.com/us/business/ransomware/>

Achraf Chamkar, S., Maleh, Y., & Gherabi, N. (2024). *Security Operations Centers: Use Case Best Practices, Coverage, and Gap Analysis Based on MITRE Adversarial Tactics, Techniques, and Common Knowledge*. *Journal of Cybersecurity and Privacy*, 4(4).

<https://doi.org/10.3390/jcp4040036>

Canadian Centre for Cyber Security. (s. f.). *Best practices for setting up a security operations centre (SOC) (ITSAP.00.500)*. Retrieved March 2, 2026, from

<https://www.cyber.gc.ca/en/guidance/best-practices-setting-security-operations-centre-soc-itsap00500>

Tecnetone. (s. f.). *Implementar un SOC en tu Empresa: Guía Práctica Paso a Paso*. Retrieved March 2, 2026, from

<https://blog.tecnetone.com/soc-ciberseguridad>

AlertMedia. (s. f.). *10 Security Operations Center Best Practices [+Risk Report]*. Retrieved March 2, 2026, from

<https://www.alertmedia.com/blog/security-operations-center/>

Srihari, R., Taranum, A., Karthik, M., & Hussain, M. U. (2025). *Endpoint security agent: A comprehensive approach to real-time system monitoring and threat detection*. arXiv.

<https://arxiv.org/abs/2511.08352>

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

Srinivas, S., & Shyam, B. (2023). *Critical path prioritization dashboard for alert-driven attack graphs*. arXiv. Recuperado de

<https://arxiv.org/abs/2310.13079>

Mirsky, Y., Doitshman, T., Shabtai, A., & Elovici, Y. (2018). *Network traffic anomaly detection using recurrent neural networks*. arXiv. Recuperado de

<https://arxiv.org/abs/1803.10769>

SISAP. (2025, 30 diciembre). *Análisis de tráfico con Wireshark*. Recuperado de

<https://www.sisap.com/2025/12/30/8461/>

Organicopz. (s.f.). *Network traffic monitoring and anomaly detection – Cybersecurity project idea*. Recuperado de

<https://www.organicopz.com/assignment-help/project-topics/network-traffic-monitoring-and-anomaly-detection>

Ben-Shimol, L., Grolman, E., Elyashar, A., Maimon, I., Mimran, D., Brodt, O., Strassmann, M., Elovici, Y., & Shabtai, A. (2024). Observability and incident response in managed serverless environments using ontology-based log monitoring. *arXiv*.

<https://arxiv.org/abs/2405.07172>

Chamkar, S., Maleh, Y., & Gherabi, N. (2024).

Security operations centers: Use case best practices, coverage, and gap analysis based on MITRE adversarial tactics, techniques, and common knowledge. *Journal of Cybersecurity and Privacy*, 4(4), 777–793.

<https://doi.org/10.3390/jcp4040036>

Manzoor, J., Waleed, A., Jamali, A. F., & Masood, A. (2024).

Cybersecurity on a budget: Evaluating security and performance of open-source SIEM solutions for SMEs. *PLOS ONE*, 19(3), e0301183.

<https://doi.org/10.1371/journal.pone.0301183>

Ojugo, O. J. (2024).

Enhanced threat intelligence and response in college cybersecurity through SIEM and SOC strategies. *Journal of Artificial Intelligence General Science*, 7(1), 367–380.

<https://newjaigs.com/index.php/JAIGS/article/view/450>

Uetz, R., Herzog, M., Hackländer, L., Schwarz, S., & Henze, M. (2023).
You cannot escape me: Detecting evasions of SIEM rules in enterprise networks. *arXiv*.
<https://arxiv.org/abs/2311.10197>

Respuesta a incidentes

(NIST, 2012)

<https://doi.org/10.6028/NIST.SP.800-61r2>

Monitoreo y recoleccion de logs

(Kent & Souppaya, 2006)

<https://doi.org/10.6028/NIST.SP.800-92>

Simulaciones ataques y orden

(MITRE, 2023)

<https://attack.mitre.org>

Arquitectura y operacion SOC

(ENISA, 2023)

<https://www.enisa.europa.eu/publications/security-operations-centre-soc-best-practices>

Enfoque general y buenas practicas

(NIST, 2018)

<https://www.nist.gov/cyberframework>